# TRƯỜNG ĐẠI HỌC PHENIKAA

# KHOA CÔNG NGHỆ THÔNG TIN




## BÁO CÁO ĐỒ ÁN LIÊN NGÀNH

***Nhóm 13***
***Static Testing, Đặc tả và Test Case phân hệ thủ thư – Hệ thống quản lý thư viện***

***Nguyễn Duy Minh – 23010359***
***Đặng Nhất Nhất – 23010345***
***Nghiêm Đức Việt – 23010636***

***Giảng viên hướng dẫn: ThS. Vũ Quang Dũng***
***Học phần: CSE703093 – An toàn phần mềm***
***Lớp tín chỉ: [Điền vào] · Học kỳ: [Điền vào]***

**Hà Nội, tháng 10 năm 2026**

# Mục lục

**Phân công thực hiện đồ án** ..... **8**
**2. Giới thiệu và mục tiêu** ..... **9**
2.1 Đặt vấn đề ..... 9
2.2 Các giải pháp đã có ..... 10
2.3 Giải pháp đề xuất ..... 11
2.4 Mục tiêu, câu hỏi nghiên cứu, phạm vi và giới hạn ..... 14
*2.4.1* Mục tiêu ..... 14
*2.4.2* Câu hỏi nghiên cứu ..... 15
*2.4.3* Phạm vi ..... 15
*2.4.4* Giới hạn ..... 16
**3. Mô tả hệ thống mục tiêu** ..... **17**
3.1 Hệ thống gốc, baseline và cấu trúc phân hệ `librarian/` ..... 17
*3.1.1* Hệ thống gốc và baseline ..... 17
*3.1.2* Kiến trúc và sơ đồ include ..... 17
*3.1.3* Kiểm kê 66 tệp PHP ..... 18
*3.1.4* Mô hình cơ sở dữ liệu ..... 20
3.2 Yêu cầu chức năng và phi chức năng suy ngược từ mã nguồn ..... 20
*3.2.1* Yêu cầu chức năng ..... 21
*3.2.2* Quy tắc nghiệp vụ ..... 22
*3.2.3* Yêu cầu phi chức năng ..... 24
3.3 Các ràng buộc ..... 25
*3.3.1* Ràng buộc về triển khai ..... 25
*3.3.2* Ràng buộc kinh tế ..... 26
*3.3.3* Ràng buộc về đạo đức ..... 26
3.4 Mô hình hệ thống ..... 26
*3.4.1* Danh sách use-case ..... 26
*3.4.2* Mô hình use-case ..... 27
*3.4.3* Mô hình lớp và đối tượng ..... 28
*3.4.4* Các biểu đồ tuần tự ..... 30
*3.4.5* Các màn hình giao diện người dùng ..... 33
**4. Phương pháp thực hiện** ..... **36**
4.1 Quy trình tổng thể ..... 36
4.2 Kiểm thử tĩnh ..... 38
*4.2.1* Rà soát thủ công theo checklist ..... 38
*4.2.2* Phân tích tự động: lựa chọn và cấu hình công cụ ..... 39
*4.2.3* Thẩm định cảnh báo và gộp thành phát hiện ..... 40
*4.2.4* Kiểm chứng tái lập và toàn vẹn baseline ..... 42
*4.2.5* Kiểm chứng hình thức bổ trợ ..... 43
4.3 Xây dựng đặc tả suy ngược ..... 44
4.4 Thiết kế test case ..... 45
**5. Kết quả và phân tích** ..... **49**
5.1 Kết quả kiểm thử tĩnh ..... 49
*5.1.1* Kết quả rà soát theo checklist ..... 49
*5.1.2* Kết quả công cụ tự động ..... 49
*5.1.3* Thẩm định cảnh báo: chênh lệch giữa cảnh báo thô và phát hiện (RQ-A2) ..... 50
*5.1.4* Sổ phát hiện xác nhận tĩnh (RQ-A1) ..... 53
*5.1.5* Tính tái lập và toàn vẹn baseline (RQ-A3) ..... 54
*5.1.6* Kết quả kiểm chứng hình thức bổ trợ ..... 54
5.2 Kết quả đặc tả (RQ-B1) ..... 55
5.3 Kết quả thiết kế test case (RQ-B2) ..... 57
*5.3.1* Bộ kiểm tra tĩnh đã thực hiện ..... 57

*5.3.2* Bộ test case động đã thiết kế ..... 58
5.4 Phân tích tổng hợp (RQ-AB) ..... 59
5.5 Kiểm thử tĩnh cấp phát bộ nhớ ..... 61
*5.5.1* Phạm vi và các trạng thái ..... 61
*5.5.2* Cấp phát bộ nhớ và chuyển trạng thái qua mệnh đề ..... 62
*5.5.3* Test case và test code ..... 65
*5.5.4* Kết quả chạy và ghi nhận lỗi bộ nhớ ..... 66
*5.5.5* Phân loại theo CWE và CVE ..... 68
**6. Thảo luận và hạn chế ..... 70**
6.1 Ưu, nhược điểm của phương pháp kết hợp thủ công và tự động ..... 70
6.2 Hạn chế ..... 71
6.3 Mối đe dọa đến tính hợp lệ ..... 72
6.4 Hướng phát triển ..... 72
6.5 Tác động xã hội, đạo đức và làm việc chuyên nghiệp ..... 73
**7. Kết luận, tài liệu tham khảo và phụ lục ..... 74**
7.1 Kết luận ..... 74
7.2 Tài liệu tham khảo ..... 75
7.3 Phụ lục ..... 79
*7.3.1* Phụ lục A – Checklist đánh giá ..... 79
*7.3.2* Phụ lục B – Sổ theo dõi phát hiện đầy đủ ..... 81
*7.3.3* Phụ lục C – Cấu hình và tái lập ..... 84
*7.3.4* Phụ lục D – Đặc tả chi tiết ..... 86
*7.3.5* Phụ lục E – Danh mục test case đầy đủ ..... 92
*7.3.6* Phụ lục F – Ma trận truy vết ..... 102
*7.3.7* Phụ lục G – Các thành phần dự án theo template ..... 105
*7.3.8* Phụ lục H – Mô hình trạng thái và so sánh trước, sau khi sửa ..... 107

# Danh mục bảng

**Bảng** 1. So sánh các giải pháp đánh giá an toàn mã nguồn hiện có ..... 11
**Bảng** 2. Mục tiêu cụ thể và tiêu chí hoàn thành ..... 14
**Bảng** 3. Câu hỏi nghiên cứu và mục trả lời trong báo cáo ..... 15
**Bảng** 4. Phạm vi khảo sát và các thành phần loại trừ ..... 15
**Bảng** 5. Thông tin nhận dạng baseline ..... 17
**Bảng** 6. Kiểm kê quy mô phân hệ thủ thư theo nhóm chức năng ..... 18
**Bảng** 7. Phân loại 66 tệp theo vai trò kỹ thuật ..... 19
**Bảng** 8. Các bảng trong schema `eb_lms` và mức độ sử dụng trong phân hệ thủ thư ..... 20
**Bảng** 9. Yêu cầu chức năng suy ngược từ mã nguồn ..... 21
**Bảng** 10. Quy tắc nghiệp vụ suy ngược và các điểm chưa đủ đặc tả ..... 23
**Bảng** 11. Yêu cầu phi chức năng ..... 24
**Bảng** 12. Ràng buộc triển khai suy ra từ mã nguồn ..... 25
**Bảng** 13. Danh sách use-case ..... 27
**Bảng** 14. Các màn hình giao diện chính của phân hệ thủ thư ..... 33
**Bảng** 15. Các giai đoạn thực hiện, sản phẩm và mục tiêu tương ứng ..... 36
**Bảng** 16. Cấu trúc checklist rà soát thủ công ..... 38
**Bảng** 17. Công cụ phân tích tĩnh và cấu hình sử dụng ..... 39
**Bảng** 18. Bốn rule Semgrep tùy biến ..... 40
**Bảng** 19. Tiêu chí phân loại điểm gọi truy vấn và kết luận tương ứng ..... 42
**Bảng** 20. Thang mức ưu tiên định tính ..... 42
**Bảng** 21. Quy tắc gán mức tin cậy cho yêu cầu suy ngược ..... 45
**Bảng** 22. Kỹ thuật thiết kế test case và cách áp dụng ..... 45
**Bảng** 23. Bảng quyết định cho thao tác lập phiếu mượn (UC-16) ..... 46
**Bảng** 24. Tổng hợp kết luận checklist theo nhóm tiêu chí ..... 49
**Bảng** 25. Kết quả chạy công cụ phân tích tĩnh ..... 50
**Bảng** 26. Phân bố 322 cảnh báo theo rule và phát hiện được gộp vào ..... 50
**Bảng** 27. Kết quả phân loại 54 điểm gọi truy vấn ..... 51
**Bảng** 28. Nguồn phát hiện của 11 phát hiện ..... 52
**Bảng** 29. Mười một phát hiện xác nhận tĩnh ..... 53
**Bảng** 30. Kết quả kiểm chứng hình thức ..... 54
**Bảng** 31. Thống kê đặc tả suy ngược theo loại và mức tin cậy ..... 56
**Bảng** 32. Quan sát chức năng suy ra từ đối chiếu đặc tả ..... 57
**Bảng** 33. Kết quả bộ kiểm tra tĩnh trong tệp Excel ..... 57
**Bảng** 34. Phân bố 90 test case động theo module, loại và dự đoán trên baseline ..... 58
**Bảng** 35. Liên hệ giữa phát hiện, khoảng trống đặc tả, yêu cầu bổ sung và test case ..... 59
**Bảng** 36. Lộ trình khắc phục đề xuất và test case kiểm chứng ..... 60

**Bảng** 37. Các trạng thái của đối tượng bộ nhớ ..... 62
**Bảng** 38. Mệnh đề PHP và sự kiện chuyển trạng thái ..... 62
**Bảng** 39. Vết chuyển trạng thái của login.php trong baseline ..... 64
**Bảng** 40. Thành phần test code và test case bộ nhớ ..... 65
**Bảng** 41. Mô hình kích thước bộ đệm C và nhân chứng của Z3 ..... 66
**Bảng** 42. Vi phạm bộ nhớ theo nhóm mã ..... 66
**Bảng** 43. Đối chiếu luật Semgrep với bộ phân tích trên baseline ..... 67
**Bảng** 44. Kết quả công cụ trên mã C trước sửa ..... 68
**Bảng** 45. Phân loại lỗi bộ nhớ theo CWE và CVE tham chiếu ..... 68
**Bảng** 46. Ưu, nhược điểm quan sát được của từng thành phần phương pháp ..... 70
**Bảng** 47. Mối đe dọa đến tính hợp lệ và biện pháp giảm thiểu ..... 72
**Bảng** 48. Kết quả theo mục tiêu cụ thể ..... 74
**Bảng** 49. Kết quả checklist 27 tiêu chí ..... 79
**Bảng** 50. Sổ theo dõi 11 phát hiện xác nhận tĩnh ..... 81
**Bảng** 51. Danh mục tệp bằng chứng và nội dung ..... 84
**Bảng** 52. Đặc tả UC-01 Đăng nhập ..... 86
**Bảng** 53. Đặc tả UC-08 Thêm sách ..... 86
**Bảng** 54. Đặc tả UC-11 Tìm kiếm sách ..... 87
**Bảng** 55. Đặc tả UC-14 Sửa thành viên ..... 87
**Bảng** 56. Đặc tả UC-16 Lập phiếu mượn ..... 87
**Bảng** 57. Đặc tả UC-17 Ghi nhận trả sách ..... 88
**Bảng** 58. Tham số của 23 truy vấn nhận dữ liệu HTTP và miền giá trị theo schema ..... 88
**Bảng** 59. Danh mục 90 test case động (trạng thái: Chưa thực thi) ..... 92
**Bảng** 60. Ma trận truy vết yêu cầu → test case ..... 102
**Bảng** 61. Ma trận truy vết phát hiện → yêu cầu → test case ..... 103
**Bảng** 62. Các mốc thực hiện có bằng chứng trong hồ sơ ..... 105
**Bảng** 63. Kiến thức mới và chiến lược học tập ..... 106
**Bảng** 64. Mô hình Kripke của luồng xác thực và kết quả kiểm tra CTL ..... 107
**Bảng** 65. So sánh trước sửa (_v0) và sau sửa (_v1) trên mã minh họa ..... 107

# Danh mục hình

**Hình** 1. Tổng quan giải pháp đề xuất: kiểm thử tĩnh kết hợp, đặc tả suy ngược và thiết kế test case truy vết được ..... 13
**Hình** 2. Sơ đồ include và ranh giới tin cậy của phân hệ thủ thư (suy ra tĩnh từ mã nguồn)..... 18
**Hình** 3. Mô hình use-case của phân hệ thủ thư kèm misuse case suy ra từ FIND-02..... 28
**Hình** 4. Mô hình miền dữ liệu suy ra từ schema và các phép nối trong mã..... 29
**Hình** 5. Biểu đồ tuần tự luồng đăng nhập (UC-01)..... 30
**Hình** 6. Biểu đồ tuần tự luồng thêm và lưu trữ sách (UC-08, UC-10); luồng sửa sách qua `edit_book.php` → `update_books.php` có cấu trúc tương tự..... 31
**Hình** 7. Biểu đồ tuần tự luồng lập phiếu mượn (UC-16) ..... 32
**Hình** 8. Biểu đồ tuần tự luồng ghi nhận trả sách (UC-17) ..... 32
**Hình** 9. Màn hình đăng nhập của phân hệ thủ thư (`index.php`; nguồn: upstream `screenshots/`)..... 34
**Hình** 10. Màn hình danh sách sách (`books.php`; nguồn: upstream `screenshots/`)..... 34
**Hình** 11. Màn hình thêm thành viên (`add_member.php`; nguồn: upstream `screenshots/`).. 35
**Hình** 12. Quy trình thực hiện năm giai đoạn và vòng lặp thẩm định lại ..... 37
**Hình** 13. Quy trình thẩm định một cảnh báo..... 41
**Hình** 14. Mô hình chuyển trạng thái dùng cho kỹ thuật ST: phiên đăng nhập và chi tiết mượn . 47
**Hình** 15. Cây phân loại 54 điểm gọi truy vấn theo nguồn dữ liệu ..... 51
**Hình** 16. Ba nguyên nhân gốc liên kết phát hiện, yêu cầu bổ sung và test case ..... 60
**Hình** 17. Các chuyển trạng thái chính của đối tượng bộ nhớ; FALSE, NOROW và DONE chỉ có trong mô hình cụ thể dùng cho Z3 ..... 64
**Hình** 18. Các mốc thực hiện có bằng chứng ..... 105

# Danh mục từ viết tắt

| Từ viết tắt | Tiếng Anh | Nghĩa tiếng Việt |
|---|---|---|
| AC | Access Control | Kiểm soát truy cập |
| ACM | Association for Computing Machinery | Hiệp hội Máy tính Hoa Kỳ |
| AI | Artificial Intelligence | Trí tuệ nhân tạo |
| API | Application Programming Interface | Giao diện lập trình ứng dụng |
| AST | Abstract Syntax Tree | Cây cú pháp trừu tượng |
| ASVS | Application Security Verification Standard | Tiêu chuẩn kiểm chứng an toàn ứng dụng của OWASP |
| BR | Business Rule | Quy tắc nghiệp vụ |
| BVA | Boundary Value Analysis | Phân tích giá trị biên |
| CI | Continuous Integration | Tích hợp liên tục |
| CLI | Command-Line Interface | Giao diện dòng lệnh |
| CNF | Conjunctive Normal Form | Dạng chuẩn hội của công thức logic |
| CRUD | Create, Read, Update, Delete | Thêm, đọc, sửa, xóa |
| CSDL | — | Cơ sở dữ liệu |
| CSRF | Cross-Site Request Forgery | Giả mạo yêu cầu liên trang |
| CVSS | Common Vulnerability Scoring System | Hệ thống chấm điểm mức độ lỗ hổng |
| CWE | Common Weakness Enumeration | Danh mục điểm yếu phần mềm phổ biến |
| DAST | Dynamic Application Security Testing | Kiểm thử an toàn ứng dụng động |
| DDL | Data Definition Language | Ngôn ngữ định nghĩa dữ liệu |
| DPLL | Davis–Putnam–Logemann–Loveland | Thuật toán giải SAT bằng lan truyền đơn vị và quay lui |
| DT | Decision Table | Bảng quyết định |
| EP | Equivalence Partitioning | Phân vùng tương đương |
| FN | False Negative | Bỏ sót (âm tính giả) |
| FP | False Positive | Cảnh báo giả (dương tính giả) |
| FR | Functional Requirement | Yêu cầu chức năng |
| HT | — | Hiện trạng (loại yêu cầu phi chức năng) |
| HTML | HyperText Markup Language | Ngôn ngữ đánh dấu siêu văn bản |
| HTTP | Hypertext Transfer Protocol | Giao thức truyền siêu văn bản |
| IDOR | Insecure Direct Object Reference | Tham chiếu trực tiếp đối tượng không an toàn |
| IEC | International Electrotechnical Commission | Ủy ban Kỹ thuật Điện quốc tế |
| IEEE | Institute of Electrical and Electronics Engineers | Viện Kỹ sư Điện và Điện tử |
| ISO | International Organization for Standardization | Tổ chức Tiêu chuẩn hóa quốc tế |
| JSON | JavaScript Object Notation | Định dạng trao đổi dữ liệu JSON |
| KT | — | Kỹ thuật thiết kế test case |
| KV | — | Kỳ vọng (loại yêu cầu phi chức năng) |
| LOC | Lines of Code | Số dòng mã (dòng vật lý) |

| Từ viết tắt | Tiếng Anh | Nghĩa tiếng Việt |
|---|---|---|
| NFR | Non-Functional Requirement | Yêu cầu phi chức năng |
| NIST | National Institute of Standards and Technology | Viện Tiêu chuẩn và Công nghệ quốc gia Hoa Kỳ |
| OSS | Open Source Software | Phần mềm mã nguồn mở |
| OWASP | Open Worldwide Application Security Project | Dự án mở về an toàn ứng dụng |
| PDO | PHP Data Objects | Lớp truy cập CSDL hướng đối tượng của PHP |
| PHP | PHP: Hypertext Preprocessor | Ngôn ngữ kịch bản phía máy chủ PHP |
| PK | Primary Key | Khóa chính |
| QS | — | Quan sát chức năng |
| RBAC | Role-Based Access Control | Kiểm soát truy cập theo vai trò |
| RQ | Research Question | Câu hỏi nghiên cứu |
| SAST | Static Application Security Testing | Kiểm thử an toàn ứng dụng tĩnh |
| SAT | Boolean Satisfiability | Bài toán thỏa mãn logic mệnh đề |
| SEC | Security test case | Test case an toàn suy ra từ CWE |
| SHA-256 | Secure Hash Algorithm 256-bit | Hàm băm an toàn 256 bit |
| SLOC | Source Lines of Code | Số dòng mã thực (không tính dòng trắng, chú thích) |
| SMT | Satisfiability Modulo Theories | Bài toán thỏa mãn theo lý thuyết |
| SQL | Structured Query Language | Ngôn ngữ truy vấn có cấu trúc |
| SQLi | SQL Injection | Chèn mã SQL |
| SRS | Software Requirements Specification | Đặc tả yêu cầu phần mềm |
| ST | State Transition testing | Kiểm thử chuyển trạng thái |
| TC | Test Case | Ca kiểm thử |
| UC | Use Case | Ca sử dụng |
| UNSAT | Unsatisfiable | Không thỏa mãn được |
| URL | Uniform Resource Locator | Định vị tài nguyên thống nhất |
| WSTG | Web Security Testing Guide | Hướng dẫn kiểm thử an toàn web của OWASP |
| XSS | Cross-Site Scripting | Chèn mã kịch bản liên trang |

## Phân công thực hiện đồ án

| Mã sinh viên | Họ và tên | Lớp | Nhiệm vụ |
|---|---|---|---|
| 23010359 | Nguyễn Duy Minh | [Điền vào] | A1, A2, A3, A4, A5, C2 |
| 23010345 | Đặng Nhất Nhất | [Điền vào] | B1, B2, B3, B4, B5 |
| 23010636 | Nghiêm Đức Việt | [Điền vào] | D1, D2, D3, D4, C1 |

Cột "Nhiệm vụ" ghi các mã nhiệm vụ theo danh mục dưới đây (mảng (A) Static testing, mảng (B) Đặc tả và test case, (C) công việc chung, (D) kiểm chứng hình thức và bộ nhớ).

| Mã | Mảng | Nhiệm vụ | Sản phẩm bàn giao |
|---|---|---|---|
| A1 | (A) Static testing | Thiết lập baseline, kiểm kê phạm vi 66 tệp PHP, đo LOC/SLOC, tính SHA-256 | Hồ sơ baseline, danh mục phạm vi |
| A2 | (A) Static testing | Xây dựng checklist 7 nhóm và rà soát mã thủ công | Checklist đã đánh giá (Phụ lục A) |
| A3 | (A) Static testing | Cấu hình, chạy Semgrep và PHPStan; lưu phiên bản, lệnh, mã thoát và output thô | Kết quả quét thô, cấu hình rule (Phụ lục C) |
| A4 | (A) Static testing | Thẩm định cảnh báo, gộp theo nguyên nhân gốc, phân loại, gán CWE và mức độ, đề xuất khắc phục | Sổ theo dõi phát hiện (Phụ lục B) |
| A5 | (A) Static testing | Kiểm chứng tái lập (Run 1 vs Run 2, đối chiếu checksum) | Biên bản tái lập |
| B1 | (B) Đặc tả & test case | Suy ngược yêu cầu FR/NFR/BR từ mã nguồn và schema, gán mức tin cậy | Đặc tả chi tiết (Phụ lục D) |
| B2 | (B) Đặc tả & test case | Mô hình hóa use-case, lớp/đối tượng, biểu đồ tuần tự, màn hình chính | Mục 3.4 |
| B3 | (B) Đặc tả & test case | Thiết kế test case chức năng (phân vùng tương đương, giá trị biên, bảng quyết định, chuyển trạng thái) | Danh mục test case (Phụ lục E) |
| B4 | (B) Đặc tả & test case | Thiết kế test case an toàn và hồi quy suy ra từ phát hiện/CWE | Danh mục test case (Phụ lục E) |
| B5 | (B) Đặc tả & test case | Lập ma trận truy vết Requirement ↔ Finding ↔ Test case, tính tỷ lệ phủ | Ma trận truy vết (Phụ lục F) |
| C1 | Chung | Biên soạn, định dạng báo cáo theo template, kiểm tra nhất quán số liệu | Báo cáo hoàn chỉnh |
| C2 | Chung | Lập kế hoạch dự án, Gantt chart, điều phối làm việc nhóm | Phụ lục G |
| D1 | (D) Hình thức & bộ nhớ | Sinh mã _v0/_v1 cho 5 chức năng và 54 truy vấn SQL; lint, Semgrep trên mã sinh | Mã _v0/_v1 (Phụ lục H) |
| D2 | (D) Hình thức & bộ nhớ | Mô hình hóa xác thực, phân quyền, SQL thành CNF; giải DPLL, đối chiếu Z3 | 178 bài toán SAT (mục 5.1.6) |
| D3 | (D) Hình thức & bộ nhớ | Mô hình hóa guard, token, độ dài khóa, secret key bằng SMT/Z3 | 562 bài toán SMT (mục 5.1.6) |
| D4 | (D) Hình thức & bộ nhớ | Kiểm thử tĩnh bộ nhớ: trạng thái, chuyển trạng thái, test code, CWE/CVE | Mục 5.5 |

# 2. Giới thiệu và mục tiêu

## 2.1 Đặt vấn đề

Hệ thống quản lý thư viện là loại ứng dụng web phổ biến ở trường học và các tổ chức quy mô nhỏ. Ứng dụng xử lý bốn nhóm dữ liệu chính: tài khoản thủ thư, danh mục sách, hồ sơ thành viên (độc giả) và giao dịch mượn – trả. Các dữ liệu này gồm thông tin định danh cá nhân, thông tin xác thực và lịch sử mượn sách. Sai sót tại khâu xác thực, phân quyền hoặc truy vấn cơ sở dữ liệu (CSDL) có thể làm mất tính bí mật và tính toàn vẹn của toàn bộ dữ liệu thư viện. Bảng xếp hạng OWASP Top 10 phiên bản 2021 đặt Broken Access Control (kiểm soát truy cập bị phá vỡ) ở vị trí A01 và Injection (chèn mã, gồm SQL Injection và Cross-Site Scripting) ở vị trí A03 [1]. Đây cũng là hai nhóm rủi ro thường gặp trong ứng dụng PHP viết theo lối thủ tục. Các điểm yếu tương ứng được định danh trong danh mục CWE (Common Weakness Enumeration – danh mục điểm yếu phần mềm phổ biến) [2].

Đồ án chọn đối tượng là hệ thống mã nguồn mở Library-Management-System của tác giả Vinit Shahdeo, giấy phép MIT, chốt tại commit `082d6fb9bdd7846b57033513791ba5b6d2095c11` [3]. Phân hệ thủ thư `librarian/` là phần quản trị nội bộ của hệ thống, gồm 66 tệp PHP với 2.978 dòng vật lý và 2.551 dòng mã thực (SLOC). Mã nguồn có ba đặc điểm làm tăng rủi ro an toàn:

- Mã PHP thủ tục trộn lẫn với HTML, không có lớp truy cập dữ liệu dùng chung. Mỗi tệp tự mở kết nối qua `dbcon.php` và tự ghép câu lệnh SQL.
- Toàn bộ thao tác CSDL dùng phần mở rộng `ext/mysql` (các hàm `mysql_*`). Phần mở rộng này đã bị loại khỏi PHP từ phiên bản 7.0 [4] và không hỗ trợ truy vấn tham số (prepared statement).
- Kiểm tra phiên đăng nhập được đặt rải rác bằng `include('session.php')` ở từng trang, không có cơ chế kiểm soát truy cập tập trung.

Bên cạnh rủi ro trong mã, hệ thống thiếu hai loại tài liệu làm căn cứ cho việc đánh giá và sửa lỗi. Thứ nhất, upstream không có tài liệu đặc tả yêu cầu phần mềm (SRS – Software Requirements Specification) chính thức. Thư mục `PROJECT REPORT/` của upstream chỉ chứa các báo cáo môn học mô tả chức năng ở mức tổng quát; mô hình dữ liệu trong các báo cáo này (nhân viên, giảng viên, tiền phạt) không khớp với tám bảng của schema `db/eb_lms.sql` (`book`, `borrow`, `borrowdetails`, `category`, `lost_book`, `member`, `type`, `users`). Thứ hai, cây mã nguồn tại commit baseline không có tệp kiểm thử nào thuộc mã của tác giả; các tệp kiểm thử đơn vị duy nhất nằm trong thư viện bên thứ ba `librarian/vendors/datatables/`.

Việc thiếu đặc tả và kiểm thử dẫn đến ba hệ quả:

1. Không có căn cứ chính thức để xác định hành vi "đúng" đối với các quy tắc nghiệp vụ, chẳng hạn hạn mức số sách mượn hay việc kiểm tra số bản sách còn lại trước khi cho mượn.
2. Không có ca kiểm thử để phát hiện lỗi tái phát (hồi quy) khi sửa lỗ hổng, đặc biệt khi phải chuyển toàn bộ tầng CSDL sang API mới.
3. Việc đánh giá an toàn dễ rơi vào hai thái cực: coi mọi cảnh báo thô của công cụ là lỗ hổng, hoặc kết luận vi phạm nghiệp vụ khi chưa có quy định nào để đối chiếu.

Từ đó, vấn đề đồ án đặt ra là: *làm thế nào đánh giá an toàn mã nguồn phân hệ thủ thư với bằng chứng truy vết được đến tệp và dòng, đồng thời xây dựng đặc tả và bộ test case làm cơ sở cho việc sửa lỗi và kiểm thử hồi quy, trong điều kiện không chạy ứng dụng*. Điều kiện không chạy ứng dụng xuất phát từ hai lý do. Về an toàn, mã baseline chứa lỗ hổng đã biết nên không được triển khai hay thử khai thác. Về kỹ thuật, `ext/mysql` không còn trong các phiên bản PHP hiện hành.

## 2.2 Các giải pháp đã có

Có ba hướng tiếp cận chính để đánh giá an toàn mã nguồn ứng dụng web. Mỗi hướng có thế mạnh và hạn chế riêng (Bảng 1).

**Kiểm thử động (DAST – Dynamic Application Security Testing, kiểm thử an toàn ứng dụng động).** Người kiểm thử hoặc công cụ gửi yêu cầu HTTP tới ứng dụng đang chạy rồi quan sát phản hồi. OWASP Web Security Testing Guide (WSTG) mô tả quy trình và kịch bản cho hướng này [5]. Ưu điểm của DAST là xác nhận được khả năng khai thác trong môi trường cụ thể và ít cảnh báo giả với các lỗi quan sát được qua phản hồi. Hạn chế là DAST cần môi trường chạy tương thích (với hệ thống này là PHP 5.x cùng `ext/mysql` và MySQL) cùng dữ liệu mẫu. Độ phủ của DAST phụ thuộc vào các luồng được kích hoạt nên dễ bỏ sót endpoint không có liên kết từ giao diện. DAST cũng khó chỉ ra nguyên nhân gốc trong mã và có nguy cơ làm hỏng dữ liệu khi thử dữ liệu tấn công lên các thao tác ghi, xóa.

**Kiểm thử an toàn tĩnh tự động (SAST – Static Application Security Testing).** Công cụ phân tích mã nguồn mà không thực thi chương trình, dựa trên so khớp mẫu trên cây cú pháp trừu tượng (AST) hoặc phân tích luồng dữ liệu nhiễm bẩn (taint analysis) từ nguồn (source) tới điểm sử dụng nguy hiểm (sink) [6]. Với PHP, Semgrep hỗ trợ cả bộ rule cộng đồng lẫn rule tự viết [7]; PHPStan là công cụ phân tích kiểu và cấu trúc [8]. SAST có ưu điểm là nhanh, quét được toàn bộ tệp, kết quả tất định và chỉ ra vị trí tệp, dòng cụ thể. Tuy vậy, SAST có hai giới hạn cố hữu. Một là cảnh báo giả (FP) khi công cụ thiếu ngữ cảnh về kiểu hoặc nguồn gốc dữ liệu. Hai là bỏ sót (FN) đối với lỗi logic và lỗi *thiếu kiểm soát*: khi một handler không kiểm tra phiên, không có đoạn mã nào để công cụ so khớp. Công cụ

kiểm tra kiểu như PHPStan chủ yếu phát hiện lỗi kiểu, lỗi cấu trúc và tham chiếu không tồn tại, không nhắm tới SQL Injection hay XSS trong mã thủ tục.

**Rà soát mã thủ công (manual code review) theo bảng kiểm.** Người đánh giá đọc mã theo các tiêu chí định sẵn, đối chiếu luồng dữ liệu, luồng include và mô hình dữ liệu. NIST SP 800-115 xếp rà soát mã vào nhóm kỹ thuật đánh giá tĩnh [9]. Rà soát thủ công hiểu được ngữ cảnh nên phát hiện tốt lỗi kiểm soát truy cập, lỗi nghiệp vụ và lỗi liên tệp. Đổi lại, phương pháp này tốn công, phụ thuộc kinh nghiệm người rà soát, khó lặp lại giữa các người đánh giá và dễ bỏ sót khi quy mô mã lớn.

***Bảng** 1. So sánh các giải pháp đánh giá an toàn mã nguồn hiện có*

| Tiêu chí | DAST | SAST | Rà soát thủ công |
|---|---|---|---|
| Cần chạy ứng dụng, CSDL | Có | Không | Không |
| Độ phủ mã nguồn | Theo luồng được kích hoạt | Toàn bộ tệp trong phạm vi quét | Theo tiêu chí và thời gian rà soát |
| Hiểu ngữ cảnh, logic nghiệp vụ | Trung bình (qua hành vi quan sát) | Thấp | Cao |
| Cảnh báo giả (FP) | Thấp với lỗi quan sát được | Cao, phụ thuộc rule | Thấp |
| Bỏ sót (FN) điển hình | Endpoint ẩn, lỗi cần trạng thái đặc biệt | Thiếu kiểm soát, lỗi logic, lỗi liên tệp | Mẫu lặp lại trên diện rộng |
| Tính tái lập | Phụ thuộc dữ liệu, môi trường | Cao (tất định khi cố định phiên bản, rule) | Thấp – trung bình |
| Bằng chứng | Yêu cầu và phản hồi HTTP | Tệp, dòng, rule ID | Tệp, dòng, lập luận |
| Phù hợp với điều kiện đồ án | Không (vi phạm nguyên tắc phi thực thi) | Có | Có |

Cả ba hướng trên còn chung một giả định: phải có *cơ sở kiểm thử* (test basis), tức đặc tả quy định hành vi đúng, để phán định kết quả. Các kỹ thuật thiết kế kiểm thử chuẩn như phân vùng tương đương, phân tích giá trị biên, bảng quyết định hay chuyển trạng thái trong ISO/IEC/IEEE 29119-4 đều suy ra ca kiểm thử từ cơ sở kiểm thử này [10]. Khi không có SRS, một cách làm phổ biến là suy ngược đặc tả từ mã nguồn hiện có. Cách làm này có rủi ro: nếu chép nguyên hành vi hiện tại thành yêu cầu, chính các lỗ hổng sẽ bị "hợp thức hóa" thành hành vi đúng.

## 2.3 Giải pháp đề xuất

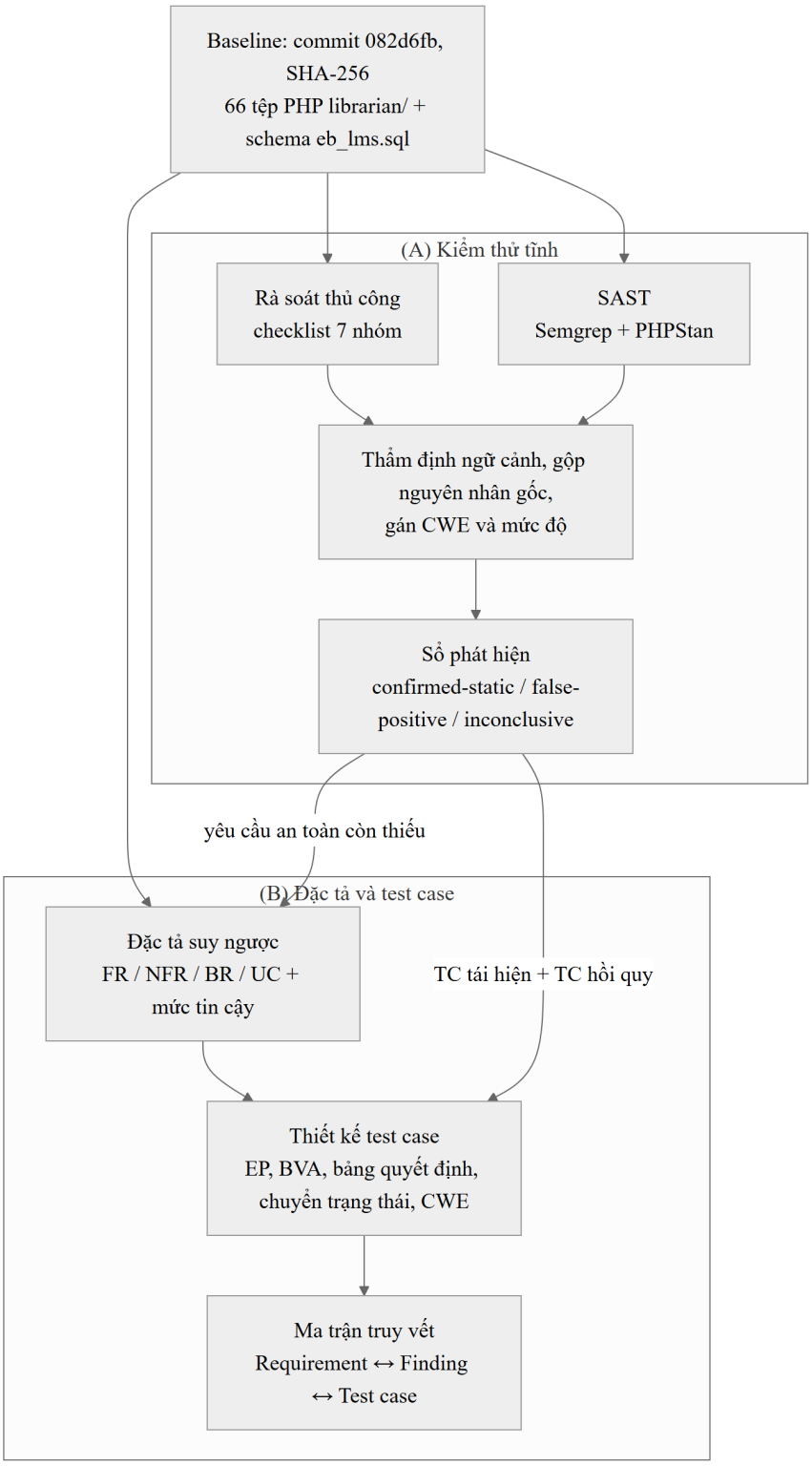
Đồ án đề xuất một quy trình gồm ba thành phần nối tiếp nhau, trong đó đầu ra của thành phần trước là đầu vào của thành phần sau (Hình 1).

**(1) Kiểm thử tĩnh kết hợp thủ công và tự động.** Rà soát thủ công theo bảng kiểm gồm bảy nhóm tiêu chí: xác thực và phiên (AUTH), kiểm soát truy cập (AC), đầu vào và truy

vấn (INP), mã hóa đầu ra (OUT), thao tác đổi trạng thái (STATE), xử lý lỗi (ERR) và toàn vẹn nghiệp vụ (BIZ). Song song, Semgrep quét toàn bộ phạm vi bằng bộ rule cộng đồng kết hợp rule tùy biến, còn PHPStan kiểm tra cấu trúc. Mỗi cảnh báo được thẩm định theo ngữ cảnh mã và gán một trong ba trạng thái: `confirmed-static` (xác nhận bằng phân tích tĩnh), `false-positive` (cảnh báo giả) hoặc `inconclusive` (chưa đủ căn cứ). Các cảnh báo cùng nguyên nhân gốc được gộp thành một phát hiện, gán mã CWE [2] và mức độ ưu tiên định tính từ Critical đến Low. Cuối cùng, quy trình quét được chạy lặp lại để kiểm chứng tính tái lập.

**(2) Đặc tả suy ngược có phân tầng tin cậy.** Yêu cầu chức năng (FR), yêu cầu phi chức năng (NFR), quy tắc nghiệp vụ (BR) và ca sử dụng (UC) được trích từ mã nguồn và schema. Mỗi yêu cầu ghi rõ nguồn trong mã (tệp, hàm hoặc dòng) và mức tin cậy: *rõ ràng*, *suy luận* hoặc *chưa đủ đặc tả*. Đặc tả tách bạch hai lớp. Lớp thứ nhất là *hành vi hiện có*, mô tả mã đang làm gì. Lớp thứ hai là *yêu cầu an toàn kỳ vọng*, xây dựng từ các phát hiện và tiêu chuẩn tham chiếu như OWASP ASVS [11]. Nhờ vậy, lỗ hổng không bị chép thành yêu cầu. Các quy tắc nghiệp vụ không có trong mã và không có văn bản quy định được ghi là câu hỏi mở cần chủ sở hữu sản phẩm xác nhận, không bị gán là lỗi. Cách ghi yêu cầu tuân theo các đặc tính của ISO/IEC/IEEE 29148: rõ ràng, kiểm chứng được và truy vết được [12].

**(3) Thiết kế test case truy vết được.** Test case được thiết kế bằng các kỹ thuật của ISO/IEC/IEEE 29119-4 [10] và các kỹ thuật kinh điển [13]: phân vùng tương đương, phân tích giá trị biên, bảng quyết định và kiểm thử chuyển trạng thái. Bổ sung cho các kỹ thuật này là test case an toàn suy ra từ từng mã CWE của phát hiện. Hồ sơ test case theo cấu trúc tài liệu kiểm thử của ISO/IEC/IEEE 29119-3 [14], vốn thay thế IEEE 829 [15]. Mỗi phát hiện được xác nhận có ít nhất hai test case: một test case tái hiện lỗi trên bản gốc và một test case hồi quy dùng sau khi sửa. Ma trận truy vết hai chiều Requirement ↔ Finding ↔ Test case cho phép đo tỷ lệ phủ yêu cầu và tỷ lệ phủ phát hiện.




***Hình** 1. Tổng quan giải pháp đề xuất: kiểm thử tĩnh kết hợp, đặc tả suy ngược và thiết kế test case truy vết được*

Điểm khác biệt của giải pháp so với việc áp dụng riêng lẻ từng hướng ở mục 2.2 nằm ở hai liên kết. Liên kết thứ nhất đi từ phát hiện tĩnh sang đặc tả: mỗi phát hiện sinh ra hoặc làm rõ một yêu cầu an toàn còn thiếu. Liên kết thứ hai đi từ đặc tả và phát hiện sang test case: mỗi yêu cầu và mỗi phát hiện đều có test case kiểm chứng. Kết quả là một bộ hồ sơ có thể chuyển tiếp sang giai đoạn sửa lỗi và kiểm thử động sau này. Các test case trong đồ án *chỉ ở mức thiết kế* và mang trạng thái "Chưa thực thi".

## 2.4 Mục tiêu, câu hỏi nghiên cứu, phạm vi và giới hạn

### *2.4.1* Mục tiêu

**Mục tiêu tổng quát:** Đánh giá an toàn mã nguồn phân hệ thủ thư bằng kiểm thử tĩnh có bằng chứng truy vết; trên cơ sở đó xây dựng đặc tả suy ngược và bộ test case truy vết được, làm nền cho việc sửa lỗi và kiểm thử hồi quy.

Các mục tiêu cụ thể và tiêu chí hoàn thành được trình bày trong Bảng 2.

***Bảng** 2. Mục tiêu cụ thể và tiêu chí hoàn thành*

| Mã | Mảng | Mục tiêu cụ thể | Tiêu chí hoàn thành |
|---|---|---|---|
| MT-A1 | (A) | Thiết lập baseline bất biến, kiểm kê phạm vi | Kiểm kê đủ 66 tệp PHP; mã băm SHA-256 trước và sau nghiên cứu trùng khớp |
| MT-A2 | (A) | Rà soát thủ công theo checklist 7 nhóm | Mọi tiêu chí có kết luận (Đạt / Không đạt / N/A / Thiếu đặc tả) kèm bằng chứng tệp:dòng hoặc lý do |
| MT-A3 | (A) | Chạy SAST bằng Semgrep và PHPStan | Lưu đủ phiên bản công cụ, lệnh chạy, mã thoát, lỗi công cụ và output thô |
| MT-A4 | (A) | Thẩm định và gộp cảnh báo thành phát hiện | Mỗi phát hiện có trạng thái, CWE, mức độ, vị trí tệp:dòng và khuyến nghị sửa |
| MT-A5 | (A) | Kiểm chứng tái lập | Hai lần quét cùng điều kiện được so khớp theo chữ ký cảnh báo; báo cáo độ lệch |
| MT-B1 | (B) | Suy ngược đặc tả FR, NFR, BR | Mỗi yêu cầu có ID, nguồn trong mã và mức tin cậy |
| MT-B2 | (B) | Mô hình hóa hệ thống | Có danh sách use-case, mô hình use-case, biểu đồ tuần tự cho đăng nhập, CRUD, mượn sách; chỉ vẽ phần có trong mã |
| MT-B3 | (B) | Thiết kế test case | Mỗi chức năng có ≥ 1 TC positive và ≥ 1 TC negative; mỗi phát hiện xác nhận có ≥ 2 TC (tái hiện và hồi quy); trạng thái "Chưa thực thi" |
| MT-B4 | (B) | Lập ma trận truy vết hai chiều | Tính được tỷ lệ yêu cầu có TC và tỷ lệ phát hiện có TC; mục tiêu cả hai đạt 100% |

### *2.4.2* Câu hỏi nghiên cứu

Đồ án trả lời sáu câu hỏi nghiên cứu (RQ), chia theo hai mảng và một câu hỏi liên kết (Bảng 3).

***Bảng** 3. Câu hỏi nghiên cứu và mục trả lời trong báo cáo*

| Mã | Câu hỏi nghiên cứu | Mục trả lời |
|---|---|---|
| RQ-A1 | Phân hệ `librarian/` chứa những điểm yếu an toàn nào có thể xác nhận bằng phân tích tĩnh, và chúng phân bố theo mức độ, theo CWE như thế nào? | 5.1 |
| RQ-A2 | Cảnh báo thô của công cụ SAST chênh lệch bao nhiêu so với phát hiện xác nhận sau thẩm định thủ công? Nguyên nhân gây cảnh báo giả là gì, và loại lỗi nào chỉ rà soát thủ công mới phát hiện được? | 5.1, 6.1 |
| RQ-A3 | Kết quả phân tích tự động có tái lập được khi cố định baseline, phiên bản công cụ và bộ rule không? | 5.1 |
| RQ-B1 | Khi không có SRS, có thể suy ngược đặc tả FR, NFR, BR từ mã nguồn và schema đến mức tin cậy nào? Điểm nào không thể đặc tả nếu thiếu xác nhận nghiệp vụ? | 5.2 |
| RQ-B2 | Bộ test case thiết kế từ đặc tả suy ngược và phát hiện tĩnh có đạt các tiêu chí phủ của MT-B3 và MT-B4 không? | 5.3 |
| RQ-AB | Các lỗ hổng phát hiện liên hệ như thế nào với khoảng trống đặc tả và kiểm thử của hệ thống? | 5.4 |

### *2.4.3* Phạm vi

Phạm vi khảo sát gồm các tệp PHP nằm *trực tiếp* trong thư mục `librarian/` tại commit baseline, cùng tệp schema `db/eb_lms.sql`. Schema chỉ được đọc để xác định bảng, khóa, kiểu dữ liệu và storage engine; không được nạp vào bất kỳ hệ quản trị CSDL nào. Số liệu kiểm kê và danh mục loại trừ lấy theo hồ sơ phạm vi của nhóm [16] và đã được đếm lại trên bản sao baseline. Các thành phần loại trừ và lý do được nêu trong Bảng 4.

***Bảng** 4. Phạm vi khảo sát và các thành phần loại trừ*

| Thành phần | Phạm vi | Lý do |
|---|---|---|
| 66 tệp `librarian/*.php` (2.978 dòng vật lý; 2.551 SLOC) | Trong | Mã do tác giả viết, thuộc phân hệ quản trị của thủ thư |
| `db/eb_lms.sql` (8 bảng) | Trong (chỉ đọc) | Xác định cấu trúc dữ liệu, kiểu cột, engine |
| `librarian/vendors/` (gồm 18 tệp PHP mẫu) | Ngoài | Thư viện bên thứ ba, không phải mã của tác giả; quét chung sẽ gây nhiễu |
| Tệp không phải `.php` trong `librarian/` (ví dụ `view.return`, `view_return.txt`) | Ngoài | Không được máy chủ thực thi như mã PHP |

| Thành phần | Phạm vi | Lý do |
|---|---|---|
| `library/` và `library.zip` | Ngoài | Bản sao cũ của hệ thống; tránh đếm trùng lỗi |
| 25 tệp PHP ở thư mục gốc (cổng độc giả công cộng) | Ngoài | Thuộc phân hệ khác, không phải phân hệ thủ thư |
| Tài sản tĩnh (CSS, JavaScript phía client, hình ảnh, font) | Ngoài | Không chứa logic xử lý phía máy chủ |
| Tài liệu upstream (`PROJECT REPORT/`, `PPTs/`, `screenshots/`) | Tham khảo | Chỉ dùng để đối chiếu mô tả chức năng, không phải đối tượng kiểm thử |

Hai thành phần có trong template là kiểm thử mờ (fuzzing) và cột CVE minh họa không được thực hiện. Fuzzing cần chạy ứng dụng và gửi đầu vào thật tới máy chủ, trái với nguyên tắc không thực thi mã upstream của đồ án; thay vào đó, các giá trị biên và đầu vào bất thường được thiết kế thành test case động (mục 4.4) để chạy ở giai đoạn sau. Các phát hiện được phân loại theo CWE thay vì gán mã CVE, vì đây là điểm yếu của một bản mã nguồn cụ thể, chưa được công bố qua quy trình cấp mã CVE.

### *2.4.4* Giới hạn

Đồ án được thực hiện trong các giới hạn sau. Các giới hạn này được phân tích lại ở Chương 6.

- **Phi thực thi hoàn toàn.** Đồ án chỉ dùng phân tích tĩnh: không chạy ứng dụng, không kết nối CSDL, không gửi yêu cầu HTTP và không khai thác động. Tác động của mỗi lỗ hổng chỉ được đánh giá ở mức lý thuyết, có điều kiện, dựa trên đường đi của dữ liệu trong mã.
- **Test case chưa thực thi.** Test case là sản phẩm thiết kế từ phân tích tĩnh, mang trạng thái "Chưa thực thi". Báo cáo không ghi kết quả Pass/Fail thực nghiệm. Dữ liệu kiểm thử an toàn chỉ dừng ở mức thăm dò thông thường (ví dụ một ký tự nháy đơn, một thẻ định dạng HTML vô hại), không có dữ liệu khai thác hoàn chỉnh hay thao tác phá hủy dữ liệu.
- **Đặc tả là suy ngược.** Đặc tả được dựng lại từ mã nên có thể lệch với ý đồ thiết kế gốc. Các quy tắc nghiệp vụ không có trong mã và không có văn bản quy định được ghi là "chưa đủ đặc tả".
- **Mức độ là ưu tiên định tính.** Thang Critical – High – Medium – Low phản ánh ưu tiên xử lý do nhóm đánh giá, không phải điểm CVSS.
- **Baseline lịch sử.** Mã nguồn dùng `ext/mysql` và chỉ phù hợp với PHP 5.x. Kết quả phản ánh trạng thái tại commit đã chốt, không đại diện cho các hệ thống quản lý thư viện khác hay cho các phân hệ ngoài `librarian/`.

# 3. Mô tả hệ thống mục tiêu

Chương này mô tả đối tượng của đồ án ở bốn góc độ: hệ thống gốc và cấu trúc mã (3.1), yêu cầu suy ngược từ mã (3.2), các ràng buộc (3.3) và mô hình hệ thống (3.4). Mọi nhận định đều dẫn về tệp và dòng trong bản baseline. Số dòng được trích theo tệp `librarian/<tệp>.php` tại commit đã chốt, ký hiệu `tệp:dòng`.

## 3.1 Hệ thống gốc, baseline và cấu trúc phân hệ `librarian/`

### *3.1.1* Hệ thống gốc và baseline

Library-Management-System là ứng dụng web quản lý thư viện viết bằng PHP và MySQL, được tác giả Vinit Shahdeo phát hành trên GitHub theo giấy phép MIT [3]. Hệ thống gồm hai phân hệ: cổng thông tin công cộng ở thư mục gốc và phân hệ quản trị của thủ thư ở thư mục `librarian/`. Nhóm sao chép kho bằng lệnh `git clone`, chuyển về commit chốt, loại thư mục `.git/` và lưu cây mã vào `study/source/` mà không chỉnh sửa tệp nào [16]. Thông tin nhận dạng baseline được tổng hợp trong Bảng 5.

***Bảng 5.*** *Thông tin nhận dạng baseline*

| Thuộc tính | Giá trị |
|---|---|
| Kho upstream | `github.com/vinitshahdeo/Library-Management-System` |
| Commit chốt | `082d6fb9bdd7846b57033513791ba5b6d2095c11` |
| Thông điệp và thời điểm commit | "added social icons", 2020-02-12 17:21:32 +0530 |
| Giấy phép | MIT; tệp `LICENSE` giữ nguyên |
| SHA-256 của git archive (tar) | `fabac8fc61e74d2124eeb31a82d73acc8d0234a57ffdd57b54af3184b37293c7` |
| SHA-256 của `LICENSE` | `2e21d291d98be3562c6c122c35e9e624ef31950db4fdfbd95a5aa5b23ce192c0` |
| SHA-256 của `db/eb_lms.sql` | `1d2817e54dfc20d81e169e8080a05f4bc805711e8676359ee69f6d67f20ce8d4` |
| Thời điểm lấy mã | 2026-09-10T02:40:00Z |
| Phạm vi khảo sát | 66 tệp `librarian/*.php`; schema `db/eb_lms.sql` (chỉ đọc) |

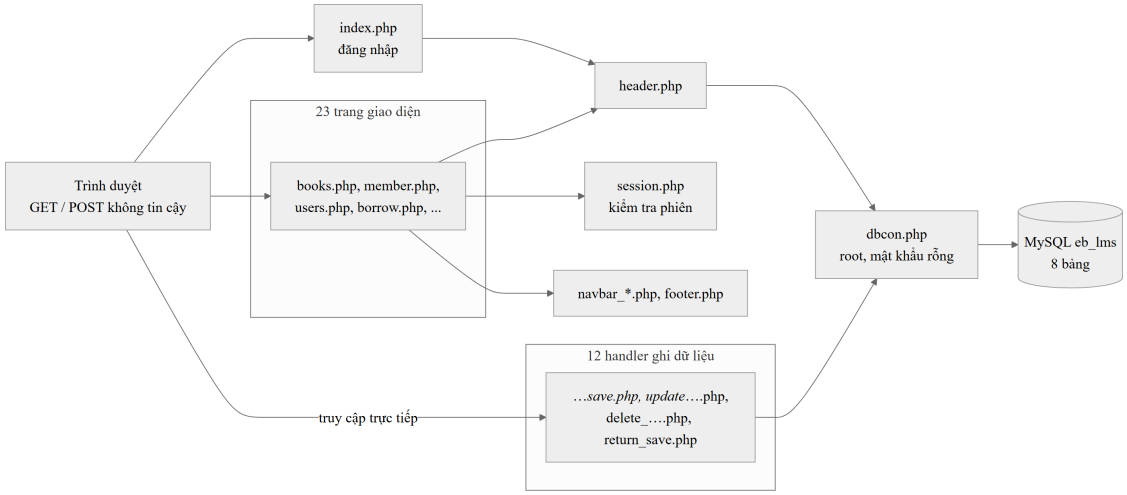
### *3.1.2* Kiến trúc và sơ đồ include

Phân hệ thủ thư không dùng framework, không có lớp (class) và không có bộ định tuyến. Mỗi tệp PHP vừa là trang giao diện vừa chứa luôn truy vấn CSDL (mô hình *page controller* thủ tục). Các thành phần dùng chung được ghép bằng lệnh `include`:

- `header.php` xuất phần `<head>` HTML (dòng 1–56) rồi include `dbcon.php` (dòng 57) để mở kết nối CSDL.

- `dbcon.php` gọi `mysql_connect` và `mysql_select_db` với thông số cố định (dòng 2).
- `session.php` khởi động phiên, kiểm tra `$_SESSION['id']`; nếu thiếu thì chuyển về `index.php` và dừng (dòng 3–8).
- `navbar_*.php` dựng thanh điều hướng; năm tệp navbar include `dropdown.php` (menu mượn/trả) và `search_form.php` (hộp thoại tìm kiếm).
- `footer.php` chứa hộp thoại xác nhận đăng xuất trỏ tới `logout.php` (dòng 19–25).
- Phần lớn thao tác ghi dữ liệu được tách sang tệp xử lý riêng (handler) như `books_save.php`, `update_member.php`, `delete_user.php`, `return_save.php`; các handler này chỉ include `dbcon.php`. Riêng thêm và sửa tài khoản thủ thư được xử lý ngay khi trang `users.php` tải, qua hai tệp nhúng `modal_add_user.php` (dòng 41–49) và `modal_edit_user.php` (dòng 44–58), tức là nằm sau `session.php`.

Hình 2 tóm tắt quan hệ include và ranh giới tin cậy suy ra từ mã. Điểm đáng chú ý là kiểm tra phiên chỉ nằm ở các trang giao diện; 12 handler ghi dữ liệu nhận yêu cầu trực tiếp từ trình duyệt mà không qua `session.php`.




***Hình** 2. Sơ đồ include và ranh giới tin cậy của phân hệ thủ thư (suy ra tĩnh từ mã nguồn)*

### *3.1.3* Kiểm kê 66 tệp PHP

Bảng 6 trình bày số liệu quy mô theo năm nhóm chức năng [16]. Số dòng được đếm bằng script đọc từng dòng: dòng trắng là dòng chỉ có khoảng trắng, dòng chú thích là dòng `//`, `#` hoặc khối `/* */`, phần còn lại là SLOC. Nhóm đã đếm lại tổng số dòng và dòng trắng trên bản sao baseline và cho kết quả trùng khớp.

***Bảng** 6. Kiểm kê quy mô phân hệ thủ thư theo nhóm chức năng*

| Nhóm chức năng | Số tệp | Dòng vật lý | Dòng trắng | Chú thích | SLOC |
|---|---|---|---|---|---|
| Xác thực và người dùng | 10 | 448 | 65 | 4 | 379 |

| Nhóm chức năng | Số tệp | Dòng vật lý | Dòng trắng | Chú thích | SLOC |
|---|---|---|---|---|---|
| Quản lý sách | 17 | 1.023 | 129 | 10 | 884 |
| Quản lý thành viên | 15 | 681 | 96 | 3 | 582 |
| Mượn – trả sách | 12 | 599 | 77 | 9 | 513 |
| Giao diện và dùng chung | 12 | 227 | 32 | 2 | 193 |
| **Tổng** | **66** | **2.978** | **399** | **28** | **2.551** |

Ngoài cách chia theo nghiệp vụ, nhóm phân loại 66 tệp theo *vai trò kỹ thuật* dựa trên quan hệ include và liên kết giữa các tệp (Bảng 7). Cách phân loại này quan trọng cho kiểm thử an toàn vì nó cho biết tệp nào là điểm vào (entry point) có thể gọi trực tiếp qua URL.

***Bảng** 7. Phân loại 66 tệp theo vai trò kỹ thuật*

| Vai trò | Số tệp | Tệp |
|---|---|---|
| Trang giao diện có include `session.php` | 23 | `add_books`, `add_member`, `add_student`, `advance_search`, `archive`, `books`, `borrow`, `damage`, `dashboard`, `edit_book`, `edit_member`, `edit_student`, `lost`, `member`, `new_books`, `old_books`, `return`, `sub_rep`, `transaction`, `unstudents`, `users`, `view_borrow`, `view_return` |
| Điểm vào không yêu cầu phiên | 2 | `index` (đăng nhập), `logout` |
| Handler ghi dữ liệu, chỉ include `dbcon.php` | 12 | `books_save`, `borrow_save`, `delete_books`, `delete_member`, `delete_student`, `delete_user`, `member_save`, `return_save`, `student_save`, `update_books`, `update_member`, `update_students` |
| Thành phần dùng chung được include | 21 | `header`, `dbcon`, `session`, `footer`, `dropdown`, `search_form`, `slider`, `toolttip_edit_delete`, `navbar`, `navbar_books`, `navbar_borrow`, `navbar_dashboard`, `navbar_member`, `navbar_user`, `navbar_transaction`, `modal_add_user`, `modal_edit_user`, `modal_return`, `delete_book_modal`, `delete_student_modal`, `delete_user_modal` |
| Mảnh mã không được tệp nào include | 7 | `login`, `borrowname`, `returnname`, `tooltip`, `navbar2`, `footer2`, `delete_member_modal` |
| Tệp rỗng (0 byte) | 1 | `unreturned_books` |

Phân tích liên kết điều hướng cho thấy thêm sáu trang tuy có kiểm tra phiên nhưng không được trang nào liên kết tới: `add_student.php`, `edit_student.php`, `unstudents.php`, `transaction.php`, `view_return.php` và `archive.php`. Nhóm student là bản sao của nhóm member: `student_save.php` trùng nội dung `member_save.php`, `delete_student.php` trùng `delete_member.php` (cùng mã băm). Danh sách thành viên `member.php` lại dùng hộp thoại `delete_student_modal.php` (dòng 48), nên thao tác xóa thành viên thực tế đi qua `delete_student.php`. Trong khi đó `delete_member.php` không được liên kết từ đâu. Các đặc điểm này được dùng ở mục 4.3 để gán mức tin cậy cho yêu cầu suy ngược.

### *3.1.4* Mô hình cơ sở dữ liệu

Schema `db/eb_lms.sql` định nghĩa tám bảng (Bảng 8). Schema không khai báo ràng buộc khóa ngoại (`FOREIGN KEY`); quan hệ giữa các bảng chỉ tồn tại ngầm qua các phép JOIN và so khớp ID trong mã PHP, ví dụ `view_borrow.php:24–28` và `books.php:61, 69`. Hai bảng `borrow` và `borrowdetails`, vốn tham gia cùng một thao tác lập phiếu mượn, dùng engine MyISAM, không hỗ trợ giao dịch [17]. Tệp schema còn chứa dữ liệu mẫu, trong đó có một tài khoản thủ thư với mật khẩu lưu dạng bản rõ (`eb_lms.sql:243–244`). Nhóm chỉ đọc tệp schema để xác định cấu trúc, không nạp dữ liệu này vào bất kỳ CSDL nào.

***Bảng** 8. Các bảng trong schema `eb_lms` và mức độ sử dụng trong phân hệ thủ thư*

| Bảng | Cột chính | Engine | Charset | Số tệp PHP dùng | Ghi chú |
|---|---|---|---|---|---|
| `book` | `book_id` (PK), `book_title` varchar(100), `category_id`, `author` varchar(50), `book_copies`, `isbn` varchar(50), `status` varchar(30) | InnoDB | latin1 | 16 | `date_receive` NOT NULL, không có giá trị mặc định |
| `borrow` | `borrow_id` (PK), `member_id`, `date_borrow` varchar(100), `due_date` varchar(100) | MyISAM | utf8 | 5 | Ngày lưu dạng chuỗi |
| `borrowdetails` | `borrow_details_id` (PK), `book_id`, `borrow_id`, `borrow_status` varchar(50), `date_return` varchar(100) | MyISAM | latin1 | 7 | `date_return` NOT NULL, không có giá trị mặc định |
| `category` | `category_id` (PK), `classname` varchar(50) | MyISAM | utf8 | 11 | Không có trang quản lý danh mục |
| `lost_book` | `Book_ID` (PK), `ISBN`, `Member_No`, `Date Lost` | InnoDB | latin1 | 0 | Không được mã nào dùng |
| `member` | `member_id` (PK), `firstname`, `lastname`, `gender`, `address`, `contact`, `type`, `year_level`, `status` | InnoDB | latin1 | 15 | `status` NOT NULL, không có giá trị mặc định |
| `type` | `id` (PK), `borrowertype` varchar(50) | MyISAM | utf8 | 0 | Không được mã nào dùng |
| `users` | `user_id` (PK), `username`, `password` varchar(100), `firstname`, `lastname` | InnoDB | latin1 | 6 | Không có cột vai trò |
| `students` | — | — | — | 1 | Được `unstudents.php:29` truy vấn nhưng không có trong schema |

## 3.2 Yêu cầu chức năng và phi chức năng suy ngược từ mã nguồn

Upstream không có SRS nên đặc tả trong mục này là **đặc tả suy ngược** từ mã nguồn và schema, không phải yêu cầu gốc đã được phê duyệt. Quy trình và quy ước xây dựng được

trình bày ở mục 4.3; đặc tả chi tiết các use-case chính và đặc tả dữ liệu đầu vào ở Phụ lục D. Mỗi yêu cầu mang một trong ba mức tin cậy:

- **R – Rõ ràng:** hành vi đọc được trực tiếp từ mã và có đường điều hướng tới.
- **S – Suy luận:** hành vi có trong mã nhưng phải suy diễn ý nghĩa hoặc không có đường điều hướng; với yêu cầu phi chức năng kỳ vọng, mức S nghĩa là yêu cầu được suy ra từ phát hiện và chuẩn tham chiếu.
- **C – Chưa đủ đặc tả:** quy tắc nghiệp vụ hợp lý nhưng không có trong mã và không có văn bản quy định; chỉ được ghi nhận như câu hỏi mở.

Đặc tả tách hai lớp. Yêu cầu chức năng (FR) và quy tắc nghiệp vụ (BR) mô tả *hành vi hiện có* của mã, kể cả khi hành vi đó thiếu an toàn. Yêu cầu phi chức năng (NFR) loại *kỳ vọng* mô tả điều hệ thống *phải* đạt để khắc phục các phát hiện. Nhờ vậy lỗ hổng không bị chép thành yêu cầu, còn test case có thể vừa kiểm chứng hành vi hiện có vừa kiểm chứng yêu cầu an toàn.

### *3.2.1* Yêu cầu chức năng

Bảng 9 liệt kê 23 yêu cầu chức năng thuộc sáu module: xác thực (AUTH), tài khoản thủ thư (USER), sách (BOOK), tìm kiếm (SRCH), thành viên (MEMB) và lưu thông mượn – trả (CIRC).

***Bảng** 9. Yêu cầu chức năng suy ngược từ mã nguồn*

| ID | Module | Yêu cầu (hành vi hiện có) | Nguồn trong mã | Tin cậy |
|---|---|---|---|---|
| FR-01 | AUTH | Thủ thư đăng nhập bằng tên đăng nhập và mật khẩu qua form POST; khi có bản ghi `users` khớp, hệ thống lưu `user_id` vào phiên và chuyển tới `dashboard.php` | `index.php:14–45` | R |
| FR-02 | AUTH | Khi không có bản ghi khớp, hệ thống hiển thị "Access Denied" và giữ nguyên trang đăng nhập | `index.php:46–47` | R |
| FR-03 | AUTH | Trang quản trị kiểm tra `$_SESSION['id']`; nếu thiếu hoặc rỗng thì chuyển về `index.php` và dừng xử lý | `session.php:3–8`; 23 trang include | R |
| FR-04 | AUTH | Thủ thư đăng xuất qua hộp thoại xác nhận; hệ thống hủy phiên và chuyển về trang chủ cổng công cộng | `footer.php:19–25`; `logout.php:2–4` | R |
| FR-05 | USER | Hiển thị danh sách tài khoản thủ thư gồm username, password, firstname, lastname | `users.php:23–46` | R |
| FR-06 | USER | Thêm tài khoản thủ thư với bốn trường bắt buộc (ràng buộc `required` phía trình duyệt) | `modal_add_user.php:4–48` | R |
| FR-07 | USER | Sửa thông tin tài khoản, kể cả mật khẩu, rồi tải lại danh sách | `modal_edit_user.php:4–56` | R |
| FR-08 | USER | Xóa tài khoản sau hộp thoại xác nhận; bản ghi bị xóa vĩnh viễn | `delete_user_modal.php:7`; `delete_user.php:4–8` | R |
| FR-09 | BOOK | Hiển thị các sách có trạng thái khác Archive, kèm số bản còn cho mượn | `books.php:55–83` | R |

| ID | Module | Yêu cầu (hành vi hiện có) | Nguồn trong mã | Tin cậy |
|---|---|---|---|---|
| FR-10 | BOOK | Lọc danh sách sách theo trạng thái New, Old, Lost, Damage, Subject for Replacement | new_books.php:48; old_books.php:48; lost.php:48; damage.php:48; sub_rep.php:48 | R |
| FR-11 | BOOK | Thêm sách với chín trường nhập; ngày thêm do hệ thống gán bằng NOW() | add_books.php:13–102; books_save.php:3–24 | R |
| FR-12 | BOOK | Sửa thông tin của sách được chọn theo book_id | edit_book.php:4–98; update_books.php:3–24 | R |
| FR-13 | BOOK | "Xóa" sách bằng cách chuyển trạng thái sang Archive, không xóa bản ghi | delete_book_modal.php:7; delete_books.php:3–5 | R |
| FR-14 | BOOK | Hiển thị danh sách sách đã lưu trữ (Archive) | archive.php:37–54 | S |
| FR-15 | SRCH | Tìm sách chưa lưu trữ theo chuỗi con của tiêu đề hoặc của tác giả | search_form.php:5–21; advance_search.php:5–7, 58–59 | R |
| FR-16 | MEMB | Hiển thị danh sách thành viên | member.php:31–43 | R |
| FR-17 | MEMB | Thêm thành viên: họ, tên, giới tính, địa chỉ, điện thoại, loại, năm học | add_member.php:13–89; member_save.php:3–18 | R |
| FR-18 | MEMB | Sửa thông tin thành viên, gồm cả trạng thái Active/Banned | edit_member.php:4–99; update_member.php:3–17 | R |
| FR-19 | MEMB | Xóa thành viên sau hộp thoại xác nhận; bản ghi bị xóa vĩnh viễn | member.php:47–48; delete_student_modal.php:7; delete_student.php:3–5 | R |
| FR-20 | CIRC | Lập phiếu mượn: chọn một thành viên, nhập hạn trả và chọn một hoặc nhiều sách chưa lưu trữ | borrow.php:14–89; borrow_save.php:4–29 | R |
| FR-21 | CIRC | Hiển thị toàn bộ chi tiết mượn ở mọi trạng thái, mới nhất trước, mỗi dòng có nút Return | view_borrow.php:24–47 | R |
| FR-22 | CIRC | Ghi nhận trả sách cho từng chi tiết mượn (theo borrow_id và book_id) | modal_return.php:7; return_save.php:4–8 | R |
| FR-23 | CIRC | Hiển thị danh sách các chi tiết mượn đã trả | return.php:26–46 | R |

FR-14 mang mức S vì archive.php không được liên kết từ thanh điều hướng và include một tệp không tồn tại (navbar_archive.php, dòng 3). Các trang thuộc nhóm student, transaction.php, view_return.php và các mảnh mã không được include (Bảng 7) không được đặc tả thành FR. Lý do là chúng không thuộc luồng điều hướng hoặc trùng lặp chức năng đã có; chúng được ghi nhận ở mục 5.2 như phần dư thừa của mã.

### *3.2.2* Quy tắc nghiệp vụ

Bảng 10 trình bày 15 quy tắc nghiệp vụ. Mười quy tắc đầu là hành vi có trong mã, phần lớn chỉ được áp dụng ở giao diện. Năm quy tắc cuối là các quy tắc thường gặp ở hệ thống thư viện nhưng không có trong mã; chúng tạo thành nhóm BIZ-INC-01 và được giữ ở mức C.

***Bảng** 10. Quy tắc nghiệp vụ suy ngược và các điểm chưa đủ đặc tả*

| ID | Quy tắc | Nguồn trong mã | Tin cậy | Nơi áp dụng |
|---|---|---|---|---|
| BR-01 | Sách bị "xóa" chuyển sang Archive và bị loại khỏi danh sách sách, kết quả tìm kiếm và màn hình lập phiếu mượn | `delete_books.php:4`; `books.php:55`; `advance_search.php:58`; `borrow.php:61` | R | Server |
| BR-02 | Số bản còn cho mượn hiển thị = `book_copies` − số chi tiết mượn của sách có trạng thái pending | `books.php:59–65, 77`; `advance_search.php:63–69, 81` | R | Chỉ hiển thị |
| BR-03 | Mỗi phiếu mượn có tối đa 3 sách | `borrow.php:93–104` (JavaScript); `borrow_save.php` không kiểm tra | R | Chỉ client |
| BR-04 | Phiếu mượn phải có ít nhất một sách; nếu không chọn sách thì quay về `borrow.php` mà không ghi dữ liệu | `borrow_save.php:8–9` | R | Server |
| BR-05 | Một phiếu mượn gồm một bản ghi `borrow` (member_id, date_borrow = `NOW()`, due_date) và một bản ghi `borrowdetails` trạng thái pending cho mỗi sách | `borrow_save.php:17–28` | R | Server |
| BR-06 | Trả sách chuyển `borrow_status` sang returned và gán `date_return = NOW()`; mã không kiểm tra trạng thái hiện tại của chi tiết mượn | `return_save.php:7` | R | Server |
| BR-07 | Trạng thái sách được chọn trong tập {New, Old, Lost, Damage, Subject for Replacement}; Archive chỉ được gán qua thao tác lưu trữ | `add_books.php:85–92`; `edit_book.php:81–88`; `delete_books.php:4` | R | Chỉ client |
| BR-08 | Loại thành viên ∈ {Student, Teacher}; năm học ∈ {First Year, …, Fourth Year, Faculty}; trạng thái ∈ {Active, Banned} | `add_member.php:53–77`; `edit_member.php:54–87` | R | Chỉ client |
| BR-09 | Số điện thoại thành viên gồm đúng 11 chữ số; trường không bắt buộc | `add_member.php:47`; `edit_member.php:48` (thuộc tính `pattern`) | R | Chỉ client |
| BR-10 | Hạn trả được chọn bằng bộ chọn ngày, không cho chọn ngày trước hôm nay | `borrow.php:32` (lớp `range-low-today` của `datepicker.js`) | S | Chỉ client |
| BR-11 | Không cho mượn khi số bản còn lại bằng 0 | Không có trong mã | C | — |
| BR-12 | Giới hạn tổng số sách một thành viên đang mượn (ngoài giới hạn 3 sách/phiếu) | Không có trong mã | C | — |
| BR-13 | Không cho thành viên ở trạng thái Banned mượn sách | Có cột `member.status` nhưng `borrow.php:22` liệt kê mọi thành viên và `borrow_save.php` không kiểm tra | C | — |
| BR-14 | Xác định quá hạn và tính tiền phạt | README upstream nêu chức năng xem tiền phạt, nhưng schema không có cột phạt và `due_date` lưu dạng chuỗi | C | — |
| BR-15 | Ghi nhận sách mất, hỏng vào bảng riêng | Bảng `lost_book` không được dùng; Lost/Damage chỉ được đặt qua form sửa sách | C | — |

Hai điểm trong bảng cần lưu ý. Thứ nhất, BR-03 cho thấy hệ thống *có* giới hạn số sách, nhưng chỉ là giới hạn 3 sách trên một phiếu và chỉ do JavaScript kiểm tra. Một yêu cầu POST gửi thẳng tới `borrow_save.php` sẽ không bị giới hạn. Vì vậy cách diễn đạt "mã không giới hạn số sách mượn" ở mục BIZ-02 của checklist cũ cần được hiệu chỉnh thành "không có giới hạn phía server". Thứ hai, `borrow.php:61` liệt kê mọi sách khác Archive, kể cả sách ở trạng thái Lost hoặc Damage. Mã không cho biết các sách này có được phép cho mượn hay không, nên điểm này cũng thuộc nhóm câu hỏi mở của BIZ-INC-01.

### *3.2.3* Yêu cầu phi chức năng

Mã nguồn hầu như không hiện thực yêu cầu phi chức năng nào về an toàn. Vì vậy Bảng 11 gồm hai loại. Loại *HT (hiện trạng)* mô tả đặc tính hệ thống đang có. Loại *KV (kỳ vọng)* là yêu cầu hệ thống phải đạt, được suy ra từ phát hiện tĩnh và chuẩn OWASP ASVS [11]. NFR-01 đến NFR-11 tương ứng một – một với các yêu cầu REQ-L01 đến REQ-L11 trong bảng đặc tả Excel của nhóm [18]; nhờ đó hai bộ hồ sơ truy vết được sang nhau.

***Bảng** 11. Yêu cầu phi chức năng*

| ID | Loại | Yêu cầu | Căn cứ trong mã | Liên kết | Tin cậy |
|---|---|---|---|---|---|
| NFR-01 | KV | Tra cứu tài khoản bằng truy vấn tham số; xác minh mật khẩu bằng hàm băm, tách khỏi câu SQL | `index.php:36–42` ghép chuỗi | REQ-L01; AUTH-01 | S |
| NFR-02 | KV | Mọi endpoint truy cập CSDL phải kiểm tra phiên (và quyền) phía server trước thao tác | 12 handler chỉ include `dbcon.php` | REQ-L02; AC-02 | S |
| NFR-03 | KV | Truy vấn CSDL tham số hóa; kiểm tra kiểu, độ dài, miền giá trị phía server theo schema | `books_save.php:20–21`; `advance_search.php:58–59` | REQ-L03; INP-01..03 | S |
| NFR-04 | KV | Mã hóa dữ liệu đầu ra theo ngữ cảnh HTML, thuộc tính, JavaScript, URL | `books.php:74, 76`; `edit_book.php:23–24` | REQ-L04; OUT-01..03 | S |
| NFR-05 | KV | Mật khẩu lưu dạng băm thích ứng; không hiển thị mật khẩu trên giao diện | `users.php:44`; `modal_edit_user.php:15` | REQ-L05; AUTH-02 | S |
| NFR-06 | KV | Thao tác thay đổi dữ liệu dùng POST và có token chống CSRF được kiểm tra phía server | `delete_*.php`, `return_save.php` nhận GET | REQ-L06; STATE-01..03 | S |
| NFR-07 | KV | Lập phiếu mượn nguyên tử: dùng ID vừa chèn của chính kết nối và giao dịch trên engine có hỗ trợ giao dịch | `borrow_save.php:17–28`; `borrow`/`borrowdetails` là MyISAM | REQ-L07; BIZ-03 | S |
| NFR-08 | KV | Thông tin kết nối CSDL tách khỏi mã nguồn; tài khoản CSDL có quyền tối thiểu | `dbcon.php:2` | REQ-L08; ERR-03 | S |
| NFR-09 | HT/ KV | Hiện trạng: chỉ chạy với PHP có `ext/mysql` (đến 5.6). Kỳ vọng: dùng API CSDL còn được hỗ trợ (MySQLi hoặc PDO) | `dbcon.php:2` và mọi lời gọi `mysql_*` | REQ-L09 | R |
| NFR-10 | KV | Không đưa lỗi CSDL chi tiết ra người dùng; ghi lỗi vào log phía server | `or die(mysql_error())` sau các truy vấn | REQ-L10; ERR-01..02 | S |

| ID | Loại | Yêu cầu | Căn cứ trong mã | Liên kết | Tin cậy |
|---|---|---|---|---|---|
| NFR-11 | KV | Mọi tệp include và bảng được tham chiếu phải tồn tại; bản phát hành không chứa tệp rỗng | `archive.php:3`; `unstudents.php:3, 29, 44` | REQ-L11 | R |
| NFR-12 | KV | Tái tạo định danh phiên sau đăng nhập; đặt cờ HttpOnly, Secure, SameSite cho cookie phiên | `index.php:35–44` không gọi `session_regenerate_id` | AUTH-04, AUTH-05 | S |
| NFR-13 | KV | Hạn chế số lần đăng nhập sai liên tiếp | `index.php:34–49` không đếm lần thất bại | AUTH-03 | S |
| NFR-14 | HT | Giao diện dùng Bootstrap, jQuery 1.7.2 và DataTables (tìm kiếm, phân trang phía client); hộp thoại xác nhận cần trình duyệt bật JavaScript | `header.php:7–18, 45–46` | — | R |

## 3.3 Các ràng buộc

### *3.3.1* Ràng buộc về triển khai

Bảng 12 tổng hợp các ràng buộc triển khai đọc được từ mã. Hai ràng buộc cuối phụ thuộc cấu hình máy chủ nên chỉ được nêu như điều kiện, chưa được kiểm chứng.

***Bảng** 12. Ràng buộc triển khai suy ra từ mã nguồn*

| Ràng buộc | Bằng chứng | Hệ quả |
|---|---|---|
| Nền tảng PHP có `ext/mysql` (PHP 5.x) và máy chủ MySQL | `dbcon.php:2`; phần mở rộng bị loại khỏi PHP 7.0 [4] | Không chạy được trên PHP hiện hành nếu không sửa mã; PHPStan cần tệp stub để phân tích |
| `librarian/` phải nằm trong cây thư mục của cổng công cộng | Đường dẫn tương đối `../css`, `../js` (`header.php:7–18`), `../index.php` (`logout.php:4`), `../LMS/vit.png` (`index.php:8`) | Không triển khai độc lập được phân hệ thủ thư |
| Kết nối CSDL cố định: máy `localhost`, tài khoản `root`, mật khẩu rỗng, CSDL `eb_lms` | `dbcon.php:2` | Thay đổi môi trường phải sửa mã (FIND-08) |
| Trộn engine và bảng mã: InnoDB với MyISAM; latin1 với utf8 | Schema (Bảng 8) | Không bảo đảm giao dịch nhiều bảng; bảng latin1 không biểu diễn được ký tự ngoài Latin-1, ví dụ tiếng Việt có dấu |
| Thứ tự xuất dữ liệu và header | `header.php` xuất HTML trước khi `session.php:3, 6` gọi `session_start()` và `header()`; `index.php:35, 43` cũng vậy | Theo tài liệu PHP, `header()` phải được gọi trước mọi đầu ra [19]; hành vi đúng phụ thuộc cấu hình output buffering. Chưa kiểm chứng |

| Ràng buộc | Bằng chứng | Hệ quả |
|---|---|---|
| Cột NOT NULL không có giá trị mặc định bị bỏ qua khi INSERT | `book.date_receive` (`books_save.php:20–21`), `member.status` (`member_save.php:15`), `borrowdetails.date_return` (`borrow_save.php:26`) | Ở chế độ SQL nghiêm ngặt, MySQL từ chối câu lệnh [20]; kết quả phụ thuộc `sql_mode`. Chưa kiểm chứng |

### *3.3.2* Ràng buộc kinh tế

Đồ án chỉ dùng công cụ mã nguồn mở, miễn phí và chạy cục bộ: Semgrep OSS, PHPStan và PHP CLI; không dùng công cụ SAST hay DAST thương mại. Chi phí giấy phép vì thế bằng 0. Nguồn lực gồm ba sinh viên trong thời lượng một học kỳ, không có máy chủ thử nghiệm hay CSDL dựng sẵn. Đây là một lý do thực tế, bên cạnh lý do an toàn, khiến kiểm thử động nằm ngoài phạm vi. Ở phía hệ thống mục tiêu, chi phí khắc phục lớn nhất là chuyển toàn bộ tầng truy cập dữ liệu từ `ext/mysql` sang MySQLi hoặc PDO, vì 54 điểm gọi `mysql_query` nằm rải rác trong 37 tệp [18].

### *3.3.3* Ràng buộc về đạo đức

- **Tôn trọng giấy phép và tác giả.** Mã upstream được dùng theo giấy phép MIT, giữ nguyên tệp `LICENSE` và ghi rõ nguồn; mọi trích dẫn mã chỉ phục vụ mục đích học thuật.
- **Không thực thi, không khai thác.** Nhóm không chạy ứng dụng, không kết nối CSDL, không gửi dữ liệu tấn công; dữ liệu kiểm thử an toàn trong test case chỉ ở mức thăm dò thông thường.
- **Bảo vệ dữ liệu cá nhân.** Dữ liệu mẫu trong schema không được nạp vào CSDL. Một số ảnh chụp màn hình của upstream hiển thị tên người, số điện thoại và mật khẩu; báo cáo không tái hiện các ảnh này và chỉ dùng ảnh không chứa dữ liệu cá nhân (mục 3.4.5).
- **Trình bày có trách nhiệm.** Báo cáo mô tả lỗ hổng ở mức nguyên nhân, tác động có điều kiện và cách khắc phục; không công bố mã khai thác hoàn chỉnh.

## 3.4 Mô hình hệ thống

### *3.4.1* Danh sách use-case

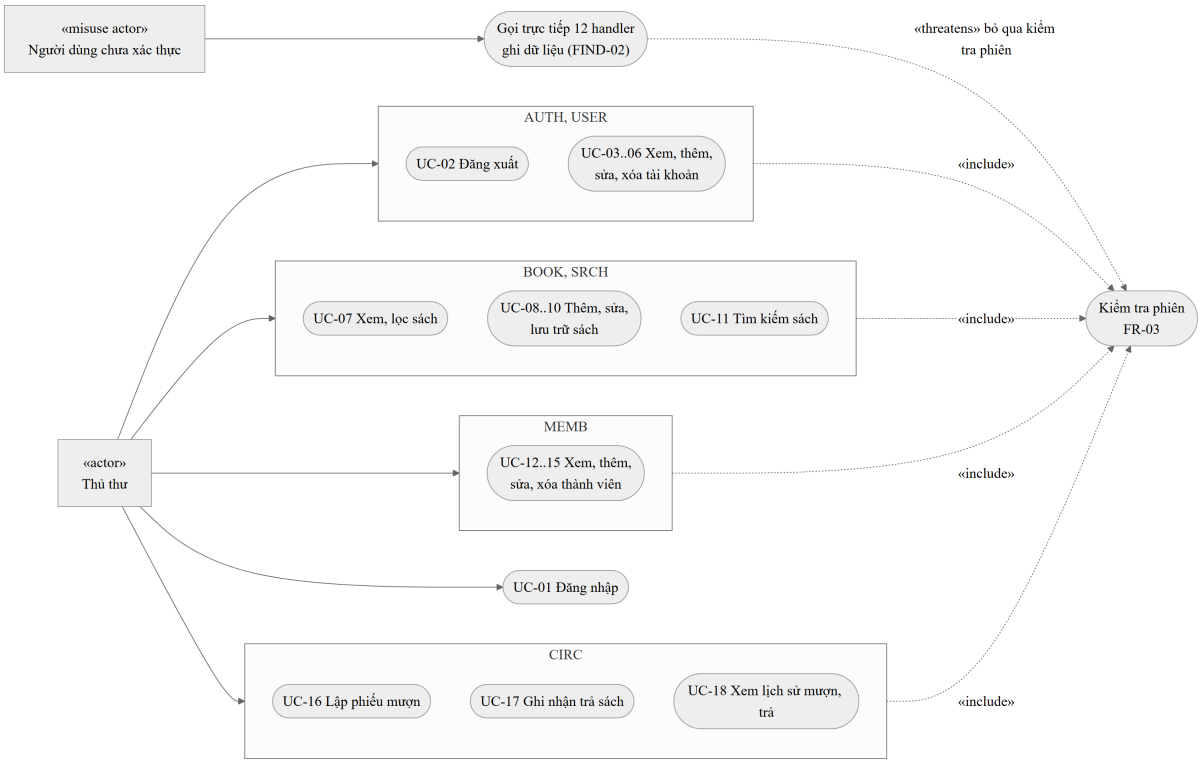
Hệ thống có một tác nhân chính là **Thủ thư**: người dùng có tài khoản trong bảng `users`. Schema không có cột vai trò nên mọi tài khoản có quyền như nhau. Bảng 13 liệt kê 18 use-case suy ra từ các luồng điều hướng có thật trong mã. FR-03 (kiểm tra phiên) không đứng riêng mà là use-case dùng chung, được include vào UC-02 đến UC-18 ở tầng trang giao diện.

***Bảng** 13. Danh sách use-case*

| ID | Use-case | Module | Tệp giao diện → tệp xử lý | FR |
|---|---|---|---|---|
| UC-01 | Đăng nhập | AUTH | `index.php` | FR-01, FR-02 |
| UC-02 | Đăng xuất | AUTH | `footer.php` → `logout.php` | FR-04 |
| UC-03 | Xem danh sách tài khoản | USER | `users.php` | FR-05 |
| UC-04 | Thêm tài khoản | USER | `users.php` + `modal_add_user.php` | FR-06 |
| UC-05 | Sửa tài khoản | USER | `users.php` + `modal_edit_user.php` | FR-07 |
| UC-06 | Xóa tài khoản | USER | `delete_user_modal.php` → `delete_user.php` | FR-08 |
| UC-07 | Xem và lọc danh mục sách | BOOK | `books.php`, `new_books.php`, `old_books.php`, `lost.php`, `damage.php`, `sub_rep.php`, `archive.php` | FR-09, FR-10, FR-14 |
| UC-08 | Thêm sách | BOOK | `add_books.php` → `books_save.php` | FR-11 |
| UC-09 | Sửa sách | BOOK | `edit_book.php` → `update_books.php` | FR-12 |
| UC-10 | Lưu trữ (xóa mềm) sách | BOOK | `delete_book_modal.php` → `delete_books.php` | FR-13 |
| UC-11 | Tìm kiếm sách | SRCH | `search_form.php` → `advance_search.php` | FR-15 |
| UC-12 | Xem danh sách thành viên | MEMB | `member.php` | FR-16 |
| UC-13 | Thêm thành viên | MEMB | `add_member.php` → `member_save.php` | FR-17 |
| UC-14 | Sửa thành viên | MEMB | `edit_member.php` → `update_member.php` | FR-18 |
| UC-15 | Xóa thành viên | MEMB | `delete_student_modal.php` → `delete_student.php` | FR-19 |
| UC-16 | Lập phiếu mượn | CIRC | `borrow.php` → `borrow_save.php` | FR-20 |
| UC-17 | Ghi nhận trả sách | CIRC | `view_borrow.php` → `modal_return.php` → `return_save.php` | FR-22 |
| UC-18 | Xem lịch sử mượn, trả | CIRC | `view_borrow.php`, `return.php` | FR-21, FR-23 |

### *3.4.2* Mô hình use-case

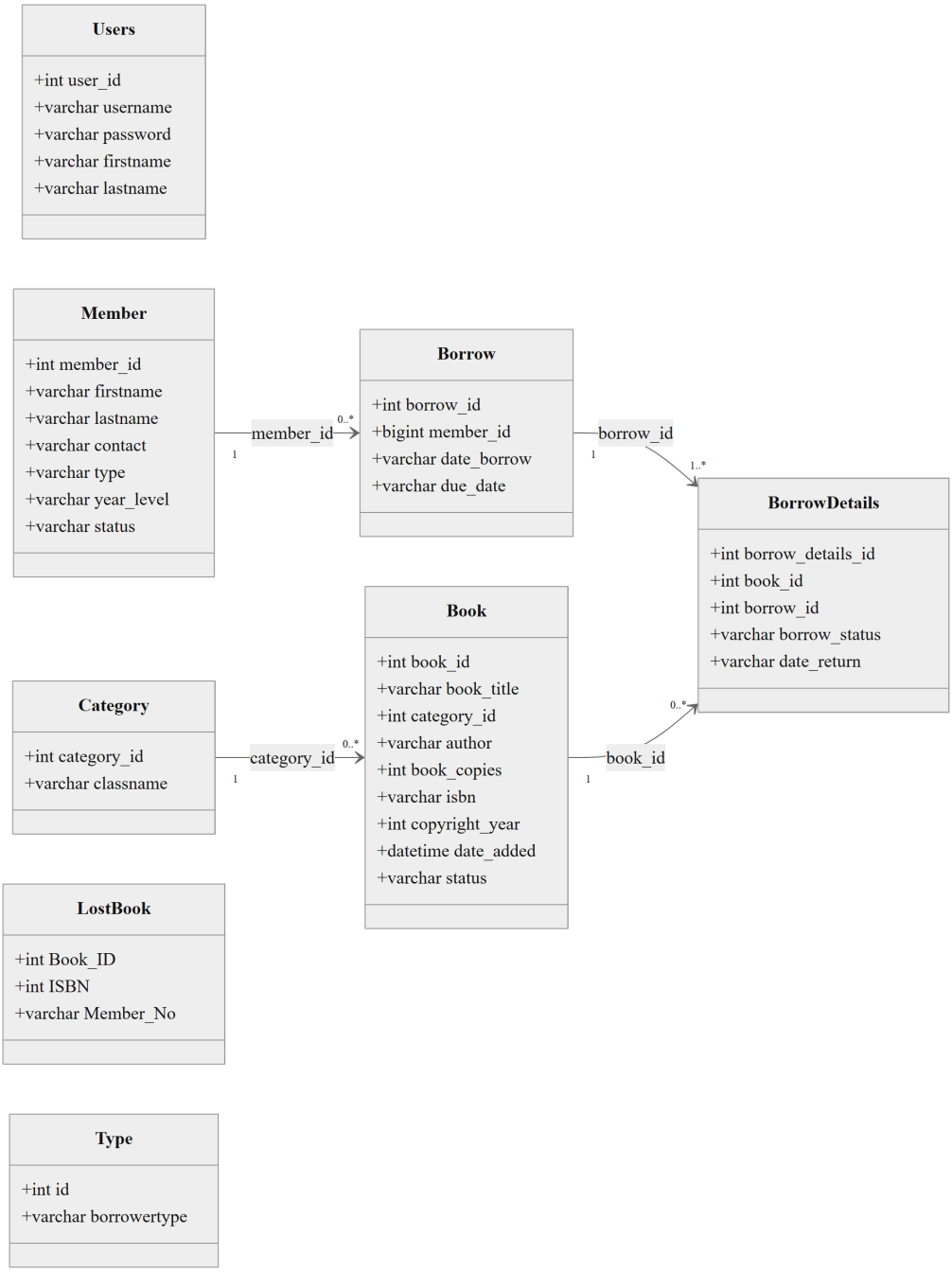
Hình 3 trình bày mô hình use-case theo sáu module. Để mô hình phản ánh đúng kết quả kiểm thử tĩnh, hình bổ sung một *misuse case*: người dùng chưa xác thực gọi trực tiếp các handler ghi dữ liệu và bỏ qua kiểm tra phiên, vốn chỉ đặt ở trang giao diện (FIND-02). Misuse case này đe dọa các use-case ghi dữ liệu của bốn module: UC-06, UC-08 đến UC-10, UC-13 đến UC-17.




***Hình** 3. Mô hình use-case của phân hệ thủ thư kèm misuse case suy ra từ FIND-02*

### *3.4.3* Mô hình lớp và đối tượng

Mã nguồn không định nghĩa lớp nào; dữ liệu được xử lý dưới dạng mảng kết quả của `mysql_fetch_array`. Vì vậy mô hình lớp ở Hình 4 là **mô hình miền dữ liệu** suy ra từ schema và từ cách mã nối các bảng. Bội số quan hệ (multiplicity) được suy từ mã: `borrow_save.php:23–28` tạo một hoặc nhiều chi tiết cho mỗi phiếu mượn; `books.php:61` đếm nhiều chi tiết mượn trên mỗi sách. Hai bảng `lost_book` và `type` không tham gia quan hệ nào trong mã.

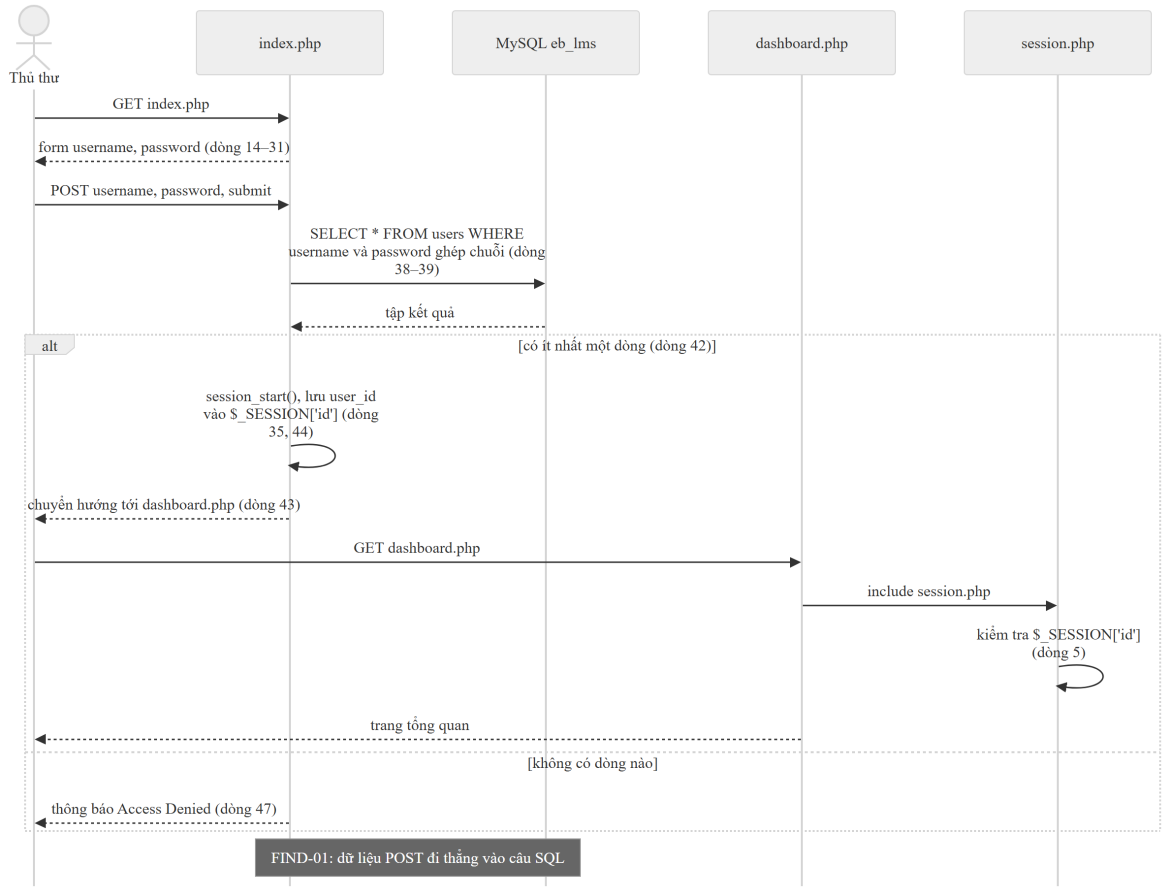



***Hình** 4. Mô hình miền dữ liệu suy ra từ schema và các phép nối trong mã*

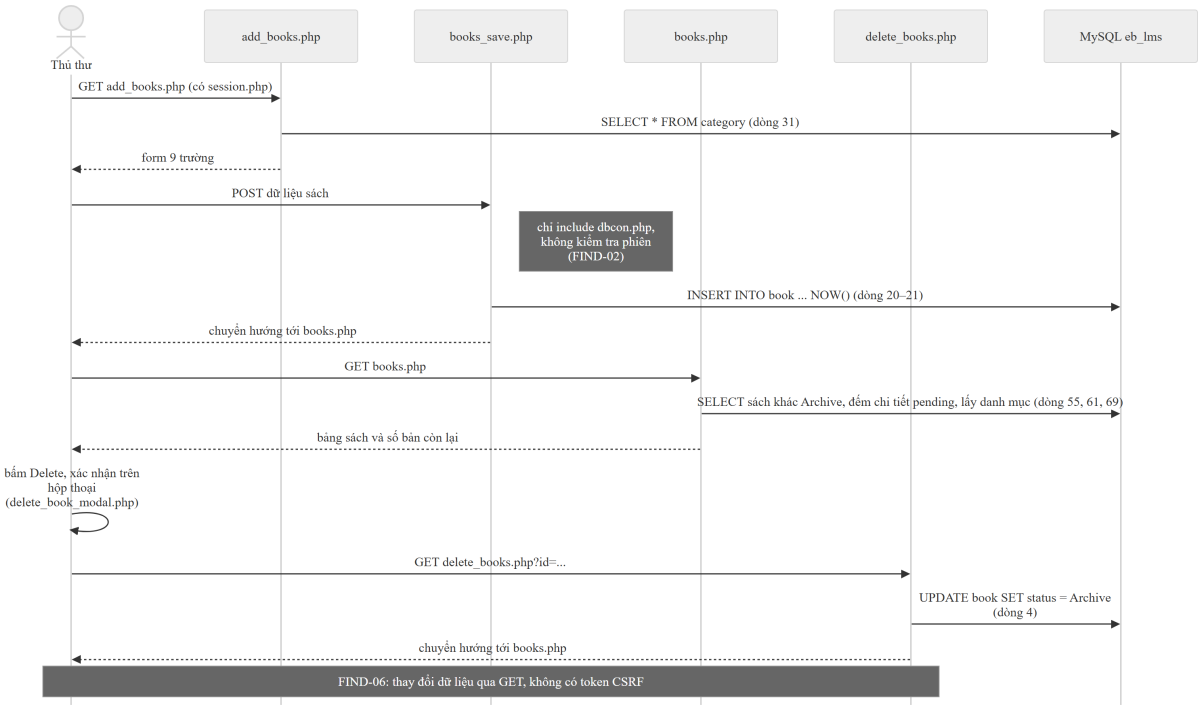
Ở mức đối tượng, một lần lập phiếu mượn tạo ra một đối tượng `Borrow` gắn với một `Member`, cùng tối đa ba đối tượng `BorrowDetails` (theo giới hạn phía client BR-03) ở trạng thái pending, mỗi đối tượng trỏ tới một `Book`. Thao tác trả sách chỉ thay đổi trạng thái của từng `BorrowDetails`, không thay đổi `Borrow`. Số bản còn cho mượn của một `Book` không được lưu mà được tính lại mỗi lần hiển thị (BR-02).

### *3.4.4* Các biểu đồ tuần tự

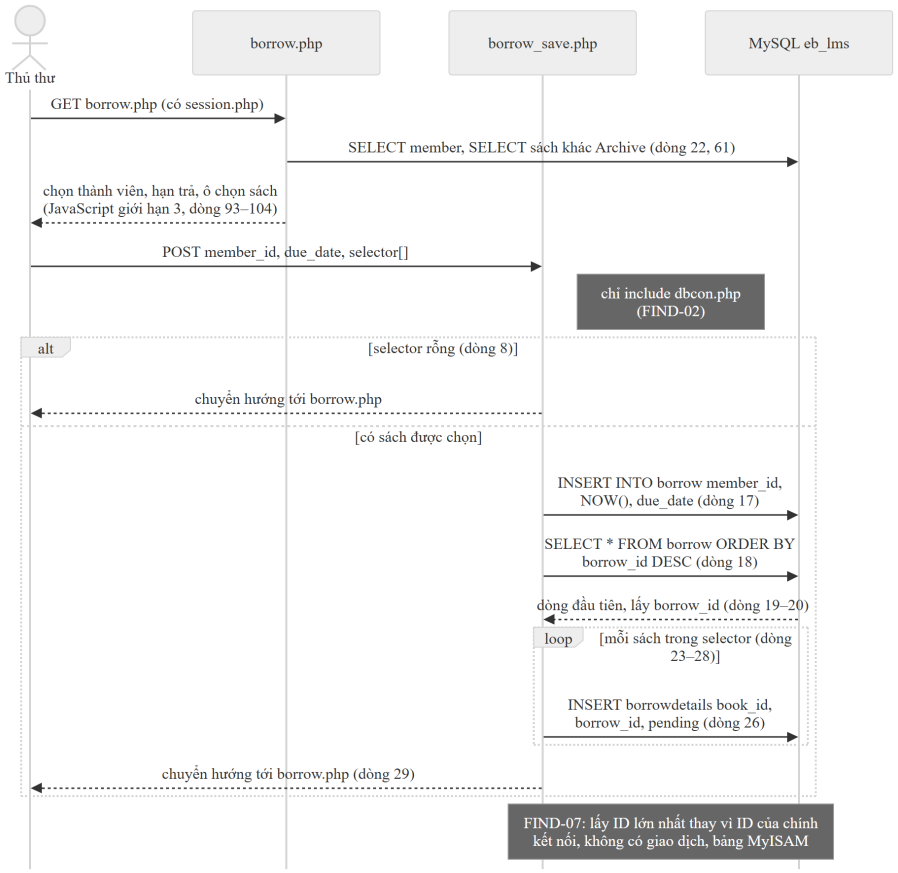
Bốn biểu đồ tuần tự dưới đây mô tả các luồng chính: đăng nhập (Hình 5), CRUD sách (Hình 6), lập phiếu mượn (Hình 7) và trả sách (Hình 8). Mỗi thông điệp ghi kèm số dòng trong mã. Các ghi chú đánh dấu vị trí xuất hiện phát hiện tĩnh, được phân tích chi tiết ở mục 5.1.



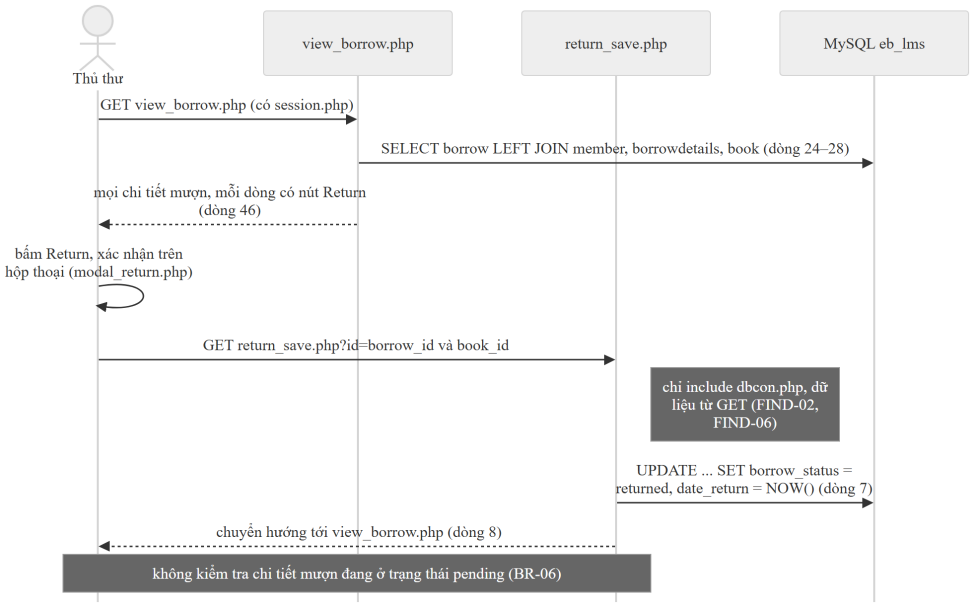

***Hình 5.*** *Biểu đồ tuần tự luồng đăng nhập (UC-01)*




***Hình** 6. Biểu đồ tuần tự luồng thêm và lưu trữ sách (UC-08, UC-10); luồng sửa sách qua `edit_book.php` → `update_books.php` có cấu trúc tương tự*




***Hình** 7. Biểu đồ tuần tự luồng lập phiếu mượn (UC-16)*




***Hình** 8. Biểu đồ tuần tự luồng ghi nhận trả sách (UC-17)*

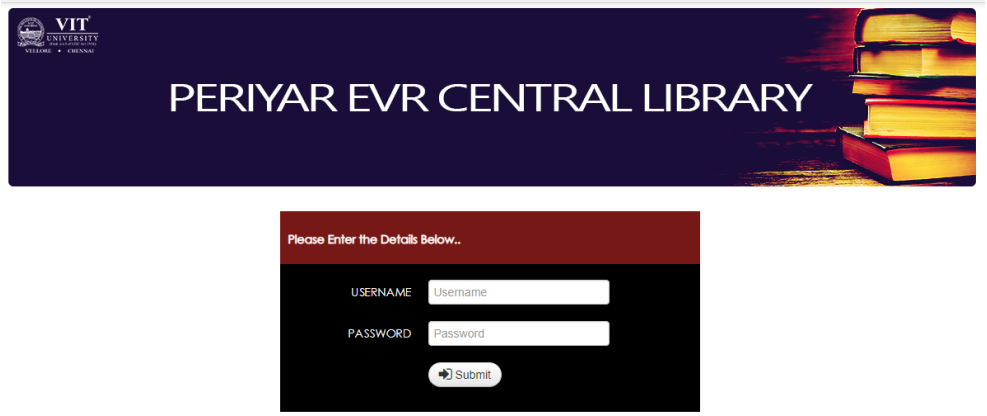
### *3.4.5* Các màn hình giao diện người dùng

Bảng 14 liệt kê các màn hình chính. Giao diện dùng Bootstrap; các bảng danh sách có ô tìm kiếm và phân trang phía client do DataTables cung cấp. Các thao tác sửa, xóa, trả sách đều mở hộp thoại modal trước khi gửi yêu cầu.

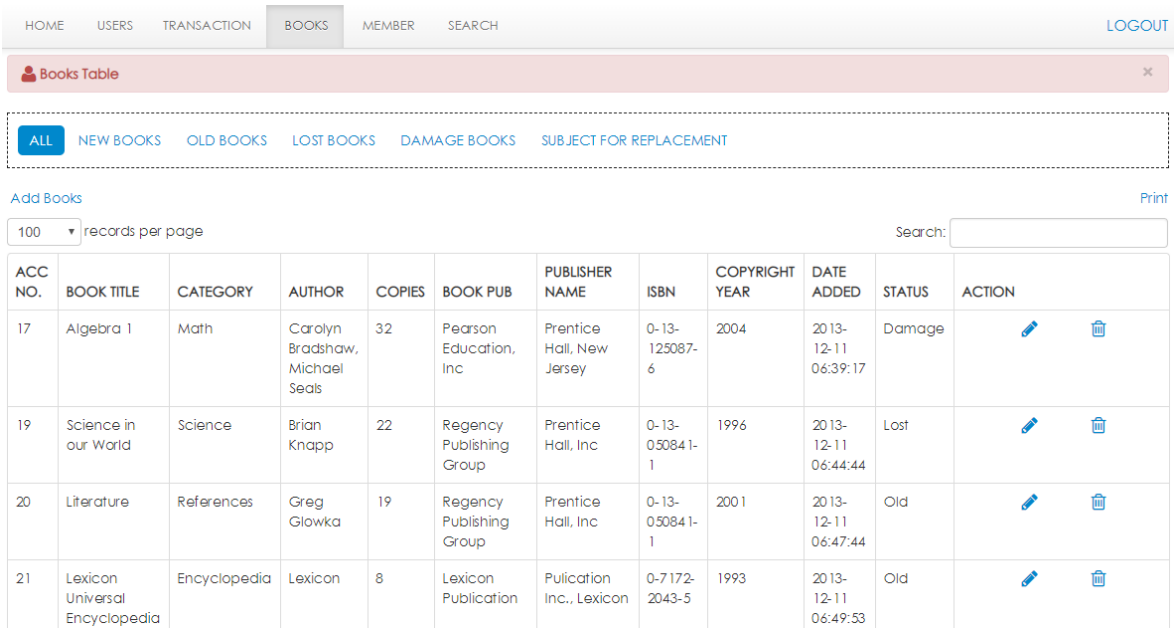
***Bảng** 14. Các màn hình giao diện chính của phân hệ thủ thư*

| Màn hình | Tệp | Thành phần chính | Use-case |
|---|---|---|---|
| Đăng nhập | `index.php` | Ô Username, Password, nút Submit; thông báo Access Denied | UC-01 |
| Tổng quan | `dashboard.php` | Thanh điều hướng, trình chiếu ảnh (`slider.php`) | — |
| Tài khoản thủ thư | `users.php` | Bảng Username, Password, Firstname, Lastname; modal thêm, sửa, xóa | UC-03 đến UC-06 |
| Danh sách sách | `books.php` và năm trang lọc | Tab theo trạng thái, nút Add Books, Print; bảng 12 cột; nút Edit, Delete | UC-07, UC-10 |
| Thêm, sửa sách | `add_books.php`, `edit_book.php` | Chín trường; danh sách danh mục; danh sách trạng thái | UC-08, UC-09 |
| Tìm kiếm | `search_form.php` (modal), `advance_search.php` | Ô Title, Author; bảng kết quả | UC-11 |
| Thành viên | `member.php`, `add_member.php`, `edit_member.php` | Bảng thành viên; form bảy trường; trạng thái Active/Banned ở form sửa | UC-12 đến UC-15 |
| Lập phiếu mượn | `borrow.php` | Chọn thành viên, hạn trả; bảng sách có ô chọn | UC-16 |
| Sách đang mượn, đã trả | `view_borrow.php`, `return.php` | Bảng chi tiết mượn; nút Return | UC-17, UC-18 |

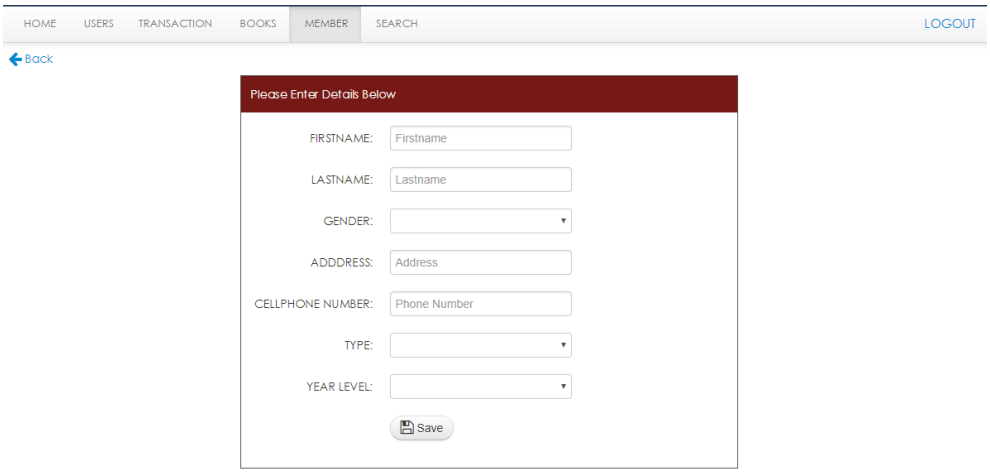
Hình 9 đến Hình 11 là ảnh chụp màn hình có sẵn trong thư mục `screenshots/` của upstream [3]. Nhóm không chạy ứng dụng để chụp ảnh. Ảnh đã được cắt bỏ thanh trình duyệt và thanh tác vụ của máy tác giả. Nhóm chỉ chọn những ảnh không chứa dữ liệu cá nhân. Ảnh được chụp trước commit baseline nên có thể khác một vài chi tiết so với mã tại commit chốt.




***Hình** 9. Màn hình đăng nhập của phân hệ thủ thư (`index.php`; nguồn: upstream `screenshots/`)*




***Hình** 10. Màn hình danh sách sách (`books.php`; nguồn: upstream `screenshots/`)*




***Hình** 11. Màn hình thêm thành viên (`add_member.php`; nguồn: upstream `screenshots/`)*

# 4. Phương pháp thực hiện

Chương này trình bày cách đồ án tạo ra các kết quả ở Chương 5, gồm quy trình tổng thể (4.1), kiểm thử tĩnh (4.2), xây dựng đặc tả suy ngược (4.3) và thiết kế test case (4.4). Phương pháp được thiết kế để mọi kết luận đều truy về được tệp và dòng mã, phiên bản công cụ, bộ rule hoặc công thức đã dùng.

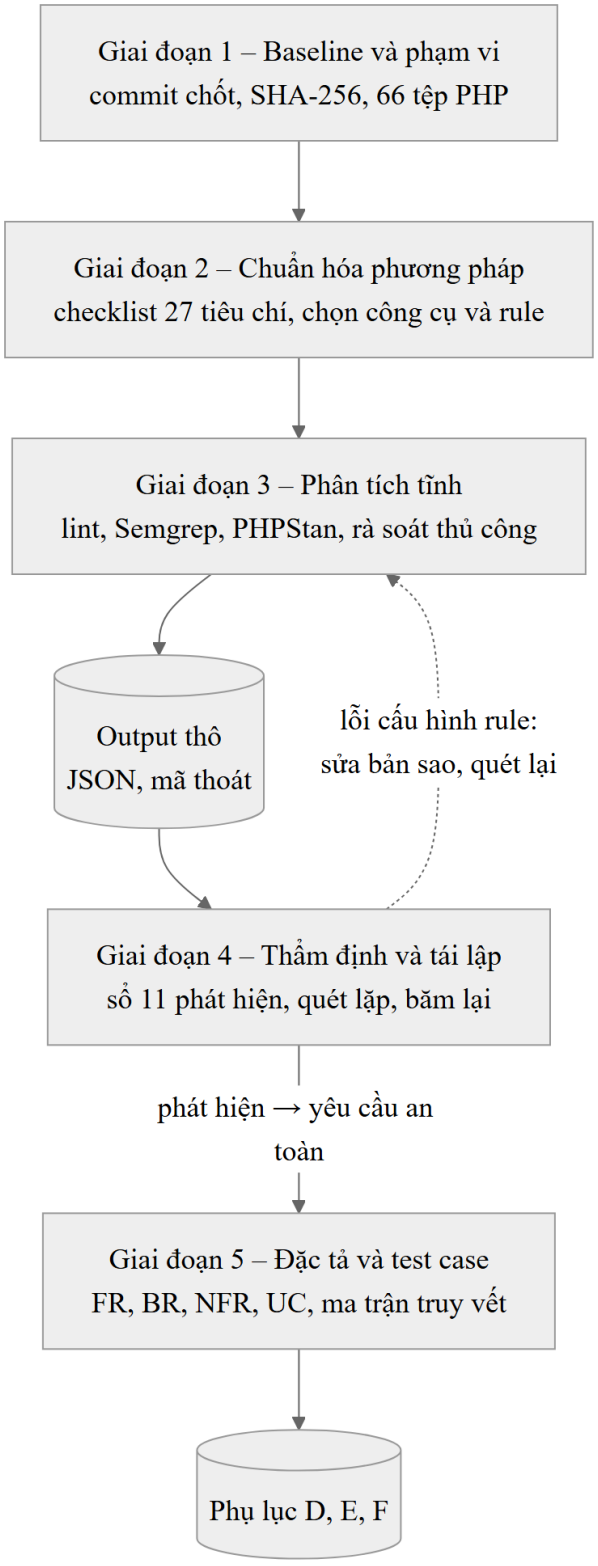
## 4.1 Quy trình tổng thể

Đồ án gồm năm giai đoạn thực hiện tuần tự (Bảng 15). Mỗi giai đoạn có tiêu chí kết thúc riêng, và sản phẩm được lưu trong kho hồ sơ của nhóm [16]. Giai đoạn 1 đến 4 thuộc mảng (A) Static testing. Giai đoạn 5 thuộc mảng (B) Đặc tả và test case, dùng đầu ra của mảng (A) làm đầu vào. Hai nguyên tắc áp dụng xuyên suốt:

- **Baseline bất biến.** Không sửa và không chạy mã baseline. Công cụ chỉ đọc văn bản nguồn; schema chỉ được đọc để xác định cấu trúc.
- **Tách dữ kiện khỏi diễn giải.** Output của công cụ được lưu nguyên dạng, gồm JSON thô, mã thoát, phiên bản và lệnh chạy. Kết luận chỉ nằm trong sổ phát hiện, mỗi kết luận có trạng thái thẩm định và bằng chứng đi kèm.

***Bảng** 15. Các giai đoạn thực hiện, sản phẩm và mục tiêu tương ứng*

| Giai đoạn | Hoạt động chính | Đầu vào | Sản phẩm | Mục tiêu |
|---|---|---|---|---|
| 1. Chuẩn bị baseline và phạm vi | Lấy mã tại commit chốt; tính SHA-256; kiểm kê 66 tệp PHP; đo dòng vật lý và SLOC; lập sơ đồ include và bảng dữ liệu | Kho upstream | Hồ sơ baseline, danh mục phạm vi (Bảng 5 đến Bảng 8) | MT-A1 |
| 2. Chuẩn hóa phương pháp, chọn công cụ | Lập checklist 7 nhóm; khảo sát công cụ PHP chạy cục bộ; thử trên tập tệp nhỏ; chốt phiên bản và bộ rule | Baseline, tài liệu công cụ | Checklist, hồ sơ công cụ, bộ rule tùy biến | MT-A2, MT-A3 |
| 3. Phân tích tĩnh | Chạy lint, Semgrep, PHPStan và bộ kiểm kê token; rà soát thủ công theo bốn luồng chức năng | Baseline, checklist, cấu hình | Output thô; checklist đã đánh giá | MT-A2, MT-A3 |
| 4. Thẩm định và tái lập | Đối chiếu cảnh báo với ngữ cảnh; gộp theo nguyên nhân gốc; gán CWE và mức ưu tiên; quét lặp; tính lại mã băm | Output thô, ghi chú rà soát | Sổ phát hiện, biên bản tái lập | MT-A4, MT-A5 |
| 5. Đặc tả, test case, truy vết | Suy ngược FR, BR, NFR, UC; mô hình hóa; thiết kế test case; lập ma trận truy vết | Baseline, schema, sổ phát hiện | Chương 3; Phụ lục D, E, F | MT-B1 đến MT-B4 |




***Hình** 12. Quy trình thực hiện năm giai đoạn và vòng lặp thẩm định lại*

Quy trình không hoàn toàn tuyến tính. Lần quét đầu tiên (10/09/2026) ghi nhận 270 cảnh báo nhưng thoát với mã 2, vì một rule tùy biến lỗi cú pháp nên không được nạp. Khi thẩm định lại hồ sơ (04/10/2026), nhóm phát hiện lỗi này, sửa trên bản sao của tệp rule và quét lại hai lần, thu được 322 cảnh báo hợp lệ (mục 4.2.2). Cũng ở bước thẩm định lại, checklist được đếm lại thành 27 tiêu chí. Danh sách handler thiếu kiểm tra phiên được mở rộng thành 12 tệp sau khi lần theo include đệ quy cho toàn bộ điểm vào. Mọi số liệu trong báo cáo dùng phiên bản sau thẩm định lại; số liệu cũ chỉ được nhắc tới để giải thích chênh lệch.

## 4.2 Kiểm thử tĩnh

### *4.2.1* Rà soát thủ công theo checklist

Checklist gồm 27 tiêu chí chia thành bảy nhóm (Bảng 16). Mỗi tiêu chí có mã, câu hỏi kiểm tra, cách thu thập bằng chứng, loại tiêu chí và kết luận. Có hai loại tiêu chí: *quy chuẩn kỹ thuật* (căn cứ OWASP Top 10 [1], CWE [2], OWASP ASVS [11]) và *giả định nghiệp vụ cần kiểm chứng* (áp dụng khi không có SRS). Câu hỏi kiểm tra được diễn đạt theo các kịch bản của OWASP WSTG [5], nhưng được trả lời bằng cách đọc mã thay vì gửi yêu cầu HTTP.

***Bảng** 16. Cấu trúc checklist rà soát thủ công*

| Nhóm | Mã | Số tiêu chí | Trọng tâm kiểm tra | Chương ASVS tham chiếu |
|---|---|---|---|---|
| AUTH | AUTH-01 đến AUTH-05 | 5 | Chống SQLi khi đăng nhập; lưu trữ mật khẩu; hạn chế thử mật khẩu; quản lý phiên; cờ cookie phiên | V2, V3 |
| AC | AC-01 đến AC-04 | 4 | Guard trang quản trị; guard endpoint hành động; phân quyền theo vai trò (RBAC); quyền trên đối tượng (IDOR) | V4 |
| INP | INP-01 đến INP-04 | 4 | Kiểm tra đầu vào phía server; truy vấn tham số; kiểm tra khóa số; xử lý tải tệp | V5, V12 |
| OUT | OUT-01 đến OUT-03 | 3 | Mã hóa đầu ra cho HTML text, thuộc tính HTML, JavaScript và URL | V5 |
| STATE | STATE-01 đến STATE-03 | 3 | Phương thức HTTP cho thao tác ghi; anti-CSRF; xác nhận phía server | V4 |
| ERR | ERR-01 đến ERR-03 | 3 | Che lỗi CSDL ở output; cấu hình hiển thị lỗi; thông tin kết nối và mật khẩu | V7, V14 |
| BIZ | BIZ-01 đến BIZ-05 | 5 | Kiểm tra số bản khả dụng; hạn mức mượn; ID và giao dịch khi mượn; thẻ bị khóa, quá hạn; nhất quán trả, hỏng, mất | V11 |
| **Tổng** | | **27** | | |

Rà soát đi theo bốn luồng chức năng: đăng nhập, phiên và quyền; sách và tìm kiếm; thành viên; mượn – trả. Trong mỗi luồng, người rà soát đi từ trang giao diện tới form, handler, câu SQL rồi tới điểm xuất dữ liệu. Include được lần theo đệ quy để xác định `session.php` có được nạp trước sink hay không. Thang kết luận và quy tắc áp dụng như sau:

- **Không đạt:** có bằng chứng tệp:dòng cho thấy biện pháp kiểm soát vắng mặt tại sink hoặc tại nhánh xử lý.
- **Một phần:** biện pháp kiểm soát có tồn tại nhưng thiếu thành phần bắt buộc, ví dụ có hủy phiên nhưng không đổi ID phiên sau đăng nhập.
- **Đạt:** biện pháp kiểm soát hiện diện trên mọi điểm vào thuộc phạm vi của tiêu chí.
- **Không áp dụng:** chức năng mà tiêu chí nhắm tới không tồn tại trong phạm vi.
- **Thiếu đặc tả:** tiêu chí nghiệp vụ không có SRS để đối chiếu. Mục này được ghi thành câu hỏi mở, không gán là lỗi.
- **Chưa đủ căn cứ:** kết luận phụ thuộc cấu hình máy chủ hoặc thông tin ngoài mã. Việc mã không cấu hình một cơ chế chưa chứng minh cơ chế đó cũng vắng mặt khi ứng dụng vận hành.
- **Cần làm rõ:** có dấu hiệu rủi ro nhưng chưa đủ thông tin về nguồn dữ liệu hoặc chính sách để kết luận.

### *4.2.2* Phân tích tự động: lựa chọn và cấu hình công cụ

Nhóm chọn công cụ theo bốn tiêu chí: chạy hoàn toàn cục bộ; đọc được mã PHP 5 thủ tục mà không cần Composer hay autoload; không phải sửa baseline; và tập trung vào lỗi an toàn thay vì phong cách mã. Danh sách khảo sát gồm Semgrep OSS, PHPStan, Psalm và PHP_CodeSniffer kèm PHPCompatibility [16]. Nhóm chạy thử trên ba tệp `login.php`, `dbcon.php` và `delete_user.php`. Khi không có stub, PHPStan dừng với lỗi "function not found" cho các hàm `mysql_*`. Khi có stub, PHPStan báo 0 lỗi trên `login.php`, tức bỏ sót SQL Injection ở dòng 6. Trong khi đó, Semgrep phân tích được cú pháp các tệp thử, báo luồng `$_POST` tới chuỗi SQL tại `login.php:6`, và với rule tùy biến thì nhận diện được thông tin kết nối cố định trong `dbcon.php`. Vì vậy Semgrep được chọn làm công cụ SAST chính [7]. PHPStan [8] chỉ được dùng để kiểm tra cấu trúc như include thiếu và tham chiếu không tồn tại, còn PHP lint dùng để kiểm tra cú pháp (Bảng 17).

***Bảng** 17. Công cụ phân tích tĩnh và cấu hình sử dụng*

| Công cụ | Phiên bản | Cấu hình | Vai trò | Đầu ra |
|---|---|---|---|---|
| PHP CLI (`php -l`) | 8.5.10 | Lint từng tệp; không gọi hàm nghiệp vụ | Kiểm tra cú pháp | `php_lint.json` |
| Semgrep OSS | 1.176.1 | 24 rule PHP lấy từ registry (các bộ `p/php`, `p/sql-injection`, `p/xss`), đóng băng thành snapshot cục bộ; 4 rule tùy biến (Bảng 18); loại `vendors/`; tắt metrics | SAST theo mẫu và theo luồng nhiễm bẩn | `semgrep_run1.json`, `semgrep_run2.json` |
| PHPStan | 2.1.8 | Level 0; tệp stub rỗng khai báo tên hàm `mysql_*`; tùy chọn `--debug` | Kiểm tra cấu trúc: include thiếu, tham chiếu không tồn tại | `phpstan_fresh.json` |

| Công cụ | Phiên bản | Cấu hình | Vai trò | Đầu ra |
|---|---|---|---|---|
| Bộ đọc token PHP | `token_get_all` của PHP CLI | Chỉ đọc văn bản; không include, không eval | Kiểm kê lời gọi `mysql_*`, biến `$_GET`, `$_POST` | `php_tokens.json` |
| DPLL tự viết và Z3 | z3-solver 5.1.0.0 | CNF lập thủ công; biến Bool và Int; chạy offline | Kiểm chứng hình thức bổ trợ (mục 4.2.5) | `formal_results.json` |

Bộ rule cộng đồng chỉ phát hiện các mẫu chung. Vì vậy nhóm viết thêm bốn rule nhận diện các mẫu đặc thù của mã `ext/mysql` (Bảng 18). Rule `php-direct-mysql-query-taint` được cố ý viết rộng, khớp mọi lời gọi `mysql_query`, để lập danh sách đầy đủ các điểm gọi truy vấn cho bước thẩm định thủ công. Một hit của rule này chưa phải là kết luận SQL Injection.

***Bảng** 18. Bốn rule Semgrep tùy biến*

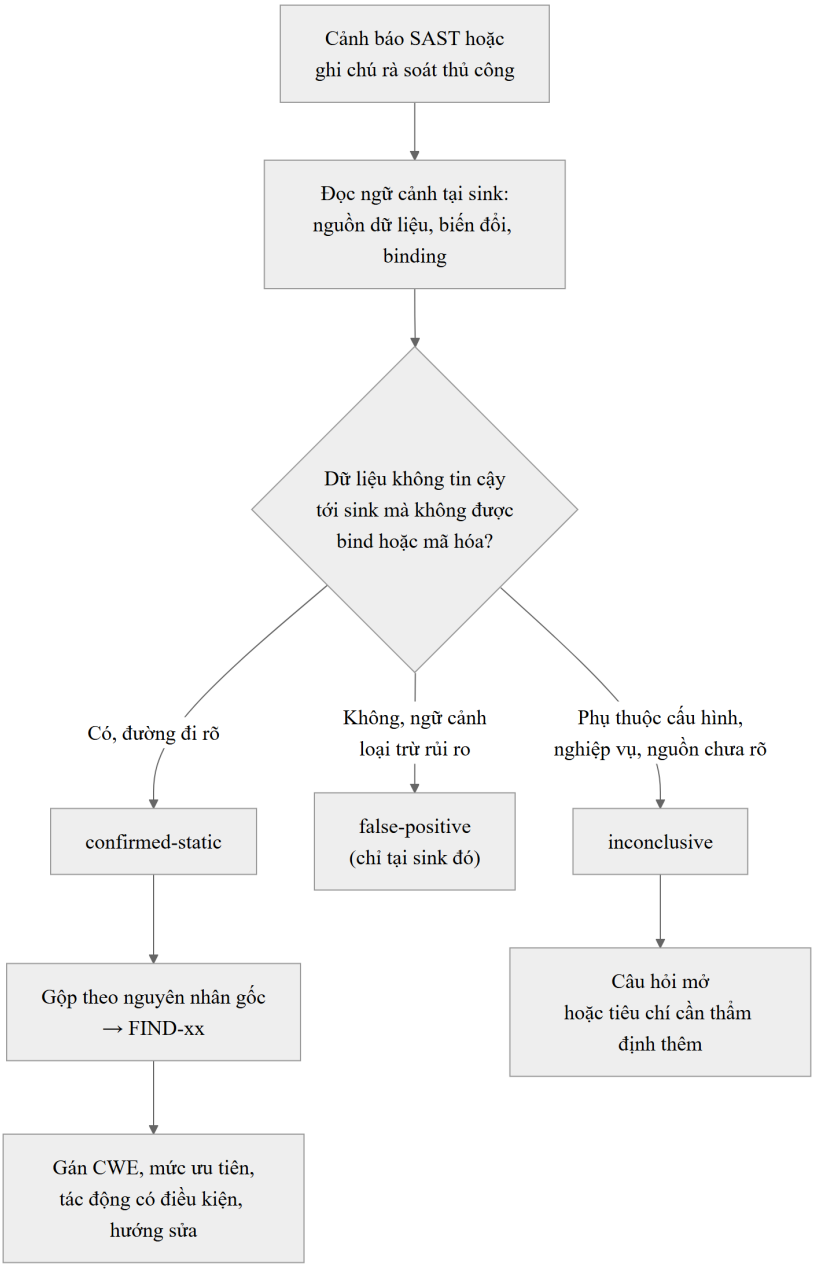
| Rule | CWE | Mức Semgrep | Mẫu so khớp | Mục đích |
|---|---|---|---|---|
| `php-legacy-mysql-extension` | CWE-477 | WARNING | `mysql_connect`, `mysql_select_db`, `mysql_query`, `mysql_fetch_array`, `mysql_error` | Đánh dấu API `ext/mysql` đã bị loại; không gồm `mysql_num_rows` |
| `php-mysql-error-information-disclosure` | CWE-209 | WARNING | `die(mysql_error())`, `echo mysql_error(...);` | Lỗi CSDL bị đưa ra output |
| `php-direct-mysql-query-taint` | CWE-89 | ERROR | `mysql_query(...)` | Liệt kê mọi điểm gọi truy vấn để thẩm định |
| `php-hardcoded-db-credentials` | CWE-798 | ERROR | `mysql_connect('...', '...', '...')` | Thông tin kết nối cố định trong mã |

Trong tệp rule gốc, mẫu `echo mysql_error(...)` thiếu dấu chấm phẩy. Do đó Semgrep báo lỗi phân tích rule (rule parse error) và rule CWE-209 không được nạp. Lần quét đầu kết thúc với mã thoát 2 và 270 hit. Nhóm sửa mẫu thành `echo mysql_error(...);` trên một bản sao (`custom_php_rules_corrected.yaml`), không sửa mã baseline. Hai lần quét mới dùng snapshot rule cố định và không tải registry trong khi quét. Một lần chạy chỉ được coi là hợp lệ khi đồng thời có mã thoát 0 và trường `errors` trong JSON rỗng [7]. Với PHPStan, stub chỉ khai báo tên hàm để công cụ không dừng vì thiếu ký hiệu. Stub không khôi phục `ext/mysql` và không mô phỏng CSDL. Các thông báo `whitespace.fileEnd` của PHPStan là vấn đề định dạng nên không được tính là lỗ hổng.

### *4.2.3* Thẩm định cảnh báo và gộp thành phát hiện

Mỗi cảnh báo được thẩm định theo quy trình ở Hình 13. Người thẩm định đọc mã tại vị trí cảnh báo, xác định nguồn của dữ liệu đi vào sink, kiểm tra trên đường đi có biện pháp làm sạch, ép kiểu hoặc binding nào không, và xét điều kiện để sink được gọi tới. Kết quả là một

trong ba trạng thái: `confirmed-static` khi đọc mã đủ chứng minh thiếu sót trong ngữ cảnh, `false-positive` khi ngữ cảnh loại trừ được rủi ro tại chính sink đó, và `inconclusive` khi chưa đủ căn cứ. Các cảnh báo cùng nguyên nhân gốc và cùng đường đi mã được gộp thành một phát hiện. Ví dụ, 147 hit của rule `ext/mysql` được gộp thành một phát hiện FIND-09. Mỗi phát hiện được gán mã CWE theo định nghĩa của MITRE [2], kèm vị trí tệp:dòng, tác động có điều kiện, hướng khắc phục và liên kết tới yêu cầu.




***Hình** 13. Quy trình thẩm định một cảnh báo*

Với SQL Injection, một hit `mysql_query(...)` chưa đủ để kết luận. Nhóm kiểm kê toàn bộ 54 điểm gọi `mysql_query` trong 37 tệp, gán mã SQL-01 đến SQL-54 theo tệp và dòng,

rồi ghi từng tham số nội suy vào câu lệnh (P01, P02, ...). Hồ sơ của mỗi tham số gồm biến PHP, nguồn (GET, POST hoặc kết quả CSDL), dòng gán, cột schema đích, kiểu và cận. Hai phép kiểm kê token độc lập cho cùng kết quả 54 điểm gọi. Mỗi điểm gọi được xếp vào một trong bốn lớp theo nguồn dữ liệu (Bảng 19). Kết quả kiểm kê được lưu trong hai sheet `SQLTruyVan` và `SQLDauVao` của tệp Excel [18].

***Bảng** 19. Tiêu chí phân loại điểm gọi truy vấn và kết luận tương ứng*

| Lớp | Điều kiện | Kết luận tại sink |
|---|---|---|
| `HTTP_INTERPOLATION` | Giá trị từ `$_GET` hoặc `$_POST` được nội suy trực tiếp vào chuỗi SQL, không binding | Không đạt SQLi; đối chiếu được đường đi từ nguồn tới truy vấn |
| `DB_AFTER_UNSAFE_SELECT` | Giá trị lấy từ kết quả của một SELECT trước đó, mà chính SELECT đó chưa bind dữ liệu HTTP | Nguy cơ nối tiếp; không mặc định tin kiểu cột của tập kết quả |
| `DB_INTEGER_INTERPOLATION` | Giá trị lấy từ cột INT của một truy vấn hằng | Chưa xác nhận SQLi; thiếu binding là vi phạm nguyên tắc gia cố (hardening) |
| `CONSTANT_QUERY` | Chuỗi SQL không có biến nội suy | Đối chứng: không phải SQLi tại sink này; lỗi API và lỗi xử lý lỗi xét riêng |

Mức ưu tiên là thang định tính của đồ án, không phải điểm CVSS. Nhóm diễn giải thang này như trong Bảng 20, và mức của cả 11 phát hiện nhất quán với các tiêu chí đó.

***Bảng** 20. Thang mức ưu tiên định tính*

| Mức | Tiêu chí | Phát hiện thuộc mức |
|---|---|---|
| Critical | Phá vỡ trực tiếp cơ chế xác thực hoặc kiểm soát truy cập trên dữ liệu của toàn phân hệ; không cần điều kiện nào ngoài khả năng gửi yêu cầu tới máy chủ | FIND-01, FIND-02 |
| High | Ảnh hưởng tính bí mật hoặc toàn vẹn của dữ liệu, nhưng cần thêm điều kiện như tương tác của người dùng hợp lệ hoặc quyền xem trang | FIND-03 đến FIND-06 |
| Medium | Ảnh hưởng toàn vẹn hoặc khả năng vận hành, phụ thuộc thời điểm thực thi hoặc cấu hình triển khai | FIND-07 đến FIND-09 |
| Low | Lộ thông tin hạn chế hoặc lỗi chất lượng làm chức năng thiếu hoàn chỉnh | FIND-10, FIND-11 |

### *4.2.4* Kiểm chứng tái lập và toàn vẹn baseline

Tính tái lập được kiểm chứng bằng hai lần quét Semgrep có cùng mã nguồn, cùng snapshot rule và cùng phiên bản công cụ. Mỗi cảnh báo được định danh bằng một *chữ ký* gồm `check_id`, đường dẫn tệp, tọa độ bắt đầu và tọa độ kết thúc. Hai tập chữ ký được so sánh để đếm số chữ ký chỉ xuất hiện ở lần 1 và số chữ ký chỉ xuất hiện ở lần 2. Toàn vẹn baseline

được kiểm chứng bằng cách tính SHA-256 của 66 tệp PHP, schema và tệp `LICENSE` trước và sau nghiên cứu. Kết luận tái lập chỉ áp dụng cho snapshot rule đã đóng băng, không áp dụng cho registry trực tuyến vốn thay đổi theo thời gian.

### *4.2.5* Kiểm chứng hình thức bổ trợ

Để làm rõ điều kiện bảo vệ mà mỗi hướng sửa phải đạt, nhóm xây dựng các cặp mã minh họa. Mã `_v0` tái tạo có chủ ý mẫu lỗi của baseline; mã `_v1` là phương án sửa đề xuất. Có năm cặp theo chức năng: `authentication`, `authorization`, `database_query`, `token_crypto`, `script_output`. Ngoài ra có 54 cặp wrapper SQL, mỗi cặp ứng với một điểm gọi truy vấn. Mỗi thuộc tính an toàn được mã hóa thành công thức logic mệnh đề ở dạng chuẩn hội (CNF). Công thức được giải bằng bộ giải DPLL do nhóm tự viết [21], rồi đối chiếu với Z3 [22] và với phép vét cạn bảng chân trị.

Với phân quyền, biến G nghĩa là thao tác được cho phép, A là đã xác thực, R là có quyền. Quan hệ của mã sau sửa là $G \leftrightarrow (A \wedge R)$. Để tìm phản ví dụ cho thuộc tính $G \rightarrow (A \wedge R)$, bộ giải được cho giải quan hệ của chương trình cùng với phủ định của thuộc tính. Kết quả SAT nghĩa là tồn tại phản ví dụ; UNSAT nghĩa là không có phản ví dụ trong mô hình trừu tượng đã khai báo. Ở dạng DIMACS, với biến 1 = G, 2 = A, 3 = R, ba mệnh đề đầu biểu diễn quan hệ $G \leftrightarrow (A \wedge R)$ và hai mệnh đề cuối biểu diễn $G \wedge (\neg A \vee \neg R)$:

```
p cnf 3 5
-1 2 0
-1 3 0
1 -2 -3 0
1 0
-2 -3 0
```

Trên công thức này, DPLL lan truyền đơn vị G = true, suy ra A = true và R = true. Khi đó mệnh đề $(\neg A \vee \neg R)$ trở thành rỗng nên kết quả là UNSAT. Với mã trước sửa, quan hệ chỉ là G = true, nên bộ giải tìm được mô hình G = true, A = false, R = false (SAT). Các thuộc tính có miền số, như độ dài khóa, thời hạn hay cận của trường dữ liệu, được kiểm bằng SMT với biến Int. Mỗi điểm gọi SQL có ba bài toán: B (trước sửa), A (sau sửa) và C (đối chứng hợp lệ). Mỗi tham số SQL có sáu bài toán SMT: thiếu trường (MISSING), sai kiểu (TYPE), sai định dạng (FORMAT), vượt cận trên (MAX), dưới cận dưới (MIN) và giá trị hợp lệ (VALID).

Phần kiểm chứng này chỉ là bổ trợ. Phép dịch từ PHP sang mô hình được làm thủ công, và UNSAT chỉ có ý nghĩa trong phạm vi trừu tượng đã khai báo. Mã `_v1` chưa được tích hợp vào baseline. Kết quả được tóm tắt ở mục 5.1.6; chi tiết từng bài toán nằm trong các sheet `SATChiTiet` và `SMTChiTiet` của tệp Excel [18]. Kiểm thử tĩnh bộ nhớ dùng bộ phân tích trạng thái riêng và được trình bày ở mục 5.5.

## 4.3 Xây dựng đặc tả suy ngược

Đặc tả được suy ngược từ năm nguồn. Ba nguồn chính là mã của 66 tệp, schema `eb_lms.sql` và các liên kết điều hướng (thuộc tính `href`, `action` của form và quan hệ include). Nguồn thứ tư là các ràng buộc phía trình duyệt, gồm thuộc tính HTML `required`, `pattern`, `maxlength`, danh sách `option` và đoạn JavaScript nhúng. Nguồn thứ năm là README và ảnh chụp màn hình của upstream; nguồn này chỉ dùng để đối chiếu tên chức năng, không dùng làm căn cứ yêu cầu. Đặc tả được xây dựng qua bảy bước:

1. Xác định điểm vào theo vai trò kỹ thuật (Bảng 7). Mảnh mã không được include và trang không có liên kết điều hướng không được đặc tả thành FR, mà được ghi nhận riêng.
2. Lần theo từng luồng điều hướng: trang, form (phương thức và đích), handler, câu SQL, đích chuyển hướng. Mỗi luồng hoàn chỉnh tạo thành một use-case.
3. Trích yêu cầu chức năng: mỗi hành vi người dùng quan sát được tạo thành một FR, kèm nguồn tệp:dòng.
4. Trích quy tắc nghiệp vụ: mỗi điều kiện trong mã (lệnh `if`, mệnh đề `WHERE`, ràng buộc giao diện) tạo thành một BR, kèm nơi áp dụng (server, chỉ client, chỉ hiển thị). Quy tắc nghiệp vụ thường gặp nhưng vắng mặt trong mã được ghi thành BR mức C.
5. Trích yêu cầu phi chức năng: loại hiện trạng (HT) lấy từ mã và cấu hình; loại kỳ vọng (KV) suy ra từ từng phát hiện và OWASP ASVS [11]. NFR-01 đến NFR-11 được ánh xạ một – một với REQ-L01 đến REQ-L11 trong tệp Excel. Sáu yêu cầu REQ-G01 đến REQ-G06 trong sheet YeuCauChucNang của tệp Excel là tiêu chí cho mã minh họa _v1 ở mục 4.2.5: truy vấn đăng nhập tham số hóa, guard phiên và quyền, wrapper prepare/bind cho 54 truy vấn, serialize dữ liệu đưa vào script, token AES-256-GCM và các ràng buộc SMT của token. Chúng không phải yêu cầu suy ngược từ hệ thống gốc.
6. Mô hình hóa use-case, miền dữ liệu và biểu đồ tuần tự; chỉ vẽ những phần có trong mã.
7. Đặc tả dữ liệu đầu vào theo kết quả kiểm kê 54 điểm gọi SQL và 92 lần xuất hiện tham số (mục 4.2.3). Mỗi tham số có nguồn, cột schema, kiểu và cận. Đây là cơ sở cho kỹ thuật phân tích giá trị biên ở mục 4.4.

Mỗi yêu cầu được gán một mức tin cậy theo quy tắc ở Bảng 21. Cách ghi yêu cầu tuân theo ISO/IEC/IEEE 29148 [12]: mỗi yêu cầu diễn đạt một ý, có ID duy nhất, kiểm chứng được bằng ít nhất một test case và truy vết được về mã nguồn hoặc phát hiện.

***Bảng** 21. Quy tắc gán mức tin cậy cho yêu cầu suy ngược*

| Mức | Điều kiện gán | Ví dụ |
|---|---|---|
| R – Rõ ràng | Hành vi đọc được trực tiếp từ mã và có đường điều hướng từ giao diện tới | FR-01 (`index.php:14–45`); BR-04 (`borrow_save.php:8–9`) |
| S – Suy luận | Hành vi có trong mã nhưng phải suy diễn ý nghĩa, hoặc tệp không có liên kết điều hướng hay có include lỗi; NFR kỳ vọng suy ra từ phát hiện và chuẩn tham chiếu | FR-14 (`archive.php` không có liên kết, include thiếu); BR-10 (ý nghĩa lớp `range-low-today` của bộ chọn ngày) |
| C – Chưa đủ đặc tả | Quy tắc hợp lý nhưng không có trong mã và không có văn bản quy định; được ghi thành câu hỏi mở | BR-11 đến BR-15 |

Nguyên tắc hai lớp (mục 3.2) được áp dụng khi hành vi hiện có mâu thuẫn với yêu cầu an toàn. Ví dụ, FR-05 ghi nhận rằng danh sách tài khoản hiển thị cả mật khẩu, còn NFR-05 yêu cầu không hiển thị mật khẩu. Test case của FR-05 kiểm tra danh sách có được hiển thị; test case của NFR-05 kiểm tra mật khẩu không xuất hiện. Mâu thuẫn được giữ công khai trong đặc tả và chỉ được giải quyết khi FIND-05 được khắc phục.

## 4.4 Thiết kế test case

Đồ án có hai bộ test case với mục đích khác nhau:

- **Bộ kiểm tra tĩnh (đã thực hiện).** Đây là sheet `TestCase` trong tệp Excel, gồm 22 TC tổng hợp (TC-01 đến TC-22) và 794 case con: 54 case nguồn SQL, 178 case SAT/CNF và 562 case SMT, tổng cộng 816 hồ sơ [18]. Đầu vào là văn bản nguồn, schema, rule hoặc công thức. "Kết quả thực tế" là kết quả của công cụ hoặc của rà soát. Kết luận "Không đạt" nghĩa là tiêu chí an toàn của mã nguồn bị vi phạm.
- **Bộ test case động (thiết kế, chưa thực thi).** Bộ này nằm ở Phụ lục E, dùng để kiểm chứng hành vi chức năng (FR, BR) và yêu cầu an toàn (NFR, phát hiện) khi ứng dụng được chạy trong môi trường thử nghiệm. Mỗi test case có cột "Dự đoán trên baseline", ghi kết quả *suy ra từ phân tích tĩnh*, không phải kết quả thực thi. Toàn bộ test case mang trạng thái "Chưa thực thi".

Bộ test case động dùng năm kỹ thuật (Bảng 22). Bốn kỹ thuật đầu theo ISO/IEC/IEEE 29119-4 [10] và Myers [13]. Kỹ thuật thứ năm suy ra test case an toàn từ mã CWE của từng phát hiện, theo hướng dẫn phòng chống của OWASP [23], [24], [25].

***Bảng** 22. Kỹ thuật thiết kế test case và cách áp dụng*

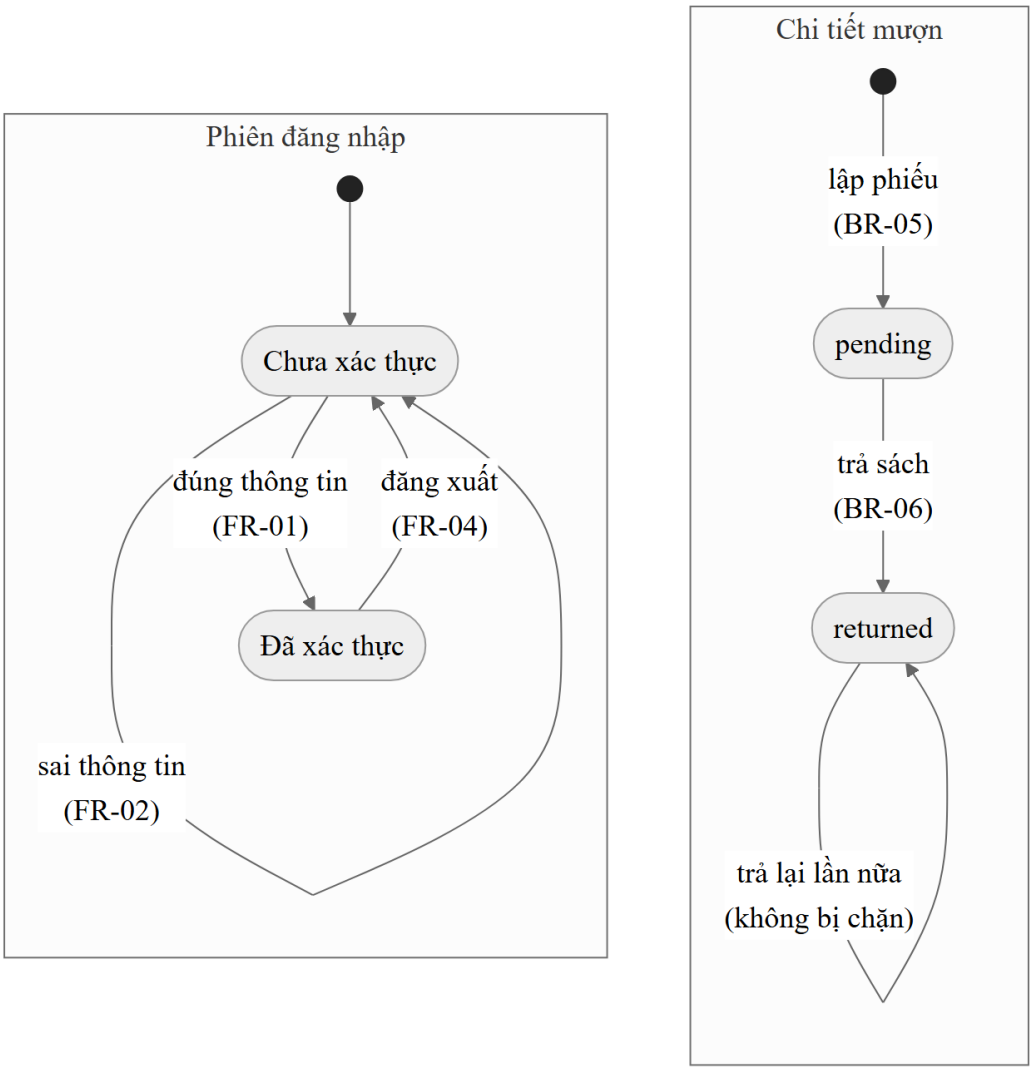
| Kỹ thuật | Cách suy ra test case | Ví dụ |
|---|---|---|
| Phân vùng tương đương (EP) | Chia miền đầu vào thành lớp hợp lệ và không hợp lệ theo schema và tập giá trị của giao diện; mỗi lớp có ít nhất một test case | Số điện thoại chứa chữ cái (TC-MEMB-03) |

| Kỹ thuật | Cách suy ra test case | Ví dụ |
|---|---|---|
| Phân tích giá trị biên (BVA) | Với `varchar(n)`: độ dài n và n + 1; với INT có cận dưới 0 hoặc 1: −1, 0, 1; số sách mỗi phiếu: 2, 3, 4; hạn trả: hôm qua, hôm nay, ngày mai | `book_copies` ∈ {−1, 0, 1} (TC-BOOK-04); số sách mỗi phiếu (TC-CIRC-03) |
| Bảng quyết định (DT) | Liệt kê tổ hợp điều kiện và hành động; mỗi quy tắc của bảng là một test case | Đăng nhập (TC-AUTH-01 đến TC-AUTH-03); lập phiếu mượn (Bảng 23) |
| Chuyển trạng thái (ST) | Phủ mọi chuyển trạng thái hợp lệ và ít nhất một chuyển trạng thái không hợp lệ | Phiên đăng nhập; chi tiết mượn pending → returned (Hình 14) |
| Test case an toàn theo CWE (SEC) | Mỗi phát hiện có ít nhất một test case tái hiện (R) trên baseline và một test case hồi quy (H) dùng sau khi sửa | TC-FIND01-R, TC-FIND01-H |

Bảng 23 là ví dụ bảng quyết định cho thao tác lập phiếu mượn. Bảng đặt hành động kỳ vọng theo đặc tả cạnh hành động dự đoán trên baseline, nên chênh lệch giữa hai dòng chính là khoảng trống cần kiểm chứng. Quy tắc Q4 và Q5 phụ thuộc hai quy tắc nghiệp vụ mức C (BR-11, BR-13). Vì vậy kỳ vọng của hai quy tắc này ghi "chờ xác nhận", không được coi là đã biết.

***Bảng** 23. Bảng quyết định cho thao tác lập phiếu mượn (UC-16)*

| Điều kiện / hành động | Q1 | Q2 | Q3 | Q4 | Q5 |
|---|---|---|---|---|---|
| C1. Có chọn ít nhất một sách | Không | Có | Có | Có | Có |
| C2. Số sách trong phiếu ≤ 3 | – | Có | Không | Có | Có |
| C3. Sách còn bản cho mượn (BR-11, mức C) | – | Có | Có | Không | Có |
| C4. Thành viên ở trạng thái Active (BR-13, mức C) | – | Có | Có | Có | Không |
| Hành động kỳ vọng | Quay lại, không ghi | Ghi phiếu | Từ chối | Chờ xác nhận | Chờ xác nhận |
| Hành động dự đoán trên baseline | Quay lại, không ghi | Ghi phiếu | Ghi phiếu | Ghi phiếu | Ghi phiếu |
| Test case | TC-CIRC-02 | TC-CIRC-01 | TC-CIRC-04 | TC-CIRC-07 | TC-CIRC-08 |




***Hình** 14. Mô hình chuyển trạng thái dùng cho kỹ thuật ST: phiên đăng nhập và chi tiết mượn*

Ở Hình 14, chuyển trạng thái returned → returned là chuyển *không hợp lệ* theo đặc tả, nhưng mã không chặn chuyển này (BR-06). Vì vậy chuyển này được thiết kế thành một test case âm (TC-CIRC-11). Mỗi test case động có các trường theo cấu trúc tài liệu kiểm thử của ISO/IEC/IEEE 29119-3 [14]: ID; truy vết (FR, BR, NFR, UC, FIND); kỹ thuật; loại (+ hợp lệ, − không hợp lệ, R tái hiện, H hồi quy); điều kiện, dữ liệu và các bước; kết quả mong đợi; dự đoán trên baseline; trạng thái. Bộ test case phải đạt bốn tiêu chí phủ:

1. Mỗi FR có ít nhất một test case loại + và một test case loại −.
2. Mỗi BR và mỗi NFR có ít nhất một test case.
3. Mỗi phát hiện có ít nhất một test case R và một test case H.
4. Mỗi BR mức C có test case với kết quả mong đợi ghi "chờ xác nhận", để test case sẵn sàng khi quy tắc được phê duyệt.

Hai chỉ số phủ được tính là *tỷ lệ phủ yêu cầu* (số yêu cầu có ít nhất một test case chia cho tổng số yêu cầu) và *tỷ lệ phủ phát hiện* (số phát hiện có đủ cặp R và H chia cho 11). Dữ liệu kiểm thử an toàn chỉ dừng ở mức thăm dò, như một ký tự nháy đơn hoặc một thẻ định dạng HTML vô hại (thẻ in nghiêng); không dùng chuỗi khai thác hoàn chỉnh. Test case chỉ được thực thi trong môi trường cô lập: máy ảo hoặc container chạy PHP 5.6 với MySQL, dùng dữ liệu tổng hợp, không kết nối mạng ngoài. Việc thực thi chỉ diễn ra khi đã được phê duyệt, phù hợp với các ràng buộc đạo đức ở mục 3.3.3.

# 5. Kết quả và phân tích

Chương này trình bày kết quả theo đúng thứ tự các câu hỏi nghiên cứu ở Bảng 3. Mục 5.1 trả lời RQ-A1 đến RQ-A3, mục 5.2 trả lời RQ-B1, mục 5.3 trả lời RQ-B2 và mục 5.4 trả lời RQ-AB. Mọi số liệu đều lấy từ output đã lưu của công cụ, từ tệp Excel [18] hoặc từ kết quả đếm lại trên mã baseline.

## 5.1 Kết quả kiểm thử tĩnh

### *5.1.1* Kết quả rà soát theo checklist

Cả 27 tiêu chí đều có kết luận, kèm bằng chứng tệp:dòng hoặc lý do chưa thể kết luận (Bảng 24; bản đầy đủ ở Phụ lục A). Có 14 tiêu chí *Không đạt* và 2 tiêu chí *Thiếu cơ chế* hoặc *Một phần*. Chỉ 1 tiêu chí *Đạt*: AC-01, trang giao diện có kiểm tra phiên. Kết quả này cho thấy biện pháp kiểm soát duy nhất được hiện thực nhất quán trong mã nằm ở tầng trang giao diện.

***Bảng** 24. Tổng hợp kết luận checklist theo nhóm tiêu chí*

| Nhóm | Số tiêu chí | Không đạt | Thiếu cơ chế, một phần | Đạt | Không áp dụng | Thiếu đặc tả | Chưa đủ căn cứ, cần làm rõ |
|---|---|---|---|---|---|---|---|
| AUTH | 5 | 2 | 2 | 0 | 0 | 0 | 1 |
| AC | 4 | 1 | 0 | 1 | 0 | 1 | 1 |
| INP | 4 | 3 | 0 | 0 | 1 | 0 | 0 |
| OUT | 3 | 2 | 0 | 0 | 0 | 0 | 1 |
| STATE | 3 | 3 | 0 | 0 | 0 | 0 | 0 |
| ERR | 3 | 2 | 0 | 0 | 0 | 0 | 1 |
| BIZ | 5 | 1 | 0 | 0 | 0 | 3 | 1 |
| **Tổng** | **27** | **14** | **2** | **1** | **1** | **4** | **5** |

Năm tiêu chí ở cột cuối gồm AUTH-05, AC-04, OUT-03, ERR-02 và BIZ-05. Đây là các trường hợp mà việc vắng mặt một cơ chế trong mã chưa đủ để kết luận. AUTH-05 và ERR-02 cần thêm cấu hình máy chủ. AC-04 cần chính sách sở hữu đối tượng. OUT-03 có nguồn dữ liệu hiện là cột INT. BIZ-05 cần quy tắc nghiệp vụ về sách mất, sách hỏng. Bốn tiêu chí *Thiếu đặc tả* (AC-03, BIZ-01, BIZ-02, BIZ-04) không bị tính là lỗi mà được chuyển thành câu hỏi mở ở mục 5.2.

### *5.1.2* Kết quả công cụ tự động

Bảng 25 tóm tắt kết quả chạy công cụ. Hai lần quét Semgrep hợp lệ có mã thoát 0 và trường `errors` rỗng. Lần quét lịch sử có mã thoát 2 vì rule CWE-209 không được nạp, nên không được dùng làm số liệu chính.

***Bảng** 25. Kết quả chạy công cụ phân tích tĩnh*

| Phép kiểm tra | Kết quả | Mã thoát, ghi chú |
|---|---|---|
| Semgrep lần 1 | 322 hit trên 66 tệp; trường `errors` rỗng | 0 |
| Semgrep lần 2 | 322 hit; tập chữ ký trùng hoàn toàn với lần 1 | 0 |
| Semgrep lần quét lịch sử (10/09/2026) | 270 hit | 2; lỗi parse rule CWE-209 |
| PHPStan level 0 | 17 thông báo trên 16 tệp: 14 `whitespace.fileEnd`, 3 include thiếu | 1 |
| PHP lint | 66/66 tệp hợp lệ cú pháp | 0 với mọi tệp |
| Mã băm baseline | 66/66 tệp PHP không đổi; schema và `LICENSE` khớp | — |

Trong 24 rule lấy từ registry, chỉ hai rule có hit: `tainted-sql-string` và `echoed-request`. 254 hit còn lại thuộc bốn rule tùy biến (Bảng 26). Mức ERROR, WARNING của Semgrep phản ánh cấu hình rule, không tương đương với mức ưu tiên Critical, High của đồ án. Log của hai lần quét ghi 28 rule được nạp nhưng chỉ 27 rule chạy: rule registry `wp-ssrf-audit` giới hạn đường dẫn ở `wp-content/plugins/` nên không áp dụng cho tệp nào của librarian/. Khi bỏ giới hạn đó, cả 28 rule cùng chạy và tổng vẫn là 322 hit.

***Bảng** 26. Phân bố 322 cảnh báo theo rule và phát hiện được gộp vào*

| Rule | CWE | Mức Semgrep | Số hit | Gộp vào |
|---|---|---|---|---|
| `php-legacy-mysql-extension` (tùy biến) | CWE-477 | WARNING | 147 | FIND-09 |
| `php-direct-mysql-query-taint` (tùy biến) | CWE-89 | ERROR | 54 | FIND-01, FIND-03 (23 điểm gọi); 31 điểm còn lại được xét riêng |
| `php-mysql-error-information-disclosure` (tùy biến) | CWE-209 | WARNING | 52 | FIND-10 |
| `echoed-request` (registry) | CWE-79 | ERROR | 42 | FIND-04 |
| `tainted-sql-string` (registry) | CWE-89 | ERROR | 26 | FIND-01, FIND-03 |
| `php-hardcoded-db-credentials` (tùy biến) | CWE-798 | ERROR | 1 | FIND-08 |
| **Tổng** | | 123 ERROR, 199 WARNING | **322** | 6 phát hiện |

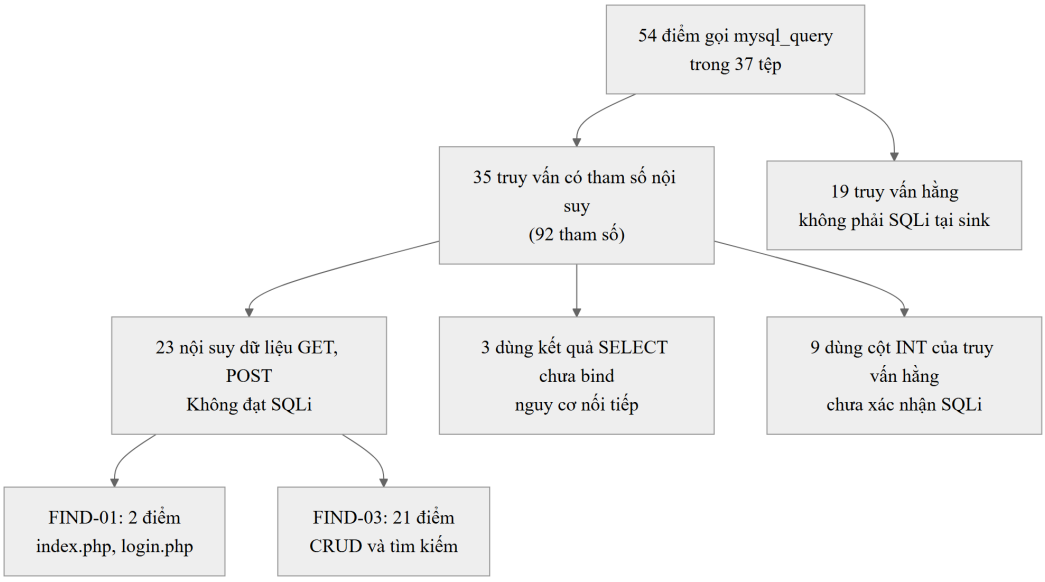
### *5.1.3* Thẩm định cảnh báo: chênh lệch giữa cảnh báo thô và phát hiện (RQ-A2)

Sau khi thẩm định và gộp theo nguyên nhân gốc, 322 cảnh báo thô còn lại 11 phát hiện. Con số 322 vì vậy không phải số lỗ hổng. Phần lớn chênh lệch đến từ việc gộp: 147 hit `ext/mysql` thuộc cùng một nguyên nhân (FIND-09), 52 hit `mysql_error` thuộc một

nguyên nhân khác (FIND-10). Phần còn lại cần thẩm định từng vị trí. Nhóm không gán đúng/sai cho toàn bộ 322 hit, nên không tính precision, recall hay tỷ lệ cảnh báo giả cho toàn tập. Tuy vậy, với rule CWE-89 tùy biến, việc kiểm kê từng điểm gọi cho phép đánh giá đầy đủ cả 54 hit (Bảng 27, Hình 15).

***Bảng** 27. Kết quả phân loại 54 điểm gọi truy vấn*

| Lớp | Số truy vấn | Số tham số | Kết luận |
|---|---|---|---|
| `HTTP_INTERPOLATION` | 23 | 80 (79 từ GET, POST; 1 từ CSDL) | Không đạt SQLi: 2 điểm ở đăng nhập (FIND-01), 21 điểm ở CRUD và tìm kiếm (FIND-03) |
| `DB_AFTER_UNSAFE_SELECT` | 3 | 3 | Nguy cơ nối tiếp: `advance_search.php:65, 73`, `edit_book.php:32` |
| `DB_INTEGER_INTERPOLATION` | 9 | 9 | Chưa xác nhận SQLi; thiếu binding vi phạm nguyên tắc gia cố |
| `CONSTANT_QUERY` | 19 | 0 | Không phải SQLi tại sink, ví dụ `users.php:39` |
| **Tổng** | **54** | **92** | |




***Hình** 15. Cây phân loại 54 điểm gọi truy vấn theo nguồn dữ liệu*

Với rule CWE-89 tùy biến, 23/54 hit (42,6%) là SQL Injection xác nhận tại sink, 12/54 (22,2%) cần thêm ngữ cảnh, và 19/54 (35,2%) không phải SQL Injection tại sink. Tỷ lệ này chỉ áp dụng cho một rule cố ý viết rộng, không áp dụng cho toàn bộ 322 hit. Rule theo luồng nhiễm bẩn `tainted-sql-string` chính xác hơn rõ rệt. Theo output lưu vị trí của lần quét lịch sử (rule này có cùng 26 hit ở cả ba lần quét), 26 hit nằm trong 20 tệp và trùng

đúng với 23 điểm `HTTP_INTERPOLATION` cộng 3 điểm `DB_AFTER_UNSAFE_SELECT`. Rule không báo truy vấn hằng nào và không bỏ sót điểm nhận dữ liệu HTTP nào.

Với XSS, kết quả ngược lại. Rule `echoed-request` cho 42 hit, tất cả nằm trong bốn tệp `advance_search.php`, `edit_book.php`, `edit_member.php` và `edit_student.php`. Rule chỉ hit các tệp này vì chúng đọc `$_GET` hoặc `$_POST` ở đầu tệp, nên công cụ coi mọi dữ liệu xuất ra là nhiễm bẩn. Trong số đó, chỉ giá trị ID ở ô ẩn của form sửa (ví dụ `edit_book.php:24`, `edit_member.php:24`) là phản chiếu trực tiếp request; các hit còn lại là dữ liệu đọc từ CSDL. Ngược lại, rule không có hit nào ở các trang danh sách chỉ đọc CSDL như `books.php:74, 76`, `users.php:43–46` hay `member.php`. Đây lại là các vị trí chính của FIND-04 (Stored XSS) và chỉ được phát hiện bằng rà soát thủ công. Cũng vì lý do tương tự, kết luận cũ của hồ sơ nghiên cứu xếp hit tại `advance_search.php:76` là cảnh báo giả (FP-01) được chuyển thành *cần thẩm định*. Lý do là dòng dữ liệu được xuất ra đến từ truy vấn SQL-02, vốn nội suy dữ liệu chưa bind, nên giả định "ID kiểu INT luôn an toàn" không còn chắc đúng.

Bảng 28 đối chiếu nguồn phát hiện của từng phát hiện.

***Bảng** 28. Nguồn phát hiện của 11 phát hiện*

| Phát hiện | Semgrep | PHPStan, lint, kiểm kê token | Rà soát thủ công |
|---|---|---|---|
| FIND-01 | `tainted-sql-string`; rule CWE-89 tùy biến | — | Có |
| FIND-02 | — | — | Có: lần theo include của 12 handler |
| FIND-03 | `tainted-sql-string`; rule CWE-89 tùy biến | — | Có |
| FIND-04 | `echoed-request` (4 tệp form, tìm kiếm) | — | Có: các trang danh sách |
| FIND-05 | — | — | Có |
| FIND-06 | — | — | Có |
| FIND-07 | — | — | Có |
| FIND-08 | Rule CWE-798 tùy biến | — | Có |
| FIND-09 | Rule CWE-477 tùy biến | Kiểm kê token; PHPStan không stub báo hàm không tồn tại | Có |
| FIND-10 | Rule CWE-209 tùy biến (sau khi sửa) | Kiểm kê token: 52 lời gọi | Có |
| FIND-11 | — | PHPStan: 3 include thiếu | Có: bảng `students`, tệp rỗng, `students.php` |

Câu trả lời cho RQ-A2 có ba ý. Thứ nhất, 322 cảnh báo thô được gộp thành 11 phát hiện, chủ yếu nhờ gộp theo nguyên nhân gốc. Thứ hai, cảnh báo giả tập trung ở rule viết rộng: 19 truy vấn hằng bị rule CWE-89 tùy biến đánh dấu. Rule `echoed-request` vừa báo cả dữ liệu không đến trực tiếp từ request, vừa bỏ sót các trang danh sách. Thứ ba, bốn phát hiện chỉ rà soát thủ công mới tìm ra: FIND-02, FIND-05, FIND-06 và FIND-07, trong đó có một phát hiện Critical. Cả bốn đều là lỗi *thiếu kiểm soát* hoặc *lỗi logic*, tức không có đoạn mã nào để công cụ so khớp. Nếu chỉ dùng 24 rule registry, chỉ ba phát hiện có cảnh báo tương ứng: FIND-01, FIND-03 và một phần FIND-04.

### *5.1.4* Sổ phát hiện xác nhận tĩnh (RQ-A1)

Bảng 29 tóm tắt 11 phát hiện có trạng thái `confirmed-static`; bản đầy đủ có nguyên nhân, tác động có điều kiện và hướng khắc phục nằm ở Phụ lục B. Phân bố theo mức ưu tiên là 2 Critical, 4 High, 3 Medium và 2 Low. Mười phát hiện là điểm yếu an toàn. Riêng FIND-11 là lỗi chất lượng, cấu trúc nên được ghi riêng và không tính là lỗ hổng. Theo CWE, nhóm chèn mã chiếm ba phát hiện (CWE-89 hai lần, CWE-79 một lần); nhóm kiểm soát truy cập và trạng thái chiếm hai phát hiện (CWE-306, CWE-352). Cả hai phát hiện Critical đều nằm ở ranh giới xác thực: đầu vào của form đăng nhập và các handler không kiểm tra phiên.

***Bảng** 29. Mười một phát hiện xác nhận tĩnh*

| ID | Phát hiện | CWE | Mức | Vị trí chính |
|---|---|---|---|---|
| FIND-01 | SQL Injection trong xác thực | CWE-89 | Critical | `index.php:36–44`; `login.php:4–12` |
| FIND-02 | Thiếu kiểm tra phiên ở 12 handler ghi dữ liệu | CWE-306 | Critical | `delete_*.php`, `*_save.php`, `update_*.php` |
| FIND-03 | SQL Injection trong CRUD và tìm kiếm | CWE-89 | High | 21 điểm gọi, ví dụ `books_save.php:20–21` |
| FIND-04 | Dữ liệu động không được mã hóa khi xuất HTML | CWE-79 | High | `books.php:73–76`; `edit_book.php:23–24` |
| FIND-05 | Mật khẩu lưu và hiển thị dạng bản rõ | CWE-256 | High | `users.php:43–46`; `modal_edit_user.php:14–16` |
| FIND-06 | Thao tác ghi qua GET, thiếu anti-CSRF | CWE-352 | High | 5 handler GET; `delete_books.php:2–5` |
| FIND-07 | Lấy sai ID, thiếu tính nguyên tử khi mượn | CWE-362 | Medium | `borrow_save.php:17–29` |
| FIND-08 | Cấu hình kết nối cố định, tài khoản root | CWE-798 | Medium | `dbcon.php:2` |
| FIND-09 | API `ext/mysql` đã lỗi thời | CWE-477 | Medium | 147 lời gọi trong 38 tệp |
| FIND-10 | Lỗi CSDL đưa trực tiếp ra output | CWE-209 | Low | 52 lời gọi trong 37 tệp |
| FIND-11 | Include thiếu, tham chiếu cấu trúc không hoàn chỉnh | Lỗi chất lượng | Low | `archive.php:3`; `unstudents.php:3, 29, 44` |

Hai đầu vào cụ thể dưới đây minh họa hai phát hiện Critical. Chúng được suy ra tĩnh từ mã nguồn và chưa được chạy, theo nguyên tắc không thực thi ở mục 2.4.3.

**FIND-01** (index.php:38–44). Nhập tên đăng nhập `' OR '1'='1' --` (có dấu cách ở cuối) và mật khẩu bất kỳ. Câu lệnh trở thành `SELECT * FROM users WHERE username='' OR '1'='1' -- ' AND password='…'`. Phần sau `--` là chú thích nên điều kiện WHERE luôn đúng, `$num_row > 0` và phiên được cấp cho người dùng đầu tiên của bảng users mà không cần mật khẩu. Điều kiện: magic_quotes_gpc không bật (tính năng này bị gỡ từ PHP 5.4; các hàm mysql_* còn đến PHP 5.6).

**FIND-02 kết hợp FIND-06** (delete_books.php:2–4). Tệp chỉ include `dbcon.php`, không include `session.php`. Yêu cầu `GET /librarian/delete_books.php?id=1` từ một trình duyệt chưa đăng nhập vẫn chạy `update book set status = 'Archive' where book_id='1'`. Đặt cùng URL vào thẻ `<img src>` trên một trang bất kỳ thì trình duyệt của thủ thư đang đăng nhập sẽ tự gửi yêu cầu, tức một tấn công CSRF.

Câu trả lời cho RQ-A1: phân hệ `librarian/` có 10 điểm yếu an toàn xác nhận được bằng phân tích tĩnh cùng 1 lỗi chất lượng. Hai điểm yếu nghiêm trọng nhất cho phép phá vỡ ranh giới xác thực. Các điểm yếu còn lại trải trên toàn bộ vòng đời dữ liệu: đầu vào (CWE-89), lưu trữ (CWE-256), đầu ra (CWE-79, CWE-209), thao tác đổi trạng thái (CWE-352, CWE-362) và cấu hình (CWE-798, CWE-477).

### *5.1.5* Tính tái lập và toàn vẹn baseline (RQ-A3)

Hai lần quét hợp lệ cho cùng 322 chữ ký cảnh báo: 0 chữ ký chỉ có ở lần 1 và 0 chữ ký chỉ có ở lần 2. Mã băm của 66/66 tệp PHP, của schema và của tệp `LICENSE` trùng nhau trước và sau nghiên cứu. Chênh lệch giữa lần quét lịch sử (270 hit) và hai lần quét hợp lệ (322 hit) đúng bằng 52 hit của rule CWE-209, rule mà lần đầu không nạp được do lỗi cú pháp. Ứng dụng không phát sinh thêm 52 lỗ hổng. Câu trả lời cho RQ-A3: kết quả phân tích tự động tái lập hoàn toàn khi cố định baseline, phiên bản công cụ và snapshot rule. Trường hợp lần quét lịch sử cũng cho thấy chỉ đếm số hit là chưa đủ: một lần chạy có mã thoát khác 0 hoặc có trường `errors` không rỗng có thể âm thầm thiếu cả một nhóm cảnh báo.

### *5.1.6* Kết quả kiểm chứng hình thức bổ trợ

Bảng 30 tóm tắt 740 bài toán SAT và SMT. Tất cả đều cho kết quả đúng kỳ vọng, và ba bộ kiểm tra DPLL, Z3 và bảng chân trị trùng nhau trên mọi công thức CNF.

***Bảng** 30. Kết quả kiểm chứng hình thức*

| Nhóm bài toán | Số lượng | Kết quả |
|---|---|---|
| CNF theo chức năng (5 cặp mã sinh, đối chứng hợp lệ, 1 đối chứng quay lui) | 16 | 10 SAT, 6 UNSAT; DPLL, Z3, bảng chân trị trùng 16/16 |
| SMT cho token (mã sinh `token_crypto`) | 10 | 1 SAT (`_v0`), 8 UNSAT (vi phạm ở `_v1`), 1 SAT (đối chứng hợp lệ) |

| Nhóm bài toán | Số lượng | Kết quả |
|---|---|---|
| CNF SQL (54 truy vấn × 3) | 162 | B: 35 SAT (truy vấn có tham số), 19 UNSAT (truy vấn hằng); A: 54 UNSAT; C: 54 SAT |
| SMT tham số SQL (92 tham số × 6) | 552 | MISSING, TYPE, FORMAT, MAX: mỗi loại 92 UNSAT; MIN: 36 UNSAT (số nguyên) và 56 SAT (chuỗi rỗng được schema cho phép); VALID: 92 SAT |
| Lint và quét mã sinh | 10 + 109 tệp | Lint 10/10 và 109/109; hit giảm từ 8 xuống 0 (mã theo chức năng) và từ 54 xuống 0 (wrapper SQL) |

Kết quả B ở 35 truy vấn có tham số khớp với phân loại ở Bảng 27: trong mô hình, trước khi sửa tồn tại trường hợp dữ liệu không tin cậy đi vào truy vấn chưa bind. Mười chín truy vấn hằng cho UNSAT cả trước và sau khi sửa, nên không bị tính là lỗ hổng. Các kết quả này chỉ chứng minh rằng điều kiện bảo vệ của mã `_v1` loại trừ được các vi phạm đã mô hình hóa. Chúng không chứng minh baseline đã được sửa, cũng không chứng minh an toàn mật mã hay hành vi khi chạy thực tế.

Sheet MoHinhTrangThai của tệp Excel [18] mô hình hóa luồng xác thực thành một cấu trúc Kripke năm trạng thái, dựng thủ công từ session.php, login.php và delete_user.php: unauthenticated (khởi tạo), denied, authenticated, authorized_write và unauthorized_write. Thuộc tính an toàn viết bằng CTL là `AG(write → authenticated)`: ở mọi trạng thái đạt được, thao tác ghi chỉ xảy ra khi đã xác thực. Thuộc tính này bị vi phạm với phản ví dụ unauthenticated → unauthorized_write, tức một handler ghi dữ liệu được gọi thẳng khi chưa đăng nhập (FIND-02). Hai thuộc tính `EF(denied)` và `EF(authenticated)` thỏa, cho thấy cả hai nhánh đăng nhập đều đạt được trong mô hình. Bảng 64 (Phụ lục H) tóm tắt kết quả. Mô hình giả định endpoint được gọi trực tiếp và truy vấn thành công, nên không chứng minh tính sống của hệ thống thật.

Bảng 65 (Phụ lục H) đặt cạnh nhau kết quả trước sửa (_v0) và sau sửa (_v1) trên cùng phép kiểm tra. Bộ sáu rule Semgrep dành cho mã sinh giảm từ 8 hit xuống 0 trên năm cặp chức năng và từ 54 hit xuống 0 trên 54 cặp wrapper SQL. Năm thuộc tính chức năng chuyển từ SAT sang UNSAT, và 35 truy vấn có tham số cũng chuyển từ SAT sang UNSAT. Đây là so sánh trên mã minh họa, không phải trên baseline đã được sửa.

## 5.2 Kết quả đặc tả (RQ-B1)

Đặc tả suy ngược gồm 52 yêu cầu và 18 use-case (Bảng 31). Có 65,4% yêu cầu ở mức R (rõ ràng), 25,0% ở mức S (suy luận) và 9,6% ở mức C (chưa đủ đặc tả). Phần lớn yêu cầu mức S là NFR kỳ vọng, vốn được suy ra từ phát hiện và từ ASVS chứ không đọc trực tiếp từ mã. Ngược lại, gần như mọi FR đạt mức R vì luồng điều hướng của phân hệ đơn giản và tường minh.

***Bảng** 31. Thống kê đặc tả suy ngược theo loại và mức tin cậy*

| Loại | Số lượng | R | S | C | Ghi chú |
|---|---|---|---|---|---|
| FR | 23 | 22 | 1 | 0 | Sáu module; FR-14 mức S vì `archive.php` không có liên kết và include thiếu |
| BR | 15 | 9 | 1 | 5 | Trong 10 quy tắc có trong mã: 4 áp dụng ở server, 5 chỉ ở client, 1 chỉ để hiển thị |
| NFR | 14 | 3 | 11 | 0 | 12 kỳ vọng, 1 vừa hiện trạng vừa kỳ vọng, 1 hiện trạng |
| **Tổng yêu cầu** | **52** | **34** | **13** | **5** | |
| UC | 18 | — | — | — | Kèm một misuse case suy ra từ FIND-02 |

Đặc tả dữ liệu đầu vào bao phủ 54 truy vấn trong 37 tệp. Trong đó có 35 truy vấn chứa tham số, với tổng 92 lần xuất hiện tham số: 79 lấy từ HTTP (68 POST, 11 GET) và 13 lấy từ CSDL. Theo kiểu, 36 tham số là số nguyên và 56 là chuỗi. Mỗi tham số có cột đích và cận theo schema (Phụ lục D.2). Đây là cơ sở để thiết kế các test case giá trị biên mà không phải đoán giới hạn.

Có ba nhóm điểm không thể đặc tả khi thiếu xác nhận nghiệp vụ:

1. **Quy tắc mượn – trả (BIZ-INC-01):** kiểm tra số bản còn lại (BR-11), hạn mức tổng (BR-12), thành viên bị khóa (BR-13), quá hạn và tiền phạt (BR-14), ghi nhận sách mất, hỏng (BR-15), và việc sách Lost hay Damage có được cho mượn hay không.
2. **Quy tắc quản trị:** mô hình vai trò (AC-03); tính duy nhất của tên đăng nhập (schema `users` chỉ có khóa chính); việc xóa thành viên đang có sách chưa trả (schema không có khóa ngoại).
3. **Chính sách dữ liệu:** trường nào bắt buộc ở server; ký tự đại diện `%` và `_` trong ô tìm kiếm là ký tự đại diện hay ký tự thường; định dạng chuẩn của hạn trả, vốn đang được lưu dạng chuỗi.

Trong quá trình đặc tả, nhóm ghi nhận các phần dư thừa của mã đã nêu ở mục 3.1.3 và 3.2.1. Nhóm student là bản sao của nhóm member: `student_save.php` và `member_save.php` trùng mã băm, `delete_student.php` và `delete_member.php` cũng vậy. `update_students.php:18` chuyển hướng tới `students.php`, một tệp không tồn tại. Sáu trang không có liên kết điều hướng, bảy mảnh mã không được include và một tệp rỗng. Hai bảng `lost_book` và `type` không được dùng, trong khi bảng `students` được truy vấn lại không có trong schema. Ngoài ra, việc đối chiếu hành vi với đặc tả làm lộ ra sáu *quan sát chức năng* (Bảng 32). Các quan sát này không thuộc 11 phát hiện an toàn, được suy ra hoàn toàn bằng phân tích tĩnh và cần kiểm thử động để xác nhận.

***Bảng** 32. Quan sát chức năng suy ra từ đối chiếu đặc tả*

| Mã | Quan sát | Vị trí | Yêu cầu | Test case |
|---|---|---|---|---|
| QS-01 | Sửa thành viên làm mất số điện thoại: form sửa không điền sẵn Contact nên handler ghi đè bằng chuỗi rỗng | `edit_member.php:48`; `update_member.php:9, 14` | FR-18 | TC-MEMB-06 |
| QS-02 | Tìm kiếm khi để trống một ô trả về toàn bộ sách chưa lưu trữ, do điều kiện `LIKE '%%'` khớp mọi dòng | `advance_search.php:58–59` | FR-15 | TC-SRCH-02 |
| QS-03 | Sửa tài khoản thực hiện câu UPDATE lặp theo số tài khoản, vì handler nằm trong tệp được include bên trong vòng lặp | `users.php:40–60`; `modal_edit_user.php:44–58` | FR-07 | TC-USER-06 |
| QS-04 | Không có ràng buộc tên đăng nhập duy nhất | Schema `users`; `modal_add_user.php:42–48` | FR-06 | TC-USER-05 |
| QS-05 | Số bản còn lại có thể âm vì không có ràng buộc khi lập phiếu | `books.php:59–65` | BR-02 | TC-BOOK-16 |
| QS-06 | Ràng buộc form không nhất quán: Category không bắt buộc; Gender là ô văn bản ở form sửa; Year Level bắt buộc ở form sửa nhưng không bắt buộc ở form thêm | `add_books.php:28`; `edit_member.php:36, 70`; `add_member.php:69` | FR-11, FR-17, FR-18 | TC-BOOK-06, TC-MEMB-08 |

Câu trả lời cho RQ-B1: khi không có SRS, có thể suy ngược đặc tả chức năng ở mức tin cậy cao (22/23 FR mức R). Tuy vậy, chỉ 4 trong 10 quy tắc nghiệp vụ có trong mã được áp dụng ở server; yêu cầu an toàn hoàn toàn phải suy ra từ phát hiện và chuẩn tham chiếu. Những điểm không thể đặc tả nếu thiếu xác nhận nghiệp vụ là các quy tắc mượn – trả, mô hình vai trò và chính sách dữ liệu; chúng được ghi thành câu hỏi mở thay vì gán là lỗi.

## 5.3 Kết quả thiết kế test case (RQ-B2)

### *5.3.1* Bộ kiểm tra tĩnh đã thực hiện

Bộ kiểm tra tĩnh trong tệp Excel gồm 816 hồ sơ (Bảng 33). Hai mươi hai TC tổng hợp là kết quả của phép đọc mã và chạy công cụ. 794 case con là các phép kiểm tra độc lập theo từng truy vấn, từng công thức và từng tham số. Mỗi hồ sơ tách riêng kết quả kỳ vọng và kết quả thực tế. Các TC tổng hợp không được tính là các lần chạy mới.

***Bảng** 33. Kết quả bộ kiểm tra tĩnh trong tệp Excel*

| Nhóm hồ sơ | Số lượng | Kết quả |
|---|---|---|
| TC tổng hợp trên baseline (TC-01 đến TC-16) | 16 | 11 Không đạt (TC-01 đến TC-11); 4 Đạt (TC-12 đến TC-15: lint, cấu hình scanner, tái lập, mã băm); 1 vi phạm trong mô hình (TC-16) |
| TC tổng hợp mã sinh và hình thức (TC-17 đến TC-22) | 6 | Khớp kỳ vọng: `_v0` SAT, `_v1` UNSAT, đối chứng SAT |

| Nhóm hồ sơ | Số lượng | Kết quả |
|---|---|---|
| Case nguồn SQL (SQL-01 đến SQL-54) | 54 | 23 Không đạt SQLi; 3 nguy cơ nối tiếp; 9 chưa xác nhận; 19 đạt đối chứng |
| Case SAT/CNF | 178 | 178/178 khớp kỳ vọng |
| Case SMT | 562 | 562/562 khớp kỳ vọng |
| **Tổng** | **816** | |

### *5.3.2* Bộ test case động đã thiết kế

Bộ test case động gồm 90 test case, tất cả ở trạng thái "Chưa thực thi" (Phụ lục E). Theo kỹ thuật, có 42 test case phân vùng tương đương, 9 giá trị biên, 8 bảng quyết định, 7 chuyển trạng thái và 24 test case an toàn theo CWE. Bảng 34 phân bố test case theo module, loại và dự đoán trên baseline.

***Bảng** 34. Phân bố 90 test case động theo module, loại và dự đoán trên baseline*

| Module | Số TC | + | − | R | H | Đạt | Không đạt | Phụ thuộc cấu hình | Chờ xác nhận |
|---|---|---|---|---|---|---|---|---|---|
| AUTH | 10 | 3 | 7 | – | – | 5 | 3 | 2 | 0 |
| USER | 9 | 5 | 4 | – | – | 5 | 2 | 1 | 1 |
| BOOK | 18 | 7 | 11 | – | – | 9 | 5 | 4 | 0 |
| SRCH | 5 | 1 | 4 | – | – | 3 | 1 | 0 | 1 |
| MEMB | 10 | 5 | 5 | – | – | 3 | 5 | 1 | 1 |
| CIRC | 16 | 4 | 12 | – | – | 6 | 5 | 0 | 5 |
| FIND | 22 | – | – | 11 | 11 | 0 | 22 | 0 | 0 |
| **Tổng** | **90** | **25** | **43** | **11** | **11** | **31** | **43** | **8** | **8** |

Bộ test case đạt cả bốn tiêu chí phủ ở mục 4.4 (kết quả kiểm tra tự động trên Phụ lục E và Phụ lục F):

- Cả 23 FR đều có ít nhất một test case loại + và một test case loại −.
- Cả 15 BR và 14 NFR đều có test case. Tỷ lệ phủ yêu cầu là 52/52 (100%), tỷ lệ phủ use-case là 18/18 (100%).
- Cả 11 phát hiện đều có đủ cặp test case tái hiện và hồi quy. Tỷ lệ phủ phát hiện là 11/11 (100%).
- Năm BR mức C đều có test case ở trạng thái "chờ xác nhận".

Không tính 11 test case hồi quy, 79 test case còn lại có thể chạy trên baseline. Dự đoán cho 79 test case này là 31 Đạt, 32 Không đạt, 8 Phụ thuộc cấu hình và 8 Chờ xác nhận. Trong 68 test case chức năng (loại + và −), 21 test case được dự đoán Không đạt. Ba test case trong số đó là trường hợp *hợp lệ*: TC-USER-06, TC-BOOK-11 và TC-MEMB-06. Nghĩa là ngay cả luồng sử dụng bình thường cũng có hành vi lệch đặc tả. Tám test case phụ thuộc cấu hình cho thấy trước khi thực thi, nhóm cần chốt cấu hình `sql_mode` và output buffering

của môi trường thử nghiệm. Nếu không, cùng một test case có thể cho kết quả khác nhau giữa hai lần chạy.

Câu trả lời cho RQ-B2: bộ test case thiết kế từ đặc tả suy ngược và phát hiện tĩnh đạt các tiêu chí phủ của MT-B3 và MT-B4. Cần lưu ý rằng tỷ lệ phủ ở đây đo *khả năng truy vết*, không đo *hiệu quả phát hiện lỗi*. Hiệu quả thực của bộ test case chỉ đánh giá được khi thực thi trong môi trường thử nghiệm.

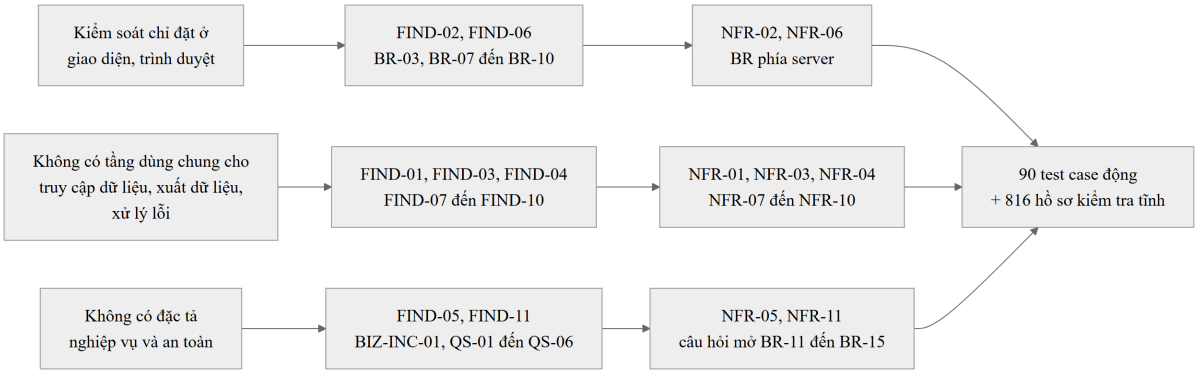
## 5.4 Phân tích tổng hợp (RQ-AB)

Đặt phát hiện tĩnh cạnh đặc tả cho thấy mỗi lỗ hổng tương ứng với một khoảng trống đặc tả: một yêu cầu an toàn chưa từng được viết ra, hoặc một quy tắc chỉ được hiện thực ở trình duyệt (Bảng 35). Nhìn tổng thể, các khoảng trống quy về ba nguyên nhân gốc (Hình 16).

***Bảng** 35. Liên hệ giữa phát hiện, khoảng trống đặc tả, yêu cầu bổ sung và test case*

| Phát hiện | Khoảng trống trong đặc tả, hành vi hiện có | Yêu cầu bổ sung | Test case |
|---|---|---|---|
| FIND-01 | FR-01 chỉ yêu cầu "có bản ghi khớp"; không có yêu cầu về cách so khớp mật khẩu | NFR-01, NFR-05 | TC-AUTH-01 đến TC-AUTH-03; TC-FIND01-R, TC-FIND01-H |
| FIND-02 | Kiểm soát truy cập chỉ có ở tầng trang (FR-03); không có yêu cầu nào cho handler | NFR-02 | TC-AUTH-05; TC-FIND02-R, TC-FIND02-H |
| FIND-03 | Không có đặc tả miền giá trị đầu vào; BR-07 đến BR-10 chỉ áp dụng ở client | NFR-03; Phụ lục D.2 | TC-BOOK-02 đến TC-BOOK-06; TC-FIND03-R, TC-FIND03-H |
| FIND-04 | Không có yêu cầu mã hóa đầu ra | NFR-04 | TC-FIND04-R, TC-FIND04-H |
| FIND-05 | Hành vi hiện có (FR-05, FR-07) chính là lỗ hổng: hiển thị và sửa mật khẩu bản rõ | NFR-05 | TC-USER-01; TC-FIND05-R, TC-FIND05-H |
| FIND-06 | Xác nhận xóa, trả sách chỉ là hộp thoại ở client (FR-08, FR-13, FR-19, FR-22) | NFR-06 | TC-USER-09, TC-BOOK-10; TC-FIND06-R, TC-FIND06-H |
| FIND-07 | BR-05 mô tả phiếu gồm nhiều bản ghi nhưng không yêu cầu tính nguyên tử | NFR-07 | TC-CIRC-01; TC-FIND07-R, TC-FIND07-H |
| FIND-08, FIND-09 | Ràng buộc triển khai cố định trong mã (Bảng 12) | NFR-08, NFR-09 | TC-FIND08-R/H, TC-FIND09-R/H |
| FIND-10 | Không có yêu cầu xử lý lỗi | NFR-10 | TC-FIND10-R, TC-FIND10-H |
| FIND-11 | Mã dư thừa, tham chiếu thiếu (mục 5.2) | NFR-11 | TC-BOOK-11; TC-FIND11-R, TC-FIND11-H |

| Phát hiện | Khoảng trống trong đặc tả, hành vi hiện có | Yêu cầu bổ sung | Test case |
|---|---|---|---|
| BIZ-INC-01 | BR-11 đến BR-15 mức C | Câu hỏi mở | TC-CIRC-07 đến TC-CIRC-09, TC-CIRC-15, TC-CIRC-16 |




***Hình** 16. Ba nguyên nhân gốc liên kết phát hiện, yêu cầu bổ sung và test case*

Nguyên nhân thứ nhất là kiểm soát chỉ đặt ở giao diện. Trang giao diện có kiểm tra phiên nhưng handler thì không (FIND-02). Thao tác xóa có hộp thoại xác nhận nhưng server không xác nhận lại (FIND-06). Năm trong mười quy tắc nghiệp vụ có trong mã chỉ do trình duyệt kiểm tra. Nguyên nhân thứ hai là mỗi trang tự mở kết nối, tự ghép SQL, tự in dữ liệu và tự in lỗi. Vì vậy 54 điểm gọi truy vấn và 52 điểm in lỗi phân tán trong 37 tệp, và cùng một lỗi lặp lại ở mọi nơi. Nguyên nhân thứ ba là thiếu đặc tả. Không có yêu cầu an toàn nào được viết ra nên hành vi thiếu an toàn được hiện thực như chức năng bình thường (FR-05). Quy tắc nghiệp vụ không rõ ràng thì không thể kiểm thử hay phán định.

Câu trả lời cho RQ-AB: lỗ hổng và khoảng trống đặc tả là hai mặt của cùng một vấn đề. Mỗi phát hiện ứng với một yêu cầu an toàn chưa từng được viết ra (NFR-01 đến NFR-11), với một quy tắc chỉ áp dụng ở client, hoặc với một hành vi hiện có vốn đã thiếu an toàn (FR-05, FR-07). Hệ thống gốc cũng không có test case nào, nên kể cả khi được sửa, các lỗ hổng này không có cơ chế phát hiện hồi quy. Từ liên hệ đó, nhóm đề xuất lộ trình khắc phục bốn đợt (Bảng 36). Mỗi đợt kết thúc bằng việc chạy lại lint, Semgrep (cùng snapshot rule) và PHPStan, rồi chạy các test case hồi quy tương ứng.

***Bảng** 36. Lộ trình khắc phục đề xuất và test case kiểm chứng*

| Đợt | Phát hiện | Nội dung sửa chính | Kiểm chứng sau sửa |
|---|---|---|---|
| 1 | FIND-01, FIND-02 | Truy vấn tham số và xác minh mật khẩu băm ở đăng nhập; đổi ID phiên sau đăng nhập; guard phiên tập trung trước 12 handler | TC-FIND01-H, TC-FIND02-H; TC-AUTH-01 đến TC-AUTH-10 |

| Đợt | Phát hiện | Nội dung sửa chính | Kiểm chứng sau sửa |
|---|---|---|---|
| 2 | FIND-03, FIND-09, FIND-04, FIND-05, FIND-06 | Chuyển 54 điểm gọi sang PDO hoặc MySQLi với prepared statement, một lần sửa giải quyết cả FIND-03 và FIND-09; mã hóa đầu ra theo ngữ cảnh; băm mật khẩu và di chuyển dữ liệu; POST kèm token anti-CSRF | TC-FIND03-H, TC-FIND04-H, TC-FIND05-H, TC-FIND06-H, TC-FIND09-H; toàn bộ test case chức năng |
| 3 | FIND-07, FIND-08, FIND-10 | Chuyển hai bảng mượn sang InnoDB, dùng giao dịch và ID theo kết nối; cấu hình kết nối ngoài mã, tài khoản quyền tối thiểu; xử lý lỗi tập trung và ghi log | TC-FIND07-H, TC-FIND08-H, TC-FIND10-H; TC-CIRC-01 đến TC-CIRC-14 |
| 4 | FIND-11, BIZ-INC-01, QS-01 đến QS-06 | Dọn mã dư thừa; xác nhận BR-11 đến BR-15 rồi hiện thực ở server; sửa các quan sát chức năng | TC-FIND11-H; các test case "chờ xác nhận"; TC-MEMB-06, TC-SRCH-02, TC-USER-06 |

## 5.5 Kiểm thử tĩnh cấp phát bộ nhớ

Mục này đáp ứng yêu cầu về bộ nhớ: xác định các trạng thái của vùng nhớ được cấp phát, mô tả cách từng mệnh đề (statement) làm chuyển trạng thái, xây dựng test case cùng test code, rồi chạy công cụ và phân loại các lỗi bộ nhớ ghi nhận được theo CWE/CVE. Phương pháp vẫn là kiểm thử tĩnh: nhóm chạy bộ phân tích của mình trên mã nguồn (chuỗi token do `php` tách ra và văn bản C); Semgrep, Clang và GCC chỉ chạy bộ phân tích, không liên kết thành chương trình. Không khởi chạy ứng dụng, không import CSDL, không gửi HTTP và không thực thi hàm PHP hay chương trình C nào.

### *5.5.1* Phạm vi và các trạng thái

Phân tích gồm hai mạch. Mạch A làm trên mã PHP thật: 66 tệp baseline, 10 tệp mã sinh theo chức năng, 108 tệp wrapper SQL và 4 cặp case bộ nhớ mới trong `generated_cases/memory`. Baseline dùng các hàm `mysql_*` của PHP 5.6; mã sinh dùng PDO của PHP 8. Mạch B làm trên 5 cặp mã C trong `generated_cases/memory_c`, viết lại năm chức năng authentication, authorization, database_query, token_crypto và script_output. Trong PHP, `malloc` và `free` nằm bên trong engine nên mã ứng dụng không thấy được; mạch B cho thấy cùng các chức năng ấy khi viết bằng ngôn ngữ phải tự quản lý bộ nhớ.

Mỗi giá trị được theo dõi (result set, kết nối, statement PDO, mảng dòng, chuỗi bí mật) là một đối tượng có trạng thái riêng, theo ý tưởng typestate [30]. Bảng 37 liệt kê 13 trạng thái. Với mã C, `malloc` thành công tương ứng ALLOCATED, `malloc` trả NULL tương ứng FALSE và `free` tương ứng RELEASED.

***Bảng** 37. Các trạng thái của đối tượng bộ nhớ*

| Mã | Trạng thái | Ý nghĩa |
|---|---|---|
| P0 | UNDEF | Biến chưa được gán |
| P1 | PENDING | Vừa gọi hàm cấp phát, chưa kiểm tra; giá trị có thể là FALSE |
| P2 | FALSE | Cấp phát thất bại (chỉ có trong mô hình cụ thể dùng cho Z3) |
| P3 | ALLOCATED | Resource hoặc bộ đệm hợp lệ, refcount ≥ 1 |
| P4 | ROW_PENDING | Mảng dòng vừa fetch, chưa kiểm tra; là FALSE khi hết dòng |
| P5 | ROW | Dòng hợp lệ đã được kiểm tra |
| P6 | NOROW | Fetch trả FALSE (chỉ có trong mô hình cụ thể dùng cho Z3) |
| P7 | SECRET | Mật khẩu hoặc khóa dạng rõ đang nằm trong heap |
| P8 | WIPED | Đã được ghi đè 0 bằng `sodium_memzero` |
| P9 | RELEASED | refcount về 0, hoặc đã free, close, unset |
| P10 | ESCAPED | Được trả về nơi gọi; quyền sở hữu chuyển ra ngoài |
| P11 | HELD_TO_END | Còn được giữ tới hết request; engine dọn khi shutdown |
| P12 | DONE | Nhánh lỗi đã thoát (`die`, `exit` hoặc ngoại lệ) |

### *5.5.2* Cấp phát bộ nhớ và chuyển trạng thái qua mệnh đề

Bộ phân tích mô hình hóa các quy tắc sau của PHP:

- Giá trị PHP là zval có đếm tham chiếu. Phép gán `$a = $b` dùng chung một zval và tăng refcount.
- Ghi đè, `unset`, gán `null` hay ra khỏi hàm làm giảm refcount; khi refcount về 0 thì vùng nhớ được giải phóng. Phép gán dựng giá trị vế phải trước rồi mới bỏ giá trị cũ.
- `mysql_query` không có LIMIT đệm toàn bộ kết quả trong bộ nhớ tiến trình. Với driver mysqlnd, phần đệm này được tính vào `memory_limit` [31].
- `sodium_memzero` chỉ ghi 0 khi chuỗi có refcount = 1, sau đó luôn đặt biến thành null [32]. Vì vậy `$p = $_POST['password']; sodium_memzero($p);` không xóa được mật khẩu, do `$_POST` vẫn giữ tham chiếu thứ hai; phải `unset($_POST['password'])` trước.

Bảng 38 cho biết mỗi loại mệnh đề sinh ra sự kiện nào. Bảng chuyển trạng thái có 36 dòng dạng (trạng thái, sự kiện) → (trạng thái mới, vi phạm); Hình 17 vẽ các chuyển chính, còn bảng đầy đủ nằm ở sheet BoNhoTrangThai của tệp Excel [18].

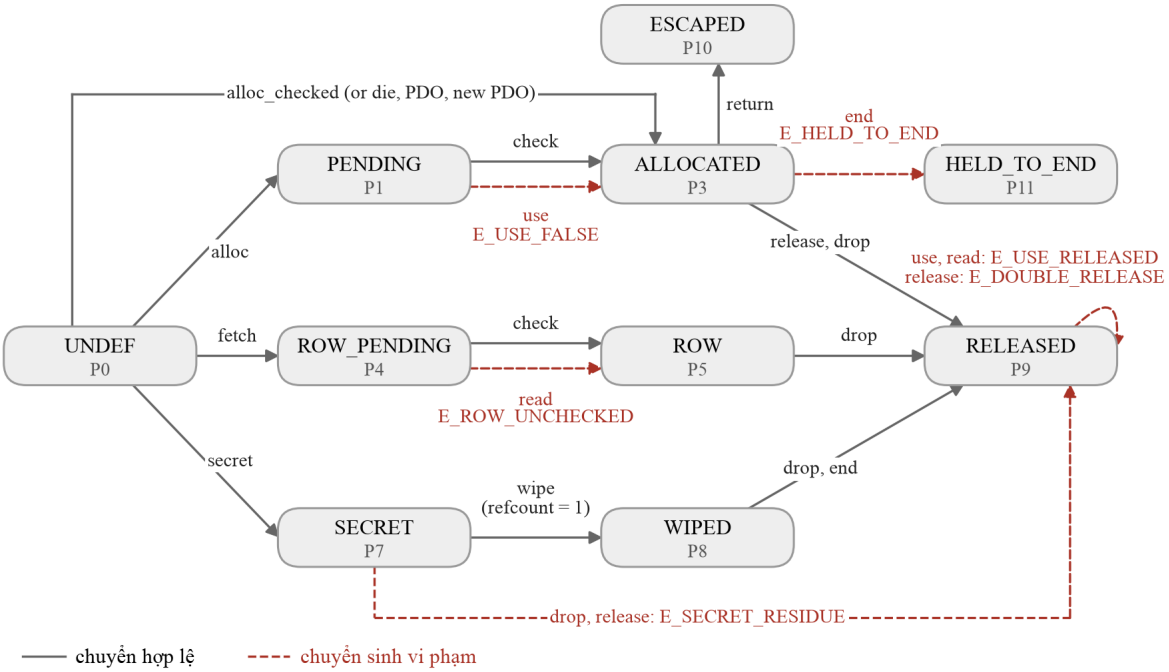
***Bảng** 38. Mệnh đề PHP và sự kiện chuyển trạng thái*

| Mệnh đề PHP | Sự kiện |
|---|---|
| `$r = mysql_query(...)` | alloc (→ PENDING) |
| `... or die(...)`, PDO với `ERRMODE_EXCEPTION`, `new PDO` | alloc_checked (→ ALLOCATED) |

| Mệnh đề PHP | Sự kiện |
|---|---|
| `mysql_num_rows($r)`, `mysql_fetch_*($r)`, `$stmt->execute()` | use trên `$r` |
| `$row = mysql_fetch_array($r)`, `$stmt->fetch()` | fetch (→ ROW_PENDING) |
| `if ($row)`, `is_array($row)`, `$n > 0` với `$n = mysql_num_rows($r)` | check |
| `$row['x']` | read |
| `mysql_free_result`, `mysql_close`, `unset` khi refcount = 1 | release |
| Ghi đè, gán `null`, } cuối hàm | drop khi refcount về 0 |
| `$b = $a` | share (refcount + 1) |
| `return $r` | return (→ ESCAPED) |
| `$p = $_POST['password']`, `base64_decode(getenv(...))`, chuỗi nội suy chứa bí mật | secret |
| `sodium_memzero($p)` khi refcount = 1 | wipe |
| Hết tệp | end |

Các dòng sinh vi phạm trong bảng chuyển trạng thái là:

- PENDING + use → **E_USE_FALSE**: dùng kết quả chưa kiểm tra, có thể là FALSE;
- ROW_PENDING + read → **E_ROW_UNCHECKED**: đọc dòng chưa kiểm tra;
- RELEASED + use hoặc read → **E_USE_RELEASED**; RELEASED + release → **E_DOUBLE_RELEASE**;
- SECRET + drop, release hoặc end → **E_SECRET_RESIDUE**: bí mật bị bỏ lại trong heap mà chưa xóa;
- PENDING hoặc ALLOCATED + end → **E_HELD_TO_END**, chỉ áp dụng cho resource.




***Hình** 17. Các chuyển trạng thái chính của đối tượng bộ nhớ; FALSE, NOROW và DONE chỉ có trong mô hình cụ thể dùng cho Z3*

Hai vi phạm khác gắn trực tiếp vào mệnh đề cấp phát. **E_UNBOUNDED_ALLOC** xảy ra khi câu SELECT không có cận số dòng. Cận được suy ra từ schema `eb_lms.sql`: hàm gộp cho 1 dòng, so bằng trên khóa chính cho 1 dòng, `LIMIT n` cho n dòng. **E_ALLOC_IN_LOOP** xảy ra khi lệnh cấp phát nằm trong vòng lặp. Vòng lặp được trải 2 lần. Tổng cộng bộ phân tích ghi 1.127 bước chuyển, trong đó 710 bước thuộc baseline. Bảng 39 là vết chuyển trạng thái của `login.php` trong baseline.

***Bảng** 39. Vết chuyển trạng thái của login.php trong baseline*

| Dòng | Mệnh đề | Đối tượng | Chuyển trạng thái |
|---|---|---|---|
| 5 | `$password = $_POST['password']` | `$password` | UNDEF → SECRET (dùng chung chuỗi với `$_POST`) |
| 6 | `$query = "... password='$password'"` | `$query` | UNDEF → SECRET (bản sao) |
| 7 | `$result = mysql_query($query) or die(...)` | `$result` | UNDEF → ALLOCATED |
| 9 | `$row = mysql_fetch_array($result)` | `$row` | UNDEF → ROW_PENDING |
| 10 | `if ($num_row > 0)` | `$row` | ROW_PENDING → ROW |
| Hết | Kết thúc request | `$password`, `$query` | SECRET → HELD_TO_END, **E_SECRET_RESIDUE** |
| Hết | Kết thúc request | `$result` | ALLOCATED → HELD_TO_END, **E_HELD_TO_END** |

Trong case sửa `memory/_v1/login_secret.php`, dòng 8 `unset($_POST['password'])` đưa refcount của mật khẩu về 1; dòng 12 `$stmt = null` chuyển statement từ ALLOCATED sang RELEASED; dòng 14 `sodium_memzero($password)` chuyển SECRET sang WIPED, rồi RELEASED khi ra khỏi hàm. Truy vấn có `LIMIT 1` và dòng được kiểm tra bằng `is_array($row)`, nên tệp không còn vi phạm nào.

### *5.5.3* Test case và test code

Bảng 40 liệt kê các thành phần. Các case PHP và C theo cùng quy ước với phần mã sinh: tệp `_v0` tái tạo có chủ ý mẫu lỗi, tệp `_v1` là bản sửa.

***Bảng** 40. Thành phần test code và test case bộ nhớ*

| Thành phần | Tệp | Nội dung |
|---|---|---|
| Bộ phân tích | `models/memory_typestate.py`, `evidence/extract_memory_tokens.php` | Bảng chuyển trạng thái, suy cận SQL từ schema, duyệt từng mệnh đề |
| Unit test | `models/test_memory_typestate.py` | 19 test, đạt cả 19 |
| Case PHP | `generated_cases/memory/_v0`, `_v1` | 4 cặp: book_listing, latest_borrow, login_secret, token_key |
| Case C | `generated_cases/memory_c/_v0`, `_v1` | 5 cặp theo năm chức năng |
| Luật Semgrep | `evidence/memory_rules.yaml` | 7 luật PHP, 4 luật C |
| Chạy công cụ | `evidence/run_memory_static.py` | `php -l`, Semgrep, Clang `--analyze`, GCC 14 `-fanalyzer` (Docker, `--network none`) |
| Z3 | `models/run_memory_cases.py` | BMC theo đối tượng, ngân sách bộ nhớ, kích thước bộ đệm C |

Các đoạn PHP trong unit test chỉ được tách token, không được thực thi. Bộ test kiểm tra các nội dung sau:

- bảng chuyển trạng thái và mô hình cụ thể dùng cho Z3;
- suy cận SQL: LIMIT, khóa chính, hàm gộp và bảng không có trong schema;
- 12 đoạn mã mẫu: `or die`, kết quả chưa kiểm tra, truy vấn trong vòng lặp, dùng sau `mysql_free_result`, giải phóng hai lần, bí danh giữ refcount, `num_rows` làm điều kiện, dòng chưa kiểm tra, `return` chuyển quyền sở hữu, mật khẩu được xóa sau `unset`, `sodium_memzero` thiếu `unset` vẫn để lại dư lượng, tham số bí mật chỉ được mượn;
- kết quả kỳ vọng chính xác của 4 case `_v0`, 4 case `_v1` không còn vi phạm, và số liệu của baseline.

Z3 [22] được dùng theo ba cách:

- **BMC theo đối tượng** [33]. Dãy sự kiện của mỗi đối tượng được trải thành công thức; mỗi lần cấp phát hoặc fetch có một biến Bool `ok` cho biết thành công hay thất bại. Trên cả 250 đối tượng, tập vi phạm Z3 tìm được trùng với kết quả vét cạn mọi tổ hợp `ok` và với bộ phân tích trừu tượng. Baseline có 127 đối tượng, 68 SAT; case bộ nhớ `_v0` có 11 đối tượng SAT, còn cả 8 đối tượng `_v1` đều UNSAT. Ví dụ nhân chứng ở `latest_borrow.php` (`_v0`): fetch với `ok = false` cho NOROW, rồi đọc `$row['borrow_id']` gây E_ROW_UNCHECKED.
- **Ngân sách bộ nhớ.** Z3 tìm N nhỏ nhất sao cho N × độ rộng dòng vượt `memory_limit` 128 MiB. Truy vấn không cận cho SAT, ví dụ bảng `book` rộng 552 byte/dòng cần N = 243.149, phép JOIN ở `return.php` rộng 1.717 byte/dòng cần N = 78.170. Truy vấn có cận cho UNSAT. Baseline có 24 SAT, 14 UNSAT và 1 không xác định (`unstudents.php` dùng bảng không có trong schema); case `memory/_v1` cho 4/4 UNSAT.
- **Kích thước bộ đệm C** (Bảng 41). Mô hình `_v0` được ghim vào literal minh họa có trong mã nên SAT; mô hình `_v1` đúng với mọi đầu vào nên UNSAT. Các tệp SMT-LIB nằm ở `evidence/memory_formal/` (45 tệp).

***Bảng** 41. Mô hình kích thước bộ đệm C và nhân chứng của Z3*

| Mô hình | Vị trí `_v0` | Điều kiện lỗi | Nhân chứng `_v0` (SAT) | `_v1` |
|---|---|---|---|---|
| `auth_name_copy` | `authentication.c:12` | Chép tên đăng nhập vào `char name[32]` | 44 ký tự + NUL = 45 byte | UNSAT |
| `query_format` | `database_query.c:9` | `sprintf` câu SQL vào `malloc(64)` | id dài 48: 33 + 48 + 1 = 82 byte | UNSAT |
| `key_copy` | `token_crypto.c:10` | Chép len byte khóa vào `malloc(16)` | len = 33 | UNSAT |
| `tag_offset` | `token_crypto.c:17` | Đọc 16 byte từ `token + len - 16` | len = 5 (lệch âm) | UNSAT |
| `escape_size` | `script_output.c:12` | Escape `<`, `>` (+3 byte), `&` (+4 byte) vào bộ đệm n + 1 | n = 25, có 2 dấu `<` | UNSAT |

### *5.5.4* Kết quả chạy và ghi nhận lỗi bộ nhớ

Bảng 42 tổng hợp vi phạm do bộ phân tích trạng thái ghi nhận; 27 trong 66 tệp baseline có ít nhất một vi phạm.

***Bảng** 42. Vi phạm bộ nhớ theo nhóm mã*

| Vi phạm | CWE chính | Baseline | Chức năng `_v0`/`_v1` | SQL `_v0`/`_v1` | Bộ nhớ `_v0`/`_v1` |
|---|---|---|---|---|---|
| `E_HELD_TO_END` | CWE-772 | 38 | 0/0 | 0/0 | 0/0 |

| Vi phạm | CWE chính | Baseline | Chức năng _v0/_v1 | SQL _v0/_v1 | Bộ nhớ _v0/_v1 |
|---|---|---|---|---|---|
| E_UNBOUNDED_ALLOC | CWE-770 (+400) | 25 | 1/1 | 25/25 | 4/0 |
| E_ROW_UNCHECKED | CWE-252 | 13 | 0/0 | 0/0 | 4/0 |
| E_ALLOC_IN_LOOP | CWE-1050 | 11 | 0/0 | 0/0 | 2/0 |
| E_SECRET_RESIDUE | CWE-316 (+226) | 6 | 2/2 | 4/4 | 3/0 |
| E_USE_FALSE | CWE-252 (+690) | 3 | 1/0 | 0/0 | 1/0 |
| **Tổng** | | **96** | **4/3** | **29/29** | **14/0** |

Từ Bảng 42 rút ra ba nhận xét:

- Bản sửa của phần chức năng và phần SQL chặn được injection và lỗi xác thực nhưng không xử lý bộ nhớ: số E_UNBOUNDED_ALLOC và E_SECRET_RESIDUE ở `_v1` giữ nguyên như ở `_v0`.
- Ba E_USE_FALSE của baseline nằm ở `add_books.php:32`, `advance_search.php:66` và `books.php:62`, đều là truy vấn trong vòng lặp không có `or die`.
- Sáu E_SECRET_RESIDUE nằm ở `index.php`, `login.php`, `modal_add_user.php` và `modal_edit_user.php`.

Semgrep 1.176.1 [7] chạy 7 luật PHP và 4 luật C do nhóm viết để đối chiếu chéo (Bảng 43). Luật Semgrep không biết schema và refcount nên kết quả chỉ là ứng viên. Trên các case `_v1`, Semgrep có đúng một dương tính giả (`memory/_v1/login_secret.php:16`, dòng đã được bảo vệ bởi `$ok`) và bộ phân tích loại bỏ được nó. Semgrep cũng xác nhận truy vấn không cận ở `generated_cases/_v1/authentication.php:6`.

***Bảng** 43. Đối chiếu luật Semgrep với bộ phân tích trên baseline*

| Luật Semgrep | Số kết quả | Số liệu tương ứng của bộ phân tích |
|---|---|---|
| `select-without-limit` | 37 | 25 E_UNBOUNDED_ALLOC; số còn lại là truy vấn theo khóa chính hoặc hàm gộp |
| `row-unchecked` | 33 | 13 E_ROW_UNCHECKED, chỉ tính vị trí đọc đầu tiên chưa kiểm tra |
| `query-in-loop` | 12 | 11 E_ALLOC_IN_LOOP |
| `result-not-freed` | 39 | 38 E_HELD_TO_END |
| `query-result-unchecked` | 5 | 3 E_USE_FALSE |
| `password-not-wiped` | 4 | 6 E_SECRET_RESIDUE trên cùng 4 tệp; bộ phân tích tính cả bản sao trong chuỗi truy vấn |

Với mạch B, GCC 14.4 `-fanalyzer` [34] và Clang 21 `--analyze` [35] đều cho 0 kết quả trên cả năm tệp `_v1`. Bảng 44 là kết quả trên các tệp `_v0`. GCC kèm theo đường đi từng bước, ví dụ ở `authentication.c`: dòng 10 cấp phát, dòng 13 đi nhánh true, dòng 15 rò rỉ `secret`.

***Bảng** 44. Kết quả công cụ trên mã C trước sửa*

| Tệp `_v0` | GCC 14.4 `-fanalyzer` | Clang 21 `--analyze` | Semgrep C | Z3 |
|---|---|---|---|---|
| `authentication.c` | 11 CWE-690; 12 CWE-121; 15 CWE-401 | 15 rò rỉ (CWE-401) | `strcpy` ×2, `malloc` chưa kiểm tra, `free` bí mật chưa xóa | SAT |
| `authorization.c` | 10, 20 CWE-690; 26 CWE-401 | 20 dùng sau khi giải phóng (CWE-416) | `malloc`, `strdup` chưa kiểm tra | — |
| `database_query.c` | 9, 19 CWE-690; 21 CWE-401; 29 CWE-415 và `-Wuse-after-free` | 29 giải phóng hai lần (CWE-415) | `sprintf`, `realloc` tự gán, 4 cấp phát chưa kiểm tra | SAT |
| `script_output.c` | 12, 15, 18 CWE-457 | 12 giá trị rác (CWE-457) | `malloc` chưa kiểm tra | SAT |
| `token_crypto.c` | 10 CWE-690; 17 CWE-127 | Không phát hiện | `malloc` chưa kiểm tra, `free` bí mật chưa xóa | SAT ×2 |

Ba lớp công cụ bổ sung cho nhau. Clang không phát hiện lỗi nào ở `token_crypto.c`. GCC không báo bí mật bị giải phóng khi chưa xóa (CWE-244), còn Semgrep bắt được. Tràn bộ đệm ở `escape_html_v0` không được trình biên dịch nào báo là ghi ngoài biên, vì biến `j` chưa khởi tạo che mất lỗi; mô hình Z3 chứng minh được lỗi này.

### *5.5.5* Phân loại theo CWE và CVE

CWE được tra trên API của MITRE ngày 21/10/2026 [2]. MITRE đánh dấu CWE-690 và CWE-400 là "Discouraged" khi ánh xạ lỗ hổng, nên nhóm dùng CWE-252 và CWE-770 làm CWE chính và chỉ ghi hai CWE kia kèm theo. CVE được tra trên NVD [36]. Mỗi CVE trong Bảng 45 chỉ là ví dụ cùng lớp CWE trên sản phẩm khác; không có CVE nào được gán cho mã của thư viện này.

***Bảng** 45. Phân loại lỗi bộ nhớ theo CWE và CVE tham chiếu*

| Lớp lỗi | CWE | Ghi nhận | CVE tham chiếu (NVD) |
|---|---|---|---|
| Cấp phát không cận | CWE-770 (+CWE-400) | PHP: 25 baseline, 4 case `_v0` | CVE-2023-0662: PHP 8.0–8.2, multipart quá nhiều phần gây DoS (CWE-400, CVSS 7.5) |
| Chép không kiểm tra độ dài | CWE-120; CWE-121, 122, 787 | C: 4 tệp (GCC, Z3, Semgrep) | CVE-2022-31626: PHP pdo_mysql/mysqlnd, mật khẩu kết nối quá dài gây tràn bộ đệm (CWE-120, 7.5) |

| Lớp lỗi | CWE | Ghi nhận | CVE tham chiếu (NVD) |
|---|---|---|---|
| Dùng sau khi giải phóng | CWE-416 (PHP: CWE-672) | C: `authorization.c` (Clang); PHP: chỉ trong unit test | CVE-2016-5773: PHP 5.6 ext/zip, dùng sau khi giải phóng qua unserialize (CWE-416, 9.8) |
| Giải phóng hai lần | CWE-415 (PHP: CWE-675) | C: `database_query.c` (GCC, Clang); PHP: chỉ trong unit test | CVE-2023-25136: OpenSSH 9.1 (CWE-415, 6.5) |
| Đọc ngoài biên; bí mật còn trong bộ nhớ | CWE-125, 127; CWE-316, 226, 244 | C: `token_crypto.c`; PHP: 6 baseline, 3 case `_v0` | CVE-2014-0160 (Heartbleed): OpenSSL đọc ngoài biên làm lộ khóa trong heap (CWE-125, 7.5) |
| Không giải phóng | CWE-772, CWE-401 | PHP: 38 baseline; C: 3 tệp (GCC) | — |
| Không kiểm tra giá trị trả về | CWE-252 (+CWE-690, 476) | PHP: 16 baseline, 5 case `_v0`; C: 4 tệp (GCC) | — |
| Biến chưa khởi tạo | CWE-457 | C: `script_output.c` (GCC, Clang) | — |
| Cấp phát trong vòng lặp | CWE-1050 | PHP: 11 baseline, 2 case `_v0` | — |

# 6. Thảo luận và hạn chế

## 6.1 Ưu, nhược điểm của phương pháp kết hợp thủ công và tự động

Bảng 46 tổng hợp điểm mạnh và điểm yếu của từng thành phần, chỉ dựa trên những gì quan sát được trong đồ án.

***Bảng** 46. Ưu, nhược điểm quan sát được của từng thành phần phương pháp*

| Thành phần | Ưu điểm quan sát được | Nhược điểm quan sát được |
|---|---|---|
| Rule registry theo luồng nhiễm bẩn | Quét đủ 66 tệp; kết quả tất định (322/322 chữ ký trùng); `tainted-sql-string` khớp đúng 26 điểm gọi có dữ liệu không tin cậy, không báo truy vấn hằng | Không phát hiện lỗi thiếu kiểm soát và lỗi logic (FIND-02, FIND-05, FIND-06, FIND-07); `echoed-request` bỏ sót các trang danh sách chỉ đọc CSDL |
| Rule tùy biến | Nhắm đúng mẫu đặc thù của mã cũ; đóng góp 254/322 hit và là nguồn tự động duy nhất cho FIND-08, FIND-09, FIND-10 | Rule viết rộng gây nhiễu (19 truy vấn hằng); một lỗi cú pháp trong tệp rule làm mất 52 hit mà số hit tổng không cho thấy |
| PHPStan và lint | Phát hiện 3 include thiếu; xác nhận 66/66 tệp hợp lệ cú pháp | Cần stub; không phát hiện SQLi, XSS trong mã thủ tục; 14/17 thông báo chỉ là định dạng; lint hợp lệ nhưng không chứng minh hàm tồn tại |
| Rà soát thủ công theo checklist | Hiểu ngữ cảnh; tìm ra 4 phát hiện mà công cụ bỏ sót, trong đó có một phát hiện Critical; tách được "không đạt" khỏi "thiếu đặc tả" | Tốn công, phụ thuộc người rà soát; hồ sơ cũ có số dòng lệch so với mã (dòng xuất mật khẩu ở `modal_edit_user.php` là 15, hồ sơ cũ ghi 18) và kết luận quá rộng (25 tiêu chí, 8 handler) đã phải hiệu chỉnh |
| Kiểm kê từng điểm gọi SQL | Biến một rule nhiễu thành phân loại chính xác cho 54 điểm gọi và 92 tham số; tạo nền cho đặc tả dữ liệu và kỹ thuật BVA | Phải làm thủ công cho từng sink; chỉ áp dụng cho truy vấn, chưa áp dụng cho điểm xuất HTML |
| Kiểm chứng hình thức | Làm rõ điều kiện bảo vệ mà bản sửa phải đạt; ba bộ giải đối chiếu lẫn nhau | Phép dịch từ PHP sang mô hình làm thủ công; kết quả nói về mã minh họa, không về baseline |

Từ bảng trên có thể rút ra ba nhận xét. Thứ nhất, công cụ và người rà soát bổ sung cho nhau theo *loại lỗi*, không theo *số lượng lỗi*. Công cụ mạnh với lỗi có mẫu mã cụ thể như ghép chuỗi SQL, gọi API cũ hay in lỗi. Người rà soát mạnh với lỗi *vắng mặt* như thiếu guard, thiếu token hay thiếu giao dịch. Kết quả thực nghiệm này xác nhận giới hạn cố hữu của SAST đã nêu ở mục 2.2: khi biện pháp kiểm soát vắng mặt thì không có đoạn mã nào để công cụ so khớp. Thứ hai, giá trị lớn nhất của công cụ trong đồ án là tạo *danh mục đầy đủ và tái lập được* (54 điểm gọi, 52 điểm in lỗi) để người rà soát không bỏ sót vị trí, chứ không phải tự đưa ra kết luận. Thứ ba, đọc output công cụ đòi hỏi kỷ luật: lần quét lịch sử

có số hit hợp lý nhưng thực chất thiếu cả một nhóm rule. Chỉ nhờ đọc mã thoát và trường `errors` mà nhóm phát hiện ra điều này.

Hướng đặc tả suy ngược và thiết kế test case truy vết được cũng có ưu, nhược điểm riêng. Ưu điểm là bộ hồ sơ dùng được ngay cho giai đoạn sửa lỗi. Mỗi phát hiện có sẵn test case hồi quy, mỗi quy tắc chưa rõ có sẵn câu hỏi mở. Nguyên tắc hai lớp giúp lỗ hổng không bị chép thành yêu cầu. Nhược điểm là đặc tả chỉ phản ánh mã. Nếu mã sai so với ý đồ thiết kế mà không vi phạm chuẩn an toàn nào, như QS-01 hay QS-02, thì chỉ việc đối chiếu chéo giữa các luồng mới làm lộ ra sai lệch. Tỷ lệ phủ 100% cũng chỉ chứng tỏ mọi yêu cầu đều có test case, chưa chứng tỏ test case đủ mạnh.

## 6.2 Hạn chế

- **Không thực thi.** Tác động của mọi phát hiện chỉ được nêu có điều kiện. Tám test case phụ thuộc cấu hình chưa biết (`sql_mode`, output buffering, `php.ini`). Năm tiêu chí checklist chưa đủ căn cứ để kết luận (Bảng 24); ba trong số đó (AUTH-05, ERR-02, AC-04) cần thêm cấu hình máy chủ hoặc chính sách.
- **Test case chưa thực thi.** Cột "Dự đoán trên baseline" là suy luận từ việc đọc mã. Dự đoán có thể sai, nhất là ở các luồng phụ thuộc trình duyệt và JavaScript.
- **Đặc tả là suy ngược.** Năm quy tắc nghiệp vụ ở mức C. Mức tin cậy do nhóm tự gán, chưa được chủ sở hữu sản phẩm xác nhận.
- **Không có số liệu độ chính xác toàn tập.** Chỉ rule CWE-89 tùy biến được thẩm định đủ 54/54 hit. Các rule khác được gộp theo nguyên nhân, không thẩm định từng hit, nên không tính được precision và recall cho 322 cảnh báo. Phân bố theo vị trí của hai rule registry được đọc từ output lưu vị trí của lần quét lịch sử, vốn có cùng số hit với hai lần quét hợp lệ.
- **Mức ưu tiên định tính.** Thang Critical đến Low không phải CVSS. Hồ sơ cũng không có dữ liệu đánh giá chéo giữa hai người rà soát độc lập.
- **Kiểm chứng hình thức có phạm vi hẹp.** Mô hình được dịch thủ công. Mã `_v1` chưa tích hợp vào baseline. Mô hình token là thí nghiệm riêng vì baseline không có token ứng dụng.
- **Mô hình bộ nhớ là trừu tượng.** Bộ phân tích không phân biệt đường đi, chỉ trải vòng lặp 2 lần và không nối `include` giữa các tệp. Độ rộng dòng lấy theo khai báo cột, không tính overhead của zval và HashTable, nên N chỉ là ước lượng. Ngân sách giả định driver mysqlnd; với libmysqlclient, bộ đệm kết quả nằm ngoài `memory_limit` [31]. E_HELD_TO_END có mức thấp vì PHP luôn dọn resource khi request kết thúc. Mô hình C dùng số nguyên toán học, không mô hình tràn `size_t`; mã `_v1` sạch chỉ có nghĩa là không còn lỗi thuộc các lớp đã mô hình hóa.

- **Phạm vi.** Chỉ khảo sát `librarian/`. Hai mươi lăm tệp của cổng độc giả, bản sao `library/` và thư viện `vendors/` nằm ngoài phạm vi.
- **Hồ sơ dự án chưa đủ.** Hồ sơ không lưu ngày bắt đầu của từng gói công việc.

## 6.3 Mối đe dọa đến tính hợp lệ

Bảng 47 phân tích các mối đe dọa đến tính hợp lệ theo bốn nhóm của Wohlin và cộng sự [26].

***Bảng** 47. Mối đe dọa đến tính hợp lệ và biện pháp giảm thiểu*

| Nhóm | Mối đe dọa | Biện pháp giảm thiểu | Rủi ro còn lại |
|---|---|---|---|
| Nội tại | Kết luận phụ thuộc người đọc mã; sai số dòng; cấu hình công cụ lỗi làm thiếu cảnh báo | Đối chiếu mọi số dòng với baseline; hai lần kiểm kê token độc lập; đọc mã thoát cùng trường `errors`; thang kết luận có định nghĩa | Không có người rà soát độc lập thứ hai |
| Cấu trúc | Đếm cảnh báo bị hiểu là đếm lỗ hổng; UNSAT bị hiểu là "an toàn"; tỷ lệ phủ bị hiểu là hiệu quả kiểm thử | Gộp theo nguyên nhân gốc; nêu giới hạn của mô hình ở mỗi kết quả; tách bộ kiểm tra tĩnh khỏi bộ test case động | Mức ưu tiên vẫn là đánh giá định tính |
| Ngoại tại | Một hệ thống PHP 5 thủ tục, không framework | Mô tả rõ đặc điểm của mã (mục 3.1) và giới hạn khái quát hóa | Nhận xét về hiệu quả công cụ chưa chắc đúng với mã hướng đối tượng hay mã dùng framework |
| Độ tin cậy kết luận | Kết quả phụ thuộc phiên bản công cụ và registry rule thay đổi theo thời gian | Đóng băng snapshot rule; ghi mã băm tệp rule, phiên bản và lệnh chạy; quét hai lần | Phiên bản Semgrep mới có thể cho kết quả khác |

## 6.4 Hướng phát triển

1. **Thực thi bộ 90 test case** trong môi trường cô lập: container PHP 5.6 với MySQL 5.7, dữ liệu tổng hợp, chốt trước `sql_mode` và output buffering. So sánh kết quả thực tế với cột dự đoán để đo độ chính xác của chính phân tích tĩnh.
2. **Khắc phục theo lộ trình bốn đợt** ở Bảng 36, dùng mã `_v1` làm điểm xuất phát. Sau mỗi đợt, chạy lại công cụ với cùng snapshot rule và chạy test case hồi quy.
3. **Đưa phân tích tĩnh vào quy trình tích hợp liên tục (CI):** chạy Semgrep với snapshot rule cố định và PHPStan cho mỗi thay đổi; chặn khi xuất hiện hit mới của rule mức ERROR. Bổ sung rule cho hai loại lỗi công cụ đã bỏ sót: tệp có thao tác ghi CSDL mà không có guard phiên, và luồng nhiễm bẩn có nguồn là kết quả truy vấn CSDL (Stored XSS).

4. **Xác nhận các câu hỏi mở** của BIZ-INC-01 và mục 5.2 với chủ sở hữu sản phẩm. Sau đó nâng các BR mức C thành yêu cầu chính thức và hoàn thiện kết quả mong đợi của tám test case "chờ xác nhận".
5. **Mở rộng phạm vi** sang cổng độc giả, và mời người rà soát thứ hai đánh giá độc lập checklist để đo mức đồng thuận.
6. **Kiểm thử động bổ sung** theo OWASP WSTG [5] trên môi trường thử, sau khi các phát hiện Critical đã được sửa.

## 6.5 Tác động xã hội, đạo đức và làm việc chuyên nghiệp

**Tác động xã hội.** Hệ thống quản lý thư viện ở trường học lưu họ tên, giới tính, địa chỉ, số điện thoại và lịch sử mượn sách của học sinh, giáo viên. Các lỗ hổng như FIND-01, FIND-02 và FIND-05 có thể làm lộ hoặc làm sai lệch những dữ liệu này, ảnh hưởng trực tiếp tới quyền riêng tư của người dùng. Mã nguồn mở dạng này thường được dùng lại làm điểm xuất phát cho bài tập và đồ án. Vì vậy, chỉ ra các mẫu lỗi phổ biến kèm hướng sửa và test case hồi quy có giá trị giáo dục vượt ra ngoài một hệ thống cụ thể.

**Đạo đức.** Đồ án tuân theo các nguyên tắc tránh gây hại, trung thực và tôn trọng quyền riêng tư của Bộ quy tắc đạo đức ACM (mục 1.2, 1.3, 1.6), cùng yêu cầu đánh giá rủi ro đầy đủ và thiết kế hệ thống an toàn (mục 2.5, 2.9) [27]. Cụ thể, nhóm không chạy ứng dụng và không thử khai thác. Dữ liệu kiểm thử chỉ ở mức thăm dò. Báo cáo không công bố mã khai thác hoàn chỉnh. Dữ liệu mẫu và ảnh chụp chứa dữ liệu cá nhân không được tái hiện. Mã upstream được dùng theo giấy phép MIT và ghi nguồn đầy đủ. Nếu thông báo kết quả cho tác giả upstream, nội dung chỉ nên gồm nguyên nhân và hướng sửa, gửi qua kênh do kho mã cung cấp.

**Làm việc chuyên nghiệp.** Số liệu được báo cáo trung thực, kể cả các số liệu cũ đã bị thay thế (270 và 322 hit, 25 và 27 tiêu chí, 8 và 12 handler), kèm giải thích chênh lệch. Báo cáo tách rõ cảnh báo khỏi phát hiện, tách dự đoán khỏi kết quả thực thi, và tách lỗi khỏi điểm thiếu đặc tả. Mọi kết luận đều truy về được bằng chứng. Về việc dùng công cụ AI, công cụ AI tạo sinh (Codex ở giai đoạn phân tích; Claude ở giai đoạn biên soạn báo cáo này) đã hỗ trợ đọc mã, sinh mã minh họa và mô hình, tổng hợp bằng chứng, soạn thảo và định dạng. Mọi số liệu đều được đối chiếu với output thực của công cụ, với mã nguồn hoặc với tệp Excel. Nhóm chịu trách nhiệm về toàn bộ nội dung báo cáo.

# 7. Kết luận, tài liệu tham khảo và phụ lục

## 7.1 Kết luận

Đồ án đã đánh giá an toàn mã nguồn phân hệ thủ thư của hệ thống Library-Management-System bằng kiểm thử tĩnh có bằng chứng truy vết. Trên cơ sở đó, nhóm xây dựng đặc tả suy ngược và bộ test case truy vết được, phục vụ giai đoạn sửa lỗi và kiểm thử hồi quy. Toàn bộ công việc được thực hiện mà không chạy ứng dụng. Cả chín mục tiêu cụ thể ở Bảng 2 đều đạt tiêu chí hoàn thành (Bảng 48).

***Bảng** 48. Kết quả theo mục tiêu cụ thể*

| Mã | Kết quả đạt được | Mục | Trạng thái |
|---|---|---|---|
| MT-A1 | Kiểm kê đủ 66 tệp PHP (2.978 dòng, 2.551 SLOC); 66/66 mã băm trùng trước và sau nghiên cứu | 3.1, 5.1.5 | Đạt |
| MT-A2 | 27/27 tiêu chí có kết luận kèm bằng chứng hoặc lý do: 14 Không đạt, 2 Thiếu cơ chế hoặc Một phần, 1 Đạt, 1 Không áp dụng, 4 Thiếu đặc tả, 5 cần thẩm định thêm | 5.1.1, Phụ lục A | Đạt |
| MT-A3 | Lưu đủ phiên bản, lệnh, mã thoát, lỗi công cụ và output thô của Semgrep, PHPStan, lint | 4.2.2, Phụ lục C | Đạt |
| MT-A4 | 11 phát hiện, mỗi phát hiện có trạng thái, CWE, mức, vị trí và hướng sửa: 2 Critical, 4 High, 3 Medium, 2 Low | 5.1.4, Phụ lục B | Đạt |
| MT-A5 | Hai lần quét cho 322/322 chữ ký trùng; độ lệch 0; giải thích được chênh lệch với lần quét lịch sử | 5.1.5 | Đạt |
| MT-B1 | 23 FR, 15 BR, 14 NFR, mỗi yêu cầu có ID, nguồn trong mã và mức tin cậy (34 R, 13 S, 5 C) | 3.2, 5.2 | Đạt |
| MT-B2 | 18 use-case, mô hình use-case kèm misuse case, mô hình miền dữ liệu, 4 biểu đồ tuần tự, 9 nhóm màn hình | 3.4 | Đạt |
| MT-B3 | 90 test case động; mỗi FR có test case + và −; mỗi phát hiện có test case R và H; trạng thái "Chưa thực thi" | 4.4, 5.3, Phụ lục E | Đạt (mức thiết kế) |
| MT-B4 | Ma trận hai chiều; tỷ lệ phủ yêu cầu 52/52, phủ use-case 18/18, phủ phát hiện 11/11 | 5.3, Phụ lục F | Đạt |

Câu trả lời cho sáu câu hỏi nghiên cứu được tóm tắt như sau:

- **RQ-A1.** Phân hệ có 10 điểm yếu an toàn xác nhận được bằng phân tích tĩnh cùng 1 lỗi chất lượng. Hai điểm yếu Critical nằm ở ranh giới xác thực: SQL Injection ở form đăng nhập (CWE-89) và 12 handler ghi dữ liệu không kiểm tra phiên (CWE-306).
- **RQ-A2.** 322 cảnh báo thô được gộp thành 11 phát hiện, chủ yếu nhờ gộp theo nguyên nhân gốc. Cảnh báo giả tập trung ở rule viết rộng, ví dụ 19/54 hit của rule CWE-89 tùy biến rơi vào truy vấn hằng. Bốn phát hiện thuộc loại thiếu kiểm soát

hoặc lỗi logic (FIND-02, FIND-05, FIND-06, FIND-07) chỉ rà soát thủ công mới tìm ra.

- **RQ-A3.** Kết quả tái lập hoàn toàn khi cố định baseline, phiên bản công cụ và snapshot rule. Một lần chạy chỉ được coi là hợp lệ khi mã thoát bằng 0 và trường `errors` rỗng.
- **RQ-B1.** Yêu cầu chức năng suy ngược được với độ tin cậy cao (22/23 FR mức R). Chỉ 4 trong 10 quy tắc nghiệp vụ có trong mã được áp dụng ở server. Quy tắc mượn – trả, mô hình vai trò và chính sách dữ liệu không thể đặc tả nếu thiếu xác nhận nghiệp vụ.
- **RQ-B2.** Bộ test case đạt các tiêu chí phủ của MT-B3 và MT-B4. Hiệu quả phát hiện lỗi thực tế cần được đo khi thực thi.
- **RQ-AB.** Mỗi lỗ hổng ứng với một khoảng trống đặc tả, và các khoảng trống quy về ba nguyên nhân gốc: kiểm soát chỉ đặt ở giao diện, không có tầng dùng chung cho dữ liệu và lỗi, và thiếu đặc tả an toàn.

Phần kiểm thử tĩnh bộ nhớ (mục 5.5) mô hình hóa 13 trạng thái và 36 phép chuyển, ghi nhận 96 vi phạm trên 27/66 tệp baseline, chủ yếu là result set bị giữ tới hết request (CWE-772) và truy vấn không cận số dòng (CWE-770). Các bản sửa về xác thực và SQL không làm giảm các lỗi này; chỉ các case `_v1` viết riêng cho bộ nhớ mới loại bỏ hết vi phạm. Trên mã C viết lại năm chức năng, GCC, Clang, Semgrep và Z3 cùng ghi nhận rò rỉ, giải phóng hai lần, dùng sau khi giải phóng, biến chưa khởi tạo và tràn bộ đệm ở `_v0`, và không còn kết quả nào ở `_v1`.

Đóng góp chính của đồ án là một bộ hồ sơ liền mạch từ cảnh báo của công cụ tới phát hiện, từ phát hiện tới yêu cầu an toàn, và từ yêu cầu tới test case. Bộ hồ sơ này cho phép bắt đầu sửa lỗi theo lộ trình bốn đợt và kiểm chứng từng đợt bằng test case hồi quy đã thiết kế sẵn. Đồ án cũng cho thấy hai bài học về phương pháp. Một là công cụ SAST hữu ích nhất khi được dùng để lập danh mục đầy đủ và tái lập được cho người rà soát. Hai là đặc tả và kiểm thử phải được xây dựng cùng với việc đánh giá an toàn, nếu không lỗ hổng sẽ tiếp tục tồn tại dưới dạng "chức năng". Bước tiếp theo là thực thi bộ test case trong môi trường cô lập và khắc phục các phát hiện Critical.

## 7.2 Tài liệu tham khảo

[1] OWASP Foundation, "OWASP Top 10:2021," 2021. [Online]. Available: https://owasp.org/Top10/

[2] The MITRE Corporation, "CWE – Common Weakness Enumeration." [Online]. Available: https://cwe.mitre.org/

[3] V. Shahdeo, "Library-Management-System," GitHub repository, commit 082d6fb9bdd7846b57033513791ba5b6d2095c11, 2020. [Online]. Available: https://github.com/vinitshahdeo/Library-Management-System

[4] The PHP Group, "Removed extensions and SAPIs," in *PHP Manual – Migrating from PHP 5.6.x to PHP 7.0.x*. [Online]. Available: https://www.php.net/manual/en/migration70.removed-exts-sapis.php

[5] OWASP Foundation, *OWASP Web Security Testing Guide*, v4.2, 2020. [Online]. Available: https://owasp.org/www-project-web-security-testing-guide/

[6] B. Chess and J. West, *Secure Programming with Static Analysis*. Upper Saddle River, NJ, USA: Addison-Wesley, 2007.

[7] Semgrep, Inc., "Semgrep documentation." [Online]. Available: https://semgrep.dev/docs/

[8] PHPStan, "PHPStan – User Guide." [Online]. Available: https://phpstan.org/user-guide/getting-started

[9] K. Scarfone, M. Souppaya, A. Cody, and A. Orebaugh, "Technical guide to information security testing and assessment," NIST, Gaithersburg, MD, USA, SP 800-115, Sep. 2008.

[10] *Software and Systems Engineering — Software Testing — Part 4: Test Techniques*, ISO/IEC/IEEE 29119-4:2021, 2021.

[11] OWASP Foundation, *Application Security Verification Standard*, v4.0.3, 2021. [Online]. Available: https://owasp.org/www-project-application-security-verification-standard/

[12] *Systems and Software Engineering — Life Cycle Processes — Requirements Engineering*, ISO/IEC/IEEE 29148:2018, 2018.

[13] G. J. Myers, C. Sandler, and T. Badgett, *The Art of Software Testing*, 3rd ed. Hoboken, NJ, USA: Wiley, 2011.

[14] *Software and Systems Engineering — Software Testing — Part 3: Test Documentation*, ISO/IEC/IEEE 29119-3:2021, 2021.

[15] *IEEE Standard for Software and System Test Documentation*, IEEE Std 829-2008, 2008.

[16] Nhóm 13, "atpm – Hồ sơ nghiên cứu kiểm thử tĩnh phân hệ thủ thư (study/scope.md, baseline.md)," GitHub repository. [Online]. Available: https://github.com/ndviet0303/atpm

[17] Oracle Corporation, "The MyISAM storage engine," in *MySQL 5.7 Reference Manual*. [Online]. Available: https://dev.mysql.com/doc/refman/5.7/en/myisam-storage-engine.html

[18] Nhóm 13, "Báo cáo bài tập lớn kiểm thử tĩnh mã nguồn hệ thống quản lý thư viện" và "Đặc tả và test case" (tệp PDF, Excel), Trường Đại học Phenikaa, 10/2026.

[19] The PHP Group, "header," in *PHP Manual*. [Online]. Available: https://www.php.net/manual/en/function.header.php

[20] Oracle Corporation, "Server SQL modes," in *MySQL 5.7 Reference Manual*. [Online]. Available: https://dev.mysql.com/doc/refman/5.7/en/sql-mode.html

[21] M. Davis, G. Logemann, and D. Loveland, "A machine program for theorem-proving," *Communications of the ACM*, vol. 5, no. 7, pp. 394–397, 1962.

[22] L. de Moura and N. Bjørner, "Z3: An efficient SMT solver," in *Proc. Tools and Algorithms for the Construction and Analysis of Systems (TACAS 2008)*, LNCS, vol. 4963. Berlin, Germany: Springer, 2008, pp. 337–340.

[23] OWASP Foundation, "SQL Injection Prevention Cheat Sheet," *OWASP Cheat Sheet Series*. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

[24] OWASP Foundation, "Cross Site Scripting Prevention Cheat Sheet," *OWASP Cheat Sheet Series*. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

[25] OWASP Foundation, "Cross-Site Request Forgery Prevention Cheat Sheet," *OWASP Cheat Sheet Series*. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

[26] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, *Experimentation in Software Engineering*. Berlin, Germany: Springer, 2012.

[27] Association for Computing Machinery, "ACM Code of Ethics and Professional Conduct," 2018. [Online]. Available: https://www.acm.org/code-of-ethics

[28] OWASP Foundation, "Password Storage Cheat Sheet," *OWASP Cheat Sheet Series*. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html

[29] The PHP Group, "Prepared statements and stored procedures," in *PHP Manual – PHP Data Objects*. [Online]. Available: https://www.php.net/manual/en/pdo.prepared-statements.php

[30] R. E. Strom and S. Yemini, "Typestate: A programming language concept for enhancing software reliability," IEEE Transactions on Software Engineering, vol. SE-12, no. 1, pp. 157–171, 1986.

[31] The PHP Group, "Memory management," in PHP Manual – Mysqlnd. [Online]. Available: https://www.php.net/manual/en/mysqlnd.memory.php

[32] The PHP Group, "ext/sodium/libsodium.c," php-src, GitHub repository. [Online]. Available: https://github.com/php/php-src/blob/master/ext/sodium/libsodium.c

[33] A. Biere, A. Cimatti, E. Clarke, and Y. Zhu, "Symbolic model checking without BDDs," in Proc. Tools and Algorithms for the Construction and Analysis of Systems (TACAS 1999), LNCS, vol. 1579. Berlin, Germany: Springer, 1999, pp. 193–207.

[34] Free Software Foundation, "Options that control static analysis," in Using the GNU Compiler Collection. [Online]. Available: https://gcc.gnu.org/onlinedocs/gcc/Static-Analyzer-Options.html

[35] LLVM Project, "Clang Static Analyzer." [Online]. Available: https://clang-analyzer.llvm.org/

[36] National Institute of Standards and Technology, "National Vulnerability Database." [Online]. Available: https://nvd.nist.gov/

## 7.3 Phụ lục

Các phụ lục dưới đây là bản đầy đủ của các bảng tóm tắt trong Chương 3 đến Chương 5. Dữ liệu chi tiết từng case SQL, SAT và SMT (816 hồ sơ) nằm trong tệp Excel `Nhom_13_Dac_ta_va_TestCase_Thu_vien.xlsx` nộp kèm báo cáo [18].

### *7.3.1* Phụ lục A – Checklist đánh giá

Bảng 49 trình bày kết luận của 27 tiêu chí sau khi thẩm định lại. Thang kết luận được định nghĩa ở mục 4.2.1.

***Bảng** 49. Kết quả checklist 27 tiêu chí*

| Mã | Tiêu chí | Kết luận | Bằng chứng hoặc giới hạn | Liên kết |
|---|---|---|---|---|
| AUTH-01 | Chống SQLi khi đăng nhập | Không đạt | `index.php:36–44`, `login.php:4–12`: dữ liệu POST được ghép thẳng vào câu SELECT | FIND-01 |
| AUTH-02 | Lưu trữ mật khẩu an toàn | Không đạt | Mật khẩu đi qua luồng POST → INSERT → so sánh trong SQL; `users.php:44` hiển thị mật khẩu | FIND-05 |
| AUTH-03 | Hạn chế thử mật khẩu | Thiếu cơ chế | Không có bộ đếm lần sai hay khóa tạm ở nhánh đăng nhập; cơ chế ở tầng ngoài ứng dụng chưa biết | NFR-13 |
| AUTH-04 | Quản lý phiên | Một phần | Có kiểm tra phiên (`session.php:5–7`) và hủy phiên (`logout.php:3`); không đổi ID phiên sau đăng nhập | NFR-12 |
| AUTH-05 | Cờ cookie phiên | Chưa đủ căn cứ | Mã không đặt cờ cookie; chưa có `php.ini` hay cấu hình triển khai để kết luận | NFR-12 |
| AC-01 | Guard trang quản trị | Đạt trong phạm vi | 23 trang giao diện include `session.php` (Bảng 7) | FR-03 |
| AC-02 | Guard endpoint hành động | Không đạt | 12 handler ghi dữ liệu chỉ include `dbcon.php` | FIND-02 |
| AC-03 | Phân quyền theo vai trò | Thiếu đặc tả | Bảng `users` không có cột vai trò; chưa có yêu cầu về mô hình vai trò | — |
| AC-04 | Quyền trên đối tượng, IDOR | Chưa kết luận | Chưa có chính sách sở hữu đối tượng; việc thiếu guard và thiếu kiểm tra ID đã được ghi riêng | FIND-02, FIND-03 |
| INP-01 | Kiểm tra đầu vào phía server | Không đạt | `books_save.php`, `update_books.php` dùng trực tiếp dữ liệu POST | FIND-03 |
| INP-02 | Truy vấn tham số | Không đạt | Không có prepared statement ở 54 điểm gọi; 23 điểm nội suy dữ liệu HTTP | FIND-03 |
| INP-03 | Kiểm tra khóa số | Không đạt | ID từ GET, POST được ghép thẳng vào SQL, ví dụ `delete_user.php:4–6` | FIND-03 |
| INP-04 | Xử lý tải tệp | Không áp dụng | Form khai báo `multipart/form-data` nhưng không handler nào dùng `$_FILES` | — |
| OUT-01 | Mã hóa HTML text | Không đạt | `books.php:74, 76` và các trang danh sách khác | FIND-04 |

| Mã | Tiêu chí | Kết luận | Bằng chứng hoặc giới hạn | Liên kết |
|---|---|---|---|---|
| OUT-02 | Mã hóa thuộc tính HTML | Không đạt | `edit_book.php:23–24` | FIND-04 |
| OUT-03 | Mã hóa JavaScript, URL | Cần củng cố | `toolttip_edit_delete.php` xuất ID vào JavaScript; nguồn hiện là cột INT nhưng chưa mã hóa theo ngữ cảnh | FIND-04 |
| STATE-01 | Phương thức thay đổi dữ liệu | Không đạt | 5 handler ghi dữ liệu qua GET | FIND-06 |
| STATE-02 | Anti-CSRF | Không đạt | Không có quy trình sinh và kiểm tra token trong form, handler | FIND-06 |
| STATE-03 | Xác nhận phía server | Không đạt | Hộp thoại Yes chỉ có ở giao diện; handler thực hiện ngay khi nhận yêu cầu | FIND-06 |
| ERR-01 | Che lỗi CSDL ở output | Không đạt | 52 lời gọi `die(mysql_error())` trong 37 tệp | FIND-10 |
| ERR-02 | Cấu hình hiển thị lỗi | Chưa đủ căn cứ | Mã không đặt `error_reporting`, `display_errors`; chưa có cấu hình máy chủ | — |
| ERR-03 | Thông tin kết nối, mật khẩu | Không đạt | `dbcon.php:2`; `users.php:44` | FIND-08, FIND-05 |
| BIZ-01 | Kiểm tra số bản khả dụng | Thiếu đặc tả | `borrow_save.php` không kiểm tra; cần chính sách kho | BR-11 |
| BIZ-02 | Hạn mức sách mỗi người | Thiếu đặc tả | Chỉ có giới hạn 3 sách mỗi phiếu ở client (BR-03); không có SRS về hạn mức | BR-12 |
| BIZ-03 | ID và giao dịch khi mượn | Không đạt | `ORDER BY borrow_id DESC` để lấy ID; `borrow`, `borrowdetails` dùng MyISAM | FIND-07 |
| BIZ-04 | Thẻ bị khóa, quá hạn | Thiếu đặc tả | Cần quy tắc nghiệp vụ trước khi kết luận | BR-13, BR-14 |
| BIZ-05 | Nhất quán trả, hỏng, mất | Cần làm rõ | `return_save.php` chỉ đổi trạng thái chi tiết mượn; bảng `lost_book` không được dùng | BR-15 |

### *7.3.2* Phụ lục B – Sổ theo dõi phát hiện đầy đủ

Mỗi phát hiện dưới đây có trạng thái `confirmed-static`. Tác động được ghi ở dạng có điều kiện vì đồ án không chạy ứng dụng. Mười hai handler thuộc FIND-02 gồm `delete_user`, `delete_books`, `delete_member`, `delete_student`, `books_save`, `member_save`, `student_save`, `borrow_save`, `return_save`, `update_books`, `update_member` và `update_students`.

***Bảng** 50. Sổ theo dõi 11 phát hiện xác nhận tĩnh*

| Phát hiện | Vị trí chính | Nguyên nhân | Tác động có điều kiện | Hướng khắc phục |
|---|---|---|---|---|
| **FIND-01** SQL Injection trong xác thực<br>Critical · CWE-89<br>REQ-L01, NFR-01 | `index.php:36–44`; `login.php:4–12` | Username, password từ POST được ghép vào SELECT; chỉ cần truy vấn trả về một dòng là phiên được cấp | Nếu chạy trên môi trường tương thích, dữ liệu nhập có thể làm thay đổi điều kiện chọn tài khoản, dẫn tới vượt qua xác thực | Truy vấn tham số theo username; xác minh mật khẩu bằng hàm băm; đổi ID phiên sau khi xác thực |
| **FIND-02** Thiếu kiểm tra phiên ở endpoint ghi dữ liệu<br>Critical · CWE-306<br>REQ-L02, NFR-02 | 12 handler; ví dụ `delete_user.php:1–8` | Handler chỉ include `dbcon.php`; không gọi `session_start`, không kiểm tra `$_SESSION`; điều kiện `isset(submit)` chỉ nhận biết nút gửi form | Nếu handler truy cập được trực tiếp, thao tác ghi, xóa không bị ràng buộc bởi phiên; guard ở trang giao diện không bảo vệ handler | Đặt guard xác thực và phân quyền tập trung trước mọi thao tác ghi; dừng xử lý khi không hợp lệ |
| **FIND-03** SQL Injection trong CRUD và tìm kiếm<br>High · CWE-89<br>REQ-L03, NFR-03 | `books_save.php:4–21`; `advance_search.php:58–59`; 21 điểm gọi nội suy dữ liệu HTTP khác | Trường sách, thành viên, ID và tham số tìm kiếm được ghép vào INSERT, UPDATE, DELETE, LIKE; không có binding hay kiểm tra kiểu | Dữ liệu nhập có thể làm thay đổi câu truy vấn trên các bảng sách, thành viên, mượn – trả | Truy vấn tham số; kiểm tra kiểu, độ dài, miền giá trị theo schema; bind cả tham số LIKE; kiểm tra ID không thay cho kiểm tra quyền |
| **FIND-04** Dữ liệu động không được mã hóa khi xuất HTML<br>High · CWE-79<br>REQ-L04, NFR-04 | `books.php:73–76`; `edit_book.php:23–24` | Tiêu đề, tác giả từ CSDL được echo vào HTML; `edit_book.php` đưa `book_title` và `$_GET['id']` vào thuộc tính `value` không mã hóa | Có đường dữ liệu từ handler ghi sách tới trang danh sách (Stored XSS) và đường phản chiếu ID (Reflected XSS); phụ thuộc dữ liệu và trình duyệt | Mã hóa theo ngữ cảnh tại điểm xuất: `htmlspecialchars` với dấu nháy và UTF-8 cho HTML; serialization cho JavaScript; mã hóa từng thành phần URL |
| **FIND-05** Mật khẩu lưu và hiển thị dạng bản rõ<br>High · CWE-256<br>REQ-L05, NFR-05 | `users.php:43–46`; `modal_edit_user.php:14–16` | Mật khẩu được INSERT nguyên văn, so sánh trong SQL, hiển thị trong bảng và trong ô `type="text"` | Người xem danh sách tài khoản hoặc người có bản sao CSDL tiếp cận được mật khẩu | Băm mật khẩu bằng hàm thích ứng và xác minh bằng `password_verify` [28]; bỏ cột mật khẩu khỏi giao diện; lập kế hoạch di chuyển dữ liệu |

| Phát hiện | Vị trí chính | Nguyên nhân | Tác động có điều kiện | Hướng khắc phục |
|---|---|---|---|---|
| **FIND-06** Thao tác ghi qua GET, thiếu anti-CSRF<br>High · CWE-352<br>REQ-L06, NFR-06 | `delete_books.php:2–5`; `modal_return.php:7` | 5 handler nhận GET để ghi; không có token; hộp thoại Yes chỉ xác nhận ở client | Có nguy cơ yêu cầu thay đổi trạng thái ngoài ý muốn khi người dùng đang đăng nhập | Dùng POST cho thao tác ghi; kiểm tra phiên, quyền và token anti-CSRF ở server [25]; cấu hình cookie phù hợp |
| **FIND-07** Lấy sai ID, thiếu tính nguyên tử khi mượn<br>Medium · CWE-362<br>REQ-L07, NFR-07 | `borrow_save.php:17–20, 23–29` | Sau INSERT phiếu, mã lấy dòng có `borrow_id` lớn nhất thay vì ID của chính kết nối; hai bảng dùng MyISAM | Với lịch xen kẽ, chi tiết của phiếu A có thể gắn vào phiếu B; lỗi giữa chừng để lại dữ liệu dở dang | Lấy ID vừa chèn của kết nối hiện tại; chuyển sang InnoDB; dùng giao dịch và rollback |
| **FIND-08** Cấu hình kết nối cố định, tài khoản root<br>Medium · CWE-798<br>REQ-L08, NFR-08 | `dbcon.php:1–3` | Máy chủ, tài khoản `root` và mật khẩu rỗng cố định trong `mysql_connect` | Nếu dùng nguyên trạng, ứng dụng phụ thuộc tài khoản quyền cao không có mật khẩu | Đọc cấu hình từ môi trường được bảo vệ; tài khoản ứng dụng có quyền tối thiểu |
| **FIND-09** API `ext/mysql` đã lỗi thời<br>Medium · CWE-477<br>REQ-L09, NFR-09 | `dbcon.php:2`; mọi lời gọi `mysql_*` | Dùng `mysql_connect`, `mysql_query`, `mysql_fetch_array`, `mysql_num_rows`, `mysql_error`, vốn đã bị loại từ PHP 7.0 [4] | Lint hợp lệ nhưng ứng dụng không chạy được trên PHP hiện hành; không có prepared statement | Chuyển tầng CSDL sang MySQLi hoặc PDO với prepared statement [29] |
| **FIND-10** Lỗi CSDL đưa trực tiếp ra output<br>Low · CWE-209<br>REQ-L10, NFR-10 | `login.php:7`; `return_save.php:7`; tổng 52 lời gọi | Mã tự in `mysql_error()` qua `die(...)` khi truy vấn lỗi | Khi truy vấn thất bại, thông báo có thể lộ tên bảng, cột, cú pháp SQL | Ghi chi tiết vào log được bảo vệ; trả thông báo chung kèm mã tham chiếu |
| **FIND-11** Include thiếu, tham chiếu cấu trúc không hoàn chỉnh<br>Low · lỗi chất lượng<br>REQ-L11, NFR-11 | `archive.php:3`; `unstudents.php:3, 29, 44`; `unreturned_books.php` | Ba include không tồn tại; bảng `students` không có trong schema; tệp rỗng; `update_students.php:18` chuyển hướng tới `students.php` không tồn tại | Chức năng không hoàn chỉnh hoặc phát sinh lỗi khi chạy; không tính là lỗ hổng độc lập | Rà soát và loại bỏ hoặc khôi phục các chức năng dư thừa theo thiết kế được xác nhận |

Ngoài 11 phát hiện trên, sổ còn ghi hai nhóm mục không được tính là lỗ hổng:

- **BIZ-INC-01** (`inconclusive`): các quy tắc mượn – trả không có trong mã và không có văn bản quy định, gồm BR-11 đến BR-15. Nhóm này cần chủ sở hữu sản phẩm xác nhận trước khi kết luận.

- **Cảnh báo giả tại sink:** 19 truy vấn hằng bị rule tùy biến CWE-89 đánh dấu nhưng không có dữ liệu nội suy, ví dụ `users.php:39`. Kết luận "không phải SQLi" chỉ áp dụng cho chính sink đó; các vấn đề khác trong cùng tệp, như việc hiển thị mật khẩu ở `users.php:44`, vẫn được xét riêng.

### *7.3.3* Phụ lục C – Cấu hình và tái lập

Bảng 51 liệt kê các tệp bằng chứng trong gói nộp của nhóm [18]. Phiên bản công cụ và cấu hình đã nêu ở Bảng 17 và Bảng 18.

***Bảng** 51. Danh mục tệp bằng chứng và nội dung*

| Tệp hoặc thư mục | Nội dung |
|---|---|
| `source_v0/librarian`, `db`, `LICENSE` | 66 tệp PHP baseline, schema và giấy phép upstream |
| `source_inventory`, `php_lint`, `php_tokens` | Mã băm, số dòng, kết quả lint và kiểm kê token PHP |
| `semgrep_run1.json`, `semgrep_run2.json`, `sast_manifest.json` | Output SAST của hai lần quét hợp lệ; phiên bản, lệnh và đối chiếu lặp |
| `historical_semgrep_audit.json` | Hồ sơ lần quét lịch sử 270 hit (mã thoát 2, lỗi parse rule) |
| `phpstan_fresh.json`, `phpstan_debug.*` | 17 thông báo PHPStan và log gốc với `--debug` |
| `generated_cases/_v0`, `generated_cases/_v1` | 10 tệp PHP mã sinh theo chức năng; chỉ phân tích văn bản, không chạy hàm |
| `generated_cases/sql` | 108 tệp PHP wrapper SQL trước và sau sửa cùng 1 tệp guard dùng chung |
| `models/run_models.py`, `formal_results.json`, `formal/` | DPLL và Z3: 16 CNF, 10 SMT, mô hình, witness, trace |
| `models/run_sql_cases.py`, `sql_inventory.json`, `sql_case_results.json` | 54 truy vấn, 92 tham số, 162 CNF SQL, 552 SMT |
| `case_register.json` | Sổ 816 hồ sơ case, tách kỳ vọng và kết quả thực tế |
| `generated_cases/memory`, `generated_cases/memory_c` | 4 cặp PHP và 5 cặp C trước, sau sửa cho kiểm thử bộ nhớ; chỉ phân tích văn bản, không chạy |
| `models/memory_typestate.py`, `test_memory_typestate.py`, `run_memory_cases.py` | Bộ phân tích trạng thái bộ nhớ, 19 unit test, BMC, ngân sách bộ nhớ và mô hình bộ đệm C bằng Z3 |
| `run_memory_static.py`, `memory_rules.yaml`, `memory_static_results.json` | `php -l`, Semgrep, Clang `--analyze` và GCC `-fanalyzer` trên mã nguồn |
| `memory_traces.json`, `memory_case_results.json`, `memory_formal/`, `memory_cwe_cve.json` | 1.127 bước chuyển, 250 đối tượng, 45 tệp SMT-LIB, phân loại CWE/CVE |
| `README`, các script trong `evidence/` | Hướng dẫn tái lập phân tích tĩnh và kiểm tra mã băm |

Snapshot rule được định danh bằng mã băm SHA-256: tệp `frozen_registry_php_rules.json` có mã `a1b9b9e96f3377860e7f9e37a729ef140f0e51aa0ac43ab5f80742aa6146335d`; tệp `custom_php_rules_corrected.yaml` có mã

`8e07a286e0bea1ff8e7960e29e06d52deea8b0379747939fa7de73ac51142764`. Môi trường tái lập cần PHP CLI, Semgrep 1.176.1, PHPStan 2.1.8 và z3-solver 5.1.0.0. Quy trình tái lập không yêu cầu tạo CSDL. Trình tự lệnh như sau:

```
# Chuẩn bị công cụ theo README; không tạo CSDL, không chạy ứng dụng
.venv/bin/python evidence/collect_static.py        # băm, lint, kiểm kê token
.venv/bin/python evidence/run_sast.py              # Semgrep lần 1, lần 2, so chữ ký
.venv/bin/python evidence/run_generated_static.py  # lint và quét mã sinh
.venv/bin/python models/run_models.py              # 16 CNF, 10 SMT
.venv/bin/python models/run_sql_cases.py           # 162 CNF SQL, 552 SMT
.venv/bin/python models/build_case_register.py     # sổ 816 hồ sơ
php -d memory_limit=1G tools/phpstan.phar analyse \
    -c tools/phpstan.neon --error-format=json --no-progress
.venv/bin/python models/test_memory_typestate.py   # 19 unit test bộ nhớ
.venv/bin/python evidence/run_memory_static.py     # Semgrep, Clang, GCC cho bộ nhớ
.venv/bin/python models/run_memory_cases.py        # Z3: BMC, ngân sách, bộ đệm C
```

PHPStan trả mã thoát 1 khi có thông báo lỗi nguồn; đây là trạng thái mong đợi với baseline. Kết quả chỉ được coi là tái lập khi mã băm của 66 tệp PHP, schema và `LICENSE` trùng với Bảng 5 và hồ sơ phạm vi [16].

### *7.3.4* Phụ lục D – Đặc tả chi tiết

#### D.1 Đặc tả các use-case chính

Bảng 52 đến Bảng 57 đặc tả sáu use-case có rủi ro cao nhất hoặc có hành vi lệch đặc tả. Mười hai use-case còn lại có cấu trúc đơn giản và đã được mô tả đủ ở Bảng 13 cùng các FR tương ứng.

***Bảng** 52. Đặc tả UC-01 Đăng nhập*

| Mục | Nội dung |
|---|---|
| Tác nhân | Thủ thư (chưa xác thực) |
| Tiền điều kiện | Có tài khoản trong bảng `users` |
| Luồng chính | 1. Mở `index.php`. 2. Nhập username, password, bấm Submit. 3. Hệ thống tìm bản ghi khớp (`index.php:38–39`). 4. Có ít nhất một dòng: lưu `user_id` vào phiên, chuyển tới `dashboard.php` (`index.php:42–44`) |
| Luồng thay thế | 3a. Không có dòng nào: hiển thị "Access Denied", ở lại trang đăng nhập (`index.php:46–47`) |
| Hậu điều kiện | `$_SESSION['id']` chứa `user_id` của tài khoản |
| Quy tắc, yêu cầu liên quan | FR-01, FR-02; NFR-01, NFR-05, NFR-12, NFR-13 |
| Phát hiện | FIND-01, FIND-05, FIND-10 |
| Test case | TC-AUTH-01 đến TC-AUTH-04, TC-AUTH-09, TC-AUTH-10, TC-FIND01-R, TC-FIND01-H |

***Bảng** 53. Đặc tả UC-08 Thêm sách*

| Mục | Nội dung |
|---|---|
| Tác nhân | Thủ thư đã đăng nhập |
| Tiền điều kiện | Phiên hợp lệ (ở trang `add_books.php`); có ít nhất một danh mục |
| Luồng chính | 1. Mở `add_books.php`. 2. Nhập chín trường, chọn danh mục và trạng thái. 3. Gửi POST tới `books_save.php`. 4. Hệ thống chèn bản ghi với `date_added = NOW()` (`books_save.php:20–21`) và chuyển tới `books.php` |
| Luồng ngoại lệ | 4a. Truy vấn lỗi: in lỗi CSDL ra trang (FIND-10) |
| Hậu điều kiện | Có bản ghi `book` mới với trạng thái đã chọn |
| Ràng buộc dữ liệu | Theo schema: `book_title` ≤ 100 ký tự; `author`, `isbn` ≤ 50; `book_pub`, `publisher_name` ≤ 100; `status` ≤ 30; `category_id`, `book_copies`, `copyright_year` là số nguyên. Mã không kiểm tra ràng buộc nào ở server |
| Quy tắc, yêu cầu liên quan | FR-11, BR-07; NFR-02, NFR-03, NFR-04 |
| Phát hiện | FIND-02, FIND-03, FIND-04, FIND-10 |
| Test case | TC-BOOK-01 đến TC-BOOK-06, TC-FIND02-R, TC-FIND03-R, TC-FIND04-R |

***Bảng** 54. Đặc tả UC-11 Tìm kiếm sách*

| Mục | Nội dung |
|---|---|
| Tác nhân | Thủ thư đã đăng nhập |
| Tiền điều kiện | Phiên hợp lệ |
| Luồng chính | 1. Mở hộp thoại tìm kiếm (`search_form.php`). 2. Nhập Title, Author. 3. Gửi POST tới `advance_search.php`. 4. Hệ thống trả các sách khác Archive có tiêu đề chứa Title hoặc tác giả chứa Author (`advance_search.php:58–59`) kèm số bản còn lại |
| Hành vi lệch kỳ vọng | Khi một trong hai ô để trống, điều kiện `LIKE '%%'` khớp mọi sách nên kết quả là toàn bộ sách chưa lưu trữ (QS-02) |
| Quy tắc, yêu cầu liên quan | FR-15, BR-01, BR-02; NFR-03, NFR-04 |
| Phát hiện | FIND-03, FIND-04 |
| Test case | TC-SRCH-01 đến TC-SRCH-05 |

***Bảng** 55. Đặc tả UC-14 Sửa thành viên*

| Mục | Nội dung |
|---|---|
| Tác nhân | Thủ thư đã đăng nhập |
| Tiền điều kiện | Phiên hợp lệ; thành viên tồn tại |
| Luồng chính | 1. Từ `member.php` bấm Edit, mở `edit_member.php?id=…`. 2. Form điền sẵn các trường trừ Contact (`edit_member.php:48`). 3. Sửa và gửi POST tới `update_member.php`. 4. Hệ thống cập nhật cả chín trường (`update_member.php:14`), chuyển về `member.php` |
| Hành vi lệch kỳ vọng | Nếu không nhập lại Contact, số điện thoại bị ghi đè thành chuỗi rỗng (QS-01); Gender là ô văn bản tự do, khác ô chọn ở form thêm |
| Quy tắc, yêu cầu liên quan | FR-18, BR-08, BR-09; NFR-02, NFR-03, NFR-04 |
| Phát hiện | FIND-02, FIND-03, FIND-04 |
| Test case | TC-MEMB-06 đến TC-MEMB-08 |

***Bảng** 56. Đặc tả UC-16 Lập phiếu mượn*

| Mục | Nội dung |
|---|---|
| Tác nhân | Thủ thư đã đăng nhập |
| Tiền điều kiện | Phiên hợp lệ (ở trang `borrow.php`); có thành viên và sách khác Archive |
| Luồng chính | 1. Chọn thành viên, hạn trả, từ 1 đến 3 sách. 2. Gửi POST tới `borrow_save.php`. 3. Hệ thống chèn `borrow` (`borrow_save.php:17`), lấy `borrow_id` lớn nhất (dòng 18–20), chèn một `borrowdetails` pending cho mỗi sách (dòng 23–28), chuyển về `borrow.php` |
| Luồng thay thế | 2a. Không chọn sách: quay lại `borrow.php`, không ghi (dòng 8–9) |
| Hậu điều kiện kỳ vọng | Một phiếu và đúng các chi tiết của phiếu đó, ghi nguyên tử |

| Mục | Nội dung |
|---|---|
| Câu hỏi mở | BR-11 (hết bản), BR-12 (hạn mức tổng), BR-13 (thành viên Banned), sách Lost hoặc Damage có được mượn không |
| Quy tắc, yêu cầu liên quan | FR-20, BR-03 đến BR-05, BR-10 đến BR-13; NFR-02, NFR-03, NFR-07 |
| Phát hiện | FIND-02, FIND-03, FIND-07 |
| Test case | TC-CIRC-01 đến TC-CIRC-09, TC-FIND07-R, TC-FIND07-H (Bảng 23) |

***Bảng** 57. Đặc tả UC-17 Ghi nhận trả sách*

| Mục | Nội dung |
|---|---|
| Tác nhân | Thủ thư đã đăng nhập |
| Tiền điều kiện | Phiên hợp lệ (ở trang `view_borrow.php`) |
| Luồng chính | 1. Bấm Return ở một dòng chi tiết mượn. 2. Chọn Yes trên hộp thoại (`modal_return.php:7`). 3. Gửi GET tới `return_save.php` với `id` và `book_id`. 4. Hệ thống đặt `borrow_status = returned`, `date_return = NOW()` (`return_save.php:7`), chuyển về `view_borrow.php` |
| Hành vi lệch kỳ vọng | Nút Return có ở mọi dòng kể cả dòng đã trả; trả lại lần nữa ghi đè `date_return` (BR-06); cặp ID không tồn tại vẫn chuyển hướng như thành công |
| Quy tắc, yêu cầu liên quan | FR-22, BR-06; NFR-02, NFR-03, NFR-06 |
| Phát hiện | FIND-02, FIND-03, FIND-06 |
| Test case | TC-CIRC-10 đến TC-CIRC-12, TC-FIND06-R |

## D.2 Đặc tả dữ liệu đầu vào của các truy vấn nhận dữ liệu HTTP

Bảng 58 đặc tả tham số của 23 truy vấn nội suy trực tiếp dữ liệu HTTP (lớp `HTTP_INTERPOLATION`), tổng cộng 79 lần xuất hiện tham số. Miền giá trị lấy từ schema: chuỗi giới hạn theo độ dài `varchar(n)` và được phép rỗng vì chưa có SRS quy định bắt buộc; số nguyên dùng cận trên 2.147.483.647, cận dưới là 1 với ID và 0 với số bản, năm xuất bản. Đây là chính sách đề xuất cho phiên bản sửa, không phải ràng buộc mà mã baseline đang kiểm tra. Mười ba tham số còn lại lấy từ kết quả CSDL thuộc 12 truy vấn ở hai lớp `DB_AFTER_UNSAFE_SELECT` và `DB_INTEGER_INTERPOLATION`; chi tiết 92 tham số nằm trong sheet `SQLDauVao` [18].

***Bảng** 58. Tham số của 23 truy vấn nhận dữ liệu HTTP và miền giá trị theo schema*

| Truy vấn | Vị trí | Thao tác | Tham số: nguồn, cột đích, miền giá trị |
|---|---|---|---|
| SQL-02 | `advance_search.php:58-59` | SELECT | `$title` (POST) → `book.book_title`, ≤ 100 ký tự; `$author` (POST) → `book.author`, ≤ 50 ký tự |

| Truy vấn | Vị trí | Thao tác | Tham số: nguồn, cột đích, miền giá trị |
|---|---|---|---|
| SQL-10 | books_save.php:20-21 | INSERT | $book_title (POST) → book.book_title, ≤ 100 ký tự; $category_id (POST) → book.category_id, số nguyên 1 … 2.147.483.647; $author (POST) → book.author, ≤ 50 ký tự; $book_copies (POST) → book.book_copies, số nguyên 0 … 2.147.483.647; $book_pub (POST) → book.book_pub, ≤ 100 ký tự; $publisher_name (POST) → book.publisher_name, ≤ 100 ký tự; $isbn (POST) → book.isbn, ≤ 50 ký tự; $copyright_year (POST) → book.copyright_year, số nguyên 0 … 2.147.483.647; $status (POST) → book.status, ≤ 30 ký tự |
| SQL-14 | borrow_save.php:17-17 | INSERT | $member_id (POST) → member.member_id, số nguyên 1 … 2.147.483.647; $due_date (POST) → borrow.due_date, ≤ 100 ký tự |
| SQL-16 | borrow_save.php:26-26 | INSERT | $id[$i] (POST) → book.book_id, số nguyên 1 … 2.147.483.647; $borrow_id (DB_INTEGER) → borrow.borrow_id, số nguyên 1 … 2.147.483.647 |
| SQL-20 | delete_books.php:4-4 | UPDATE | $id (GET) → book.book_id, số nguyên 1 … 2.147.483.647 |
| SQL-21 | delete_member.php:4-4 | DELETE | $id (GET) → member.member_id, số nguyên 1 … 2.147.483.647 |
| SQL-22 | delete_student.php:4-4 | DELETE | $id (GET) → member.member_id, số nguyên 1 … 2.147.483.647 |
| SQL-23 | delete_user.php:6-6 | DELETE | $id (GET) → users.user_id, số nguyên 1 … 2.147.483.647 |
| SQL-24 | edit_book.php:10-10 | SELECT | $get_id (GET) → book.book_id, số nguyên 1 … 2.147.483.647 |
| SQL-26 | edit_member.php:10-10 | SELECT | $get_id (GET) → member.member_id, số nguyên 1 … 2.147.483.647 |
| SQL-27 | edit_student.php:10-10 | SELECT | $get_id (GET) → member.member_id, số nguyên 1 … 2.147.483.647 |
| SQL-28 | edit_student.php:58-58 | SELECT | $get_id (GET) → member.member_id, số nguyên 1 … 2.147.483.647 |
| SQL-29 | edit_student.php:77-77 | SELECT | $get_id (GET) → member.member_id, số nguyên 1 … 2.147.483.647 |
| SQL-30 | index.php:39-39 | SELECT | $username (POST) → users.username, ≤ 100 ký tự; $password (POST) → users.password, ≤ 100 ký tự |
| SQL-31 | login.php:7-7 | SELECT | $username (POST) → users.username, ≤ 100 ký tự; $password (POST) → users.password, ≤ 100 ký tự |

| Truy vấn | Vị trí | Thao tác | Tham số: nguồn, cột đích, miền giá trị |
|---|---|---|---|
| SQL-35 | member_save.php:15-15 | INSERT | $firstname (POST) → member.firstname, ≤ 100 ký tự; $lastname (POST) → member.lastname, ≤ 100 ký tự; $gender (POST) → member.gender, ≤ 10 ký tự; $address (POST) → member.address, ≤ 100 ký tự; $contact (POST) → member.contact, ≤ 100 ký tự; $type (POST) → member.type, ≤ 100 ký tự; $year_level (POST) → member.year_level, ≤ 100 ký tự |
| SQL-36 | modal_add_user.php:48-48 | INSERT | $username (POST) → users.username, ≤ 100 ký tự; $password (POST) → users.password, ≤ 100 ký tự; $firstname (POST) → users.firstname, ≤ 100 ký tự; $lastname (POST) → users.lastname, ≤ 100 ký tự |
| SQL-37 | modal_edit_user.php:53-53 | UPDATE | $username (POST) → users.username, ≤ 100 ký tự; $password (POST) → users.password, ≤ 100 ký tự; $firstname (POST) → users.firstname, ≤ 100 ký tự; $lastname (POST) → users.lastname, ≤ 100 ký tự; $user_id (POST) → users.user_id, số nguyên 1 … 2.147.483.647 |
| SQL-43 | return_save.php:7-7 | UPDATE | $id (GET) → borrow.borrow_id, số nguyên 1 … 2.147.483.647; $book_id (GET) → book.book_id, số nguyên 1 … 2.147.483.647 |
| SQL-45 | student_save.php:15-15 | INSERT | $firstname (POST) → member.firstname, ≤ 100 ký tự; $lastname (POST) → member.lastname, ≤ 100 ký tự; $gender (POST) → member.gender, ≤ 10 ký tự; $address (POST) → member.address, ≤ 100 ký tự; $contact (POST) → member.contact, ≤ 100 ký tự; $type (POST) → member.type, ≤ 100 ký tự; $year_level (POST) → member.year_level, ≤ 100 ký tự |
| SQL-49 | update_books.php:20-21 | UPDATE | $book_title (POST) → book.book_title, ≤ 100 ký tự; $category_id (POST) → book.category_id, số nguyên 1 … 2.147.483.647; $author (POST) → book.author, ≤ 50 ký tự; $book_copies (POST) → book.book_copies, số nguyên 0 … 2.147.483.647; $book_pub (POST) → book.book_pub, ≤ 100 ký tự; $publisher_name (POST) → book.publisher_name, ≤ 100 ký tự; $isbn (POST) → book.isbn, ≤ 50 ký tự; $copyright_year (POST) → book.copyright_year, số nguyên 0 … 2.147.483.647; $status (POST) → book.status, ≤ 30 ký tự; $id (POST) → book.book_id, số nguyên 1 … 2.147.483.647 |

| Truy vấn | Vị trí | Thao tác | Tham số: nguồn, cột đích, miền giá trị |
|---|---|---|---|
| SQL-50 | update_member.php:14-14 | UPDATE | $firstname (POST) → member.firstname, ≤ 100 ký tự; $lastname (POST) → member.lastname, ≤ 100 ký tự; $gender (POST) → member.gender, ≤ 10 ký tự; $address (POST) → member.address, ≤ 100 ký tự; $contact (POST) → member.contact, ≤ 100 ký tự; $type (POST) → member.type, ≤ 100 ký tự; $year_level (POST) → member.year_level, ≤ 100 ký tự; $status (POST) → member.status, ≤ 100 ký tự; $id (POST) → member.member_id, số nguyên 1 … 2.147.483.647 |
| SQL-51 | update_students.php:15-15 | UPDATE | $firstname (POST) → member.firstname, ≤ 100 ký tự; $lastname (POST) → member.lastname, ≤ 100 ký tự; $gender (POST) → member.gender, ≤ 10 ký tự; $address (POST) → member.address, ≤ 100 ký tự; $contact (POST) → member.contact, ≤ 100 ký tự; $type (POST) → member.type, ≤ 100 ký tự; $year_level (POST) → member.year_level, ≤ 100 ký tự; $id (POST) → member.member_id, số nguyên 1 … 2.147.483.647 |

### *7.3.5* Phụ lục E – Danh mục test case đầy đủ

Bảng 59 liệt kê 90 test case động. Toàn bộ test case mang trạng thái **Chưa thực thi**. Cột "Dự đoán trên baseline" ghi kết quả suy ra từ phân tích tĩnh, mở đầu bằng một trong bốn nhãn: **Đạt**, **Không đạt**, **Phụ thuộc cấu hình** (kết quả phụ thuộc `sql_mode`, output buffering hoặc cấu hình PHP) và **Chờ xác nhận** (kỳ vọng phụ thuộc quy tắc nghiệp vụ mức C). Với test case loại H, dự đoán trên baseline luôn là "Không đạt (chưa sửa)". Ký hiệu loại: + là trường hợp hợp lệ, − là trường hợp không hợp lệ hoặc bị cấm, R là tái hiện phát hiện, H là hồi quy sau sửa.

***Bảng** 59. Danh mục 90 test case động (trạng thái: Chưa thực thi)*

| ID | Truy vết | KT | Loại | Điều kiện, dữ liệu và các bước | Kết quả mong đợi | Dự đoán trên baseline |
|---|---|---|---|---|---|---|
| TC-AUTH-01 | FR-01, FR-02, UC-01 | DT | + | Tài khoản thử có trong `users`; nhập đúng username, password; bấm Submit | Chuyển tới `dashboard.php`; phiên chứa `user_id` của tài khoản | **Đạt**: `index.php:42–44` |
| TC-AUTH-02 | FR-02 | DT | − | Username đúng, mật khẩu sai | Hiển thị "Access Denied"; không tạo phiên đăng nhập | **Đạt**: `index.php:46–47` |
| TC-AUTH-03 | FR-02 | DT | − | Username không tồn tại, mật khẩu bất kỳ | Như TC-AUTH-02 | **Đạt**: `index.php:46–47` |
| TC-AUTH-04 | FR-01 | EP | − | (a) Để trống một ô rồi bấm Submit; (b) gửi trực tiếp POST thiếu trường `password` | (a) Trình duyệt chặn; (b) server từ chối, không truy vấn với giá trị rỗng | **Không đạt**: (a) chặn nhờ `required` (`index.php:18, 24`); (b) server không kiểm tra trường (`index.php:36–37`) |
| TC-AUTH-05 | FR-03, FR-05, FR-09, FR-16, FR-21 | ST | − | Chưa đăng nhập; mở trực tiếp `users.php`, `books.php`, `member.php`, `view_borrow.php` | Mỗi trang chuyển về `index.php`, không xuất dữ liệu | **Phụ thuộc cấu hình**: `session.php:5–7` gọi `exit()` nên không xuất dữ liệu; chuyển hướng phụ thuộc output buffering vì `header.php` đã xuất HTML |
| TC-AUTH-06 | FR-03 | ST | + | Đã đăng nhập; mở `books.php` | Hiển thị danh sách sách | **Đạt**: `session.php:9`; `books.php:55` |
| TC-AUTH-07 | FR-04, UC-02 | ST | + | Đã đăng nhập; bấm Logout, chọn Yes | Phiên bị hủy; chuyển về trang chủ cổng công cộng | **Đạt**: `footer.php:19–25`; `logout.php:2–4` |

| ID | Truy vết | KT | Loại | Điều kiện, dữ liệu và các bước | Kết quả mong đợi | Dự đoán trên baseline |
|---|---|---|---|---|---|---|
| TC-AUTH-08 | FR-04 | ST | − | Sau TC-AUTH-07, mở lại `books.php` bằng địa chỉ cũ | Không có dữ liệu; chuyển về `index.php` | **Phụ thuộc cấu hình**: phiên đã hủy nên bị chặn; chuyển hướng như TC-AUTH-05 |
| TC-AUTH-09 | NFR-12 | SEC | − | Ghi định danh phiên trước và sau đăng nhập; xem thuộc tính cookie phiên | ID phiên đổi sau đăng nhập; cookie có HttpOnly, SameSite, Secure (khi dùng HTTPS) | **Không đạt**: không gọi `session_regenerate_id` (`index.php:35–44`); cờ cookie phụ thuộc `php.ini` |
| TC-AUTH-10 | NFR-13 | SEC | − | Đăng nhập sai liên tiếp vượt ngưỡng của chính sách (ngưỡng cần phê duyệt) | Tài khoản hoặc nguồn yêu cầu bị trì hoãn, khóa tạm | **Không đạt**: không có bộ đếm lần sai (`index.php:34–49`) |
| TC-USER-01 | FR-05, UC-03 | EP | + | Đã đăng nhập; mở `users.php` | Bảng liệt kê đủ tài khoản | **Đạt**: `users.php:39–46`; cột Password vi phạm NFR-05 (TC-FIND05-R) |
| TC-USER-02 | FR-06, UC-04 | EP | + | Thêm tài khoản với bốn trường hợp lệ | Tài khoản mới xuất hiện trong bảng | **Đạt**: `modal_add_user.php:42–48` |
| TC-USER-03 | FR-06 | BVA | − | Gửi trực tiếp `username` dài 101 ký tự (vượt `varchar(100)`) | Từ chối, thông báo độ dài hợp lệ | **Phụ thuộc cấu hình**: không kiểm tra độ dài; MySQL cắt chuỗi hoặc báo lỗi tùy `sql_mode` [20] |
| TC-USER-04 | FR-06 | BVA | + | `username` dài đúng 100 ký tự | Lưu đủ 100 ký tự | **Đạt**: vừa cột `varchar(100)` |
| TC-USER-05 | FR-06 | EP | − | Thêm tài khoản có `username` trùng tài khoản đã có | Từ chối tên đăng nhập trùng (quy tắc cần xác nhận) | **Chờ xác nhận**: schema không có ràng buộc UNIQUE, mã không kiểm tra trùng |
| TC-USER-06 | FR-07, UC-05 | EP | + | Sửa `firstname` của một tài khoản qua hộp thoại Edit | Giá trị mới hiển thị; chỉ một câu UPDATE được thực hiện | **Không đạt**: giá trị đúng nhưng UPDATE chạy lặp theo số tài khoản vì `modal_edit_user.php` được include trong vòng lặp (`users.php:40–60`) |
| TC-USER-07 | FR-07 | EP | − | Gửi trực tiếp yêu cầu sửa với `username` rỗng | Từ chối | **Không đạt**: chỉ có `required` ở trình duyệt; server ghi chuỗi rỗng (`modal_edit_user.php:48–53`) |

| ID | Truy vết | KT | Loại | Điều kiện, dữ liệu và các bước | Kết quả mong đợi | Dự đoán trên baseline |
|---|---|---|---|---|---|---|
| TC-USER-08 | FR-08, UC-06 | EP | + | Bấm Delete, chọn Yes | Tài khoản bị xóa | **Đạt**: `delete_user_modal.php:7`; `delete_user.php:6` |
| TC-USER-09 | FR-08 | EP | − | Bấm Delete, chọn Close | Không xóa | **Đạt**: hộp thoại không gửi yêu cầu |
| TC-BOOK-01 | FR-11, UC-08 | EP | + | Nhập đủ chín trường hợp lệ, trạng thái New | Sách mới xuất hiện; `date_added` là thời điểm lưu | **Phụ thuộc cấu hình**: luồng ghi đúng (`books_save.php:20–21`) nhưng `date_receive` NOT NULL không được gán (Bảng 12) |
| TC-BOOK-02 | FR-11, BR-07 | EP | − | (a) Không chọn Status; (b) gửi trực tiếp `status` ngoài tập giá trị | Bị từ chối ở cả hai trường hợp | **Không đạt**: (a) chặn nhờ `required` (`add_books.php:85`); (b) server ghi giá trị bất kỳ |
| TC-BOOK-03 | FR-11 | EP | − | `book_copies` = `abc` | Từ chối: phải là số nguyên | **Phụ thuộc cấu hình**: ô văn bản (`add_books.php:54`), server không kiểm tra; MySQL đổi thành 0 hoặc báo lỗi tùy `sql_mode` |
| TC-BOOK-04 | FR-11 | BVA | – | `book_copies` lần lượt −1, 0, 1 | −1 bị từ chối; 0 và 1 được chấp nhận | **Không đạt**: không có cận dưới; −1 được ghi vào cột INT có dấu |
| TC-BOOK-05 | FR-11 | BVA | – | `book_title` dài 100 và 101 ký tự | 100: lưu đủ; 101: bị từ chối | **Phụ thuộc cấu hình**: không kiểm tra độ dài; xử lý 101 ký tự tùy `sql_mode` |
| TC-BOOK-06 | FR-11 | EP | − | Để trống Category (tùy chọn rỗng ở `add_books.php:29`) | Từ chối: danh mục bắt buộc | **Phụ thuộc cấu hình**: ô chọn không có `required` (`add_books.php:28`); chuỗi rỗng ghi vào cột INT tùy `sql_mode` |
| TC-BOOK-07 | FR-12, UC-09 | EP | + | Sửa `author` của một sách | Giá trị mới hiển thị ở `books.php` | **Đạt**: `update_books.php:20–21` |
| TC-BOOK-08 | FR-12 | EP | − | Mở `edit_book.php?id=` với ID không tồn tại | Thông báo không tìm thấy sách | **Không đạt**: hiển thị form rỗng, không báo lỗi (`edit_book.php:10–11`) |

| ID | Truy vết | KT | Loại | Điều kiện, dữ liệu và các bước | Kết quả mong đợi | Dự đoán trên baseline |
|---|---|---|---|---|---|---|
| TC-BOOK-09 | FR-13, BR-01, UC-10 | EP | + | Bấm Delete trên một sách, chọn Yes | Trạng thái thành Archive; sách biến khỏi `books.php`, kết quả tìm kiếm, màn hình lập phiếu | **Đạt**: `delete_books.php:4`; `books.php:55`; `advance_search.php:58`; `borrow.php:61` |
| TC-BOOK-10 | FR-13 | EP | − | Bấm Delete, chọn Close | Sách giữ nguyên trạng thái | **Đạt**: hộp thoại không gửi yêu cầu |
| TC-BOOK-11 | FR-14, NFR-11 | EP | + | Mở `archive.php` | Danh sách sách Archive, không có cảnh báo | **Không đạt**: include `navbar_archive.php` không tồn tại (`archive.php:3`); danh sách vẫn được truy vấn (`archive.php:37`) |
| TC-BOOK-12 | FR-14 | EP | − | Mở `archive.php` khi có sách New | Sách New không xuất hiện | **Đạt**: `archive.php:37` |
| TC-BOOK-13 | FR-10, UC-07 | EP | + | Mở lần lượt năm trang lọc trạng thái | Mỗi trang chỉ có sách đúng trạng thái | **Đạt**: các truy vấn hằng ở dòng 48 của năm tệp; so khớp nhờ collation mặc định không phân biệt hoa thường |
| TC-BOOK-14 | FR-10 | EP | − | Mở `new_books.php` khi có sách Old | Sách Old không xuất hiện | **Đạt**: `new_books.php:48` |
| TC-BOOK-15 | FR-09, BR-02 | BVA | + | Sách có `book_copies` = 3 và 1 chi tiết pending | Số bản còn lại hiển thị 2 | **Đạt**: `books.php:59–65, 77` |
| TC-BOOK-16 | BR-02, BR-11 | BVA | − | Sách có `book_copies` = 1 và 2 chi tiết pending | Số bản còn lại không âm; không cho mượn thêm (chờ BR-11) | **Không đạt**: hiển thị −1; không có ràng buộc (QS-05) |
| TC-BOOK-17 | NFR-14 | EP | + | Mở `books.php` khi JavaScript bật | Bảng có ô tìm kiếm, phân trang của DataTables | **Đạt**: `header.php:45–46` |
| TC-BOOK-18 | NFR-14 | EP | − | Tắt JavaScript, bấm Delete trên một sách | Không có thay đổi dữ liệu | **Đạt**: liên kết chỉ trỏ tới hộp thoại (`books.php:87`) |
| TC-SRCH-01 | FR-15, UC-11 | EP | + | Title và Author cùng khớp một sách chưa lưu trữ | Kết quả có sách đó | **Đạt**: `advance_search.php:58–59` |
| TC-SRCH-02 | FR-15 | EP | − | Title khớp một sách, để trống Author | Chỉ trả các sách có tiêu đề khớp | **Không đạt**: `author LIKE '%%'` khớp mọi sách nên trả toàn bộ sách chưa lưu trữ (QS-02) |
| TC-SRCH-03 | FR-15 | EP | − | Title và Author đều không khớp sách nào | Danh sách rỗng | **Đạt**: `advance_search.php:58–59` |

| ID | Truy vết | KT | Loại | Điều kiện, dữ liệu và các bước | Kết quả mong đợi | Dự đoán trên baseline |
|---|---|---|---|---|---|---|
| TC-SRCH-04 | FR-15, BR-01 | EP | – | Tìm theo tiêu đề của một sách Archive | Không trả sách Archive | **Đạt**: điều kiện `status != 'Archive'` có ở cả hai vế |
| TC-SRCH-05 | FR-15 | EP | – | Title chứa ký tự `%` hoặc `_` | Ký tự được hiểu theo nghĩa đen (chính sách cần xác nhận) | **Chờ xác nhận**: hiện được hiểu là ký tự đại diện của LIKE |
| TC-MEMB-01 | FR-16, UC-12 | EP | + | Mở `member.php` | Danh sách thành viên | **Đạt**: `member.php:31–43` |
| TC-MEMB-02 | FR-17, UC-13 | EP | + | Thêm thành viên đủ bảy trường hợp lệ, số điện thoại 11 chữ số | Thành viên mới xuất hiện, trạng thái Active | **Phụ thuộc cấu hình**: `member.status` NOT NULL không được gán (`member_save.php:15`) |
| TC-MEMB-03 | FR-17, BR-09 | EP | – | Số điện thoại chứa chữ cái | Từ chối | **Không đạt**: client chặn nhờ `pattern` (`add_member.php:47`); gửi trực tiếp thì server vẫn ghi |
| TC-MEMB-04 | BR-09 | BVA | – | Số điện thoại 10, 11, 12 chữ số | 10 và 12: từ chối; 11: chấp nhận | **Không đạt**: client chặn (10 do `pattern`, 12 do `maxlength`); server không kiểm tra |
| TC-MEMB-05 | FR-17, BR-08 | EP | – | Để trống Type | Từ chối | **Không đạt**: client chặn nhờ `required` (`add_member.php:53`); server không kiểm tra miền giá trị |
| TC-MEMB-06 | FR-18, UC-14 | EP | + | Sửa Address, giữ nguyên các trường khác | Chỉ Address thay đổi | **Không đạt**: Contact không được điền sẵn (`edit_member.php:48`) nên bị ghi đè thành rỗng (`update_member.php:9, 14`) (QS-01) |
| TC-MEMB-07 | FR-18, BR-08 | ST | + | Đổi trạng thái Active → Banned | Trạng thái thành Banned | **Đạt**: `edit_member.php:84–88`; `update_member.php:12, 14` |
| TC-MEMB-08 | FR-18, BR-08 | EP | – | Nhập Gender ngoài tập {Male, Female} ở form sửa | Từ chối | **Không đạt**: form sửa dùng ô văn bản (`edit_member.php:36`), khác ô chọn ở form thêm |

| ID | Truy vết | KT | Loại | Điều kiện, dữ liệu và các bước | Kết quả mong đợi | Dự đoán trên baseline |
|---|---|---|---|---|---|---|
| TC-MEMB-09 | FR-19, UC-15 | EP | + | Bấm Delete, chọn Yes | Thành viên bị xóa | **Đạt**: `delete_student_modal.php:7`; `delete_student.php:4` |
| TC-MEMB-10 | FR-19 | EP | – | Xóa thành viên đang có chi tiết mượn pending | Từ chối hoặc cảnh báo (quy tắc cần xác nhận) | **Chờ xác nhận**: xóa được; phiếu mượn còn lại mất liên kết vì không có khóa ngoại |
| TC-CIRC-01 | FR-20, BR-05, UC-16 | DT | + | Q2 (Bảng 23): thành viên Active, hạn trả hợp lệ, 2 sách còn bản | Một bản ghi `borrow` và 2 bản ghi `borrowdetails` pending | **Đạt** khi không có phiếu lập đồng thời: `borrow_save.php:17–28` |
| TC-CIRC-02 | FR-20, BR-04 | DT | – | Q1: không chọn sách nào | Quay lại `borrow.php`, không ghi dữ liệu | **Đạt**: `borrow_save.php:8–9` |
| TC-CIRC-03 | BR-03 | BVA | + | Trên giao diện, chọn 2 rồi 3 sách, thử chọn sách thứ 4 | Chọn được 2 và 3 sách; sách thứ 4 bị chặn | **Đạt** ở client: đủ 3 sách thì các ô còn lại bị vô hiệu (`borrow.php:93–104`) |
| TC-CIRC-04 | FR-20, BR-03 | DT | – | Q3: gửi trực tiếp POST có 4 sách | Server từ chối phiếu vượt 3 sách | **Không đạt**: server ghi đủ 4 chi tiết (`borrow_save.php:23–28`) |
| TC-CIRC-05 | BR-10 | BVA | – | Hạn trả là hôm qua, hôm nay, ngày mai | Hôm qua bị từ chối | **Không đạt**: bộ chọn ngày chặn ngày đã qua (`borrow.php:32`) nhưng server không kiểm tra |
| TC-CIRC-06 | FR-20 | EP | – | Gửi trực tiếp `due_date` không phải ngày | Từ chối | **Không đạt**: chuỗi bất kỳ được ghi vào `borrow.due_date` |
| TC-CIRC-07 | BR-11 | DT | – | Q4: lập phiếu cho sách đã hết bản | Chờ xác nhận BR-11 | **Chờ xác nhận**: phiếu được ghi; số bản còn lại thành âm |
| TC-CIRC-08 | BR-13 | DT | – | Q5: lập phiếu cho thành viên Banned | Chờ xác nhận BR-13 | **Chờ xác nhận**: phiếu được ghi; `borrow.php:22` liệt kê mọi thành viên |
| TC-CIRC-09 | BR-12 | EP | – | Thành viên đã có 3 chi tiết pending lập thêm phiếu 3 sách | Chờ xác nhận hạn mức BR-12 | **Chờ xác nhận**: không có giới hạn tổng |
| TC-CIRC-10 | FR-22, BR-06, UC-17 | ST | + | Trả một chi tiết pending | pending → returned; `date_return` là thời điểm trả | **Đạt**: `return_save.php:7` |

| ID | Truy vết | KT | Loại | Điều kiện, dữ liệu và các bước | Kết quả mong đợi | Dự đoán trên baseline |
|---|---|---|---|---|---|---|
| TC-CIRC-11 | BR-06 | ST | – | Trả lại một chi tiết đã returned | Từ chối; `date_return` giữ nguyên | **Không đạt**: nút Return có ở mọi dòng (`view_borrow.php:46`); `date_return` bị ghi đè |
| TC-CIRC-12 | FR-22 | EP | – | Gọi trả sách với cặp `id`, `book_id` không tồn tại | Thông báo không tìm thấy | **Không đạt**: không dòng nào được cập nhật nhưng vẫn chuyển hướng như thành công (`return_save.php:7–8`) |
| TC-CIRC-13 | FR-21, FR-23, UC-18 | EP | + | Sau TC-CIRC-10, mở `view_borrow.php` và `return.php` | Chi tiết vừa trả có trạng thái returned và xuất hiện ở `return.php` | **Đạt**: `view_borrow.php:24–29`; `return.php:26–31` |
| TC-CIRC-14 | FR-23 | EP | – | Mở `return.php` khi có chi tiết pending | Chi tiết pending không xuất hiện | **Đạt**: điều kiện `borrow_status = 'returned'` (`return.php:30`) |
| TC-CIRC-15 | BR-14 | EP | – | Có chi tiết pending đã quá `due_date` | Chờ xác nhận BR-14 (đánh dấu quá hạn, tính phạt) | **Chờ xác nhận**: không có chức năng; `due_date` lưu dạng chuỗi |
| TC-CIRC-16 | BR-15 | EP | – | Đổi trạng thái một sách sang Lost qua form sửa | Chờ xác nhận BR-15 (ghi vào bảng sách mất) | **Chờ xác nhận**: chỉ đổi `book.status`; bảng `lost_book` không được dùng |
| TC-FIND01-R | FIND-01, NFR-01 | SEC | R | Đăng nhập với username chứa một ký tự nháy đơn | Dữ liệu được xử lý như giá trị; "Access Denied", không có lỗi CSDL | **Không đạt**: câu SQL lỗi cú pháp và thông báo lỗi CSDL hiển thị, cho thấy dữ liệu làm đổi cấu trúc truy vấn (`index.php:38–39`) |
| TC-FIND01-H | FIND-01, NFR-01 | SEC | H | Sau sửa: lặp lại TC-FIND01-R; đăng nhập đúng; đăng nhập sai với tài khoản đã băm mật khẩu | Truy vấn tham số; đúng thì vào được, sai bị từ chối; không lộ lỗi CSDL | **Không đạt** (chưa sửa) |
| TC-FIND02-R | FIND-02, NFR-02 | SEC | R | Không có phiên; gửi trực tiếp POST hợp lệ (dữ liệu thử) tới `books_save.php` | Yêu cầu bị từ chối, không ghi dữ liệu | **Không đạt**: bản ghi được tạo vì handler chỉ include `dbcon.php` (`books_save.php:2–24`) |

| ID | Truy vết | KT | Loại | Điều kiện, dữ liệu và các bước | Kết quả mong đợi | Dự đoán trên baseline |
|---|---|---|---|---|---|---|
| TC-FIND02-H | FIND-02, NFR-02 | SEC | H | Sau sửa: lặp lại với cả 12 handler, khi không có phiên và khi có phiên hợp lệ | Không có phiên: từ chối, CSDL không đổi; có phiên: thao tác thực hiện bình thường | **Không đạt** (chưa sửa) |
| TC-FIND03-R | FIND-03, NFR-03 | SEC | R | Thêm sách có `author` chứa một ký tự nháy đơn | Giá trị được lưu nguyên văn | **Không đạt**: lỗi cú pháp SQL tại `books_save.php:20–21`, thông báo lỗi CSDL hiển thị |
| TC-FIND03-H | FIND-03, NFR-03 | SEC | H | Sau sửa: lặp lại với từng tham số của 23 truy vấn nhận dữ liệu HTTP (Phụ lục D.2); gửi ID không phải số nguyên dương | Giá trị có ký tự đặc biệt được lưu, so khớp nguyên văn; ID sai kiểu bị từ chối trước khi truy vấn | **Không đạt** (chưa sửa) |
| TC-FIND04-R | FIND-04, NFR-04 | SEC | R | Thêm sách có tiêu đề chứa thẻ in nghiêng (ví dụ `<i>thu</i>`); mở `books.php`, `edit_book.php` | Thẻ hiển thị nguyên văn dạng văn bản | **Không đạt**: tiêu đề hiển thị in nghiêng vì không mã hóa đầu ra (`books.php:74`; `edit_book.php:23`) |
| TC-FIND04-H | FIND-04, NFR-04 | SEC | H | Sau sửa: lặp lại với tiêu đề, tác giả, tên thành viên chứa thẻ HTML và dấu nháy kép ở mọi trang danh sách, form sửa và tham số `id` trên URL | Mọi giá trị hiển thị nguyên văn; giá trị có dấu nháy kép hiển thị đủ trong ô nhập | **Không đạt** (chưa sửa) |
| TC-FIND05-R | FIND-05, NFR-05 | SEC | R | Mở `users.php` và hộp thoại Edit của một tài khoản | Không có mật khẩu nào hiển thị | **Không đạt**: cột Password (`users.php:44`) và ô văn bản (`modal_edit_user.php:15`) hiển thị mật khẩu bản rõ |
| TC-FIND05-H | FIND-05, NFR-05 | SEC | H | Sau sửa: tạo tài khoản mới; xem cột `password` trong CSDL thử; đăng nhập đúng và sai | CSDL lưu chuỗi băm; giao diện không hiển thị mật khẩu; đăng nhập xác minh qua hàm băm | **Không đạt** (chưa sửa) |
| TC-FIND06-R | FIND-06, NFR-06 | SEC | R | Đang có phiên hợp lệ; từ một trang thử nghiệm khác nguồn, gửi GET tới `delete_books.php?id=<ID sách thử>` | Yêu cầu bị từ chối | **Không đạt**: sách chuyển sang Archive mà không qua hộp thoại (`delete_books.php:3–5`) |

| ID | Truy vết | KT | Loại | Điều kiện, dữ liệu và các bước | Kết quả mong đợi | Dự đoán trên baseline |
|---|---|---|---|---|---|---|
| TC-FIND06-H | FIND-06, NFR-06 | SEC | H | Sau sửa: với 5 handler đang nhận GET, gửi GET, POST thiếu token, POST sai token, POST đúng token | Chỉ POST có token hợp lệ được thực hiện | **Không đạt** (chưa sửa) |
| TC-FIND07-R | FIND-07, NFR-07, BR-05 | SEC | R | Hai phiên lập phiếu gần đồng thời; dùng điểm dừng của trình gỡ lỗi giữ phiên A sau câu INSERT | Chi tiết của mỗi phiếu gắn đúng `borrow_id` của phiếu đó | **Không đạt**: phiên A có thể đọc `borrow_id` của phiếu B (`borrow_save.php:17–20`) |
| TC-FIND07-H | FIND-07, NFR-07 | SEC | H | Sau sửa: lặp lại TC-FIND07-R; gây lỗi ở lần ghi chi tiết thứ hai | Mỗi chi tiết gắn đúng phiếu; khi lỗi, phiếu và mọi chi tiết đều được hoàn tác | **Không đạt** (chưa sửa) |
| TC-FIND08-R | FIND-08, NFR-08 | SEC | R | Xem cấu hình kết nối mà ứng dụng dùng khi chạy | Cấu hình lấy từ ngoài mã; tài khoản không phải `root` | **Không đạt**: `root`, mật khẩu rỗng cố định tại `dbcon.php:2` |
| TC-FIND08-H | FIND-08, NFR-08 | SEC | H | Sau sửa: đổi biến môi trường cấu hình; thử một thao tác DDL bằng tài khoản ứng dụng | Ứng dụng dùng cấu hình mới mà không sửa mã; thao tác DDL bị từ chối | **Không đạt** (chưa sửa) |
| TC-FIND09-R | FIND-09, NFR-09 | SEC | R | Triển khai baseline trên PHP 8.x | Mọi trang hoạt động | **Không đạt**: hàm `mysql_connect` không tồn tại từ PHP 7.0 [4] (`dbcon.php:2`) |
| TC-FIND09-H | FIND-09, NFR-09 | SEC | H | Sau sửa: chạy toàn bộ test case chức năng trên phiên bản PHP mục tiêu | Các test case chức năng cho kết quả như kỳ vọng | **Không đạt** (chưa sửa) |
| TC-FIND10-R | FIND-10, NFR-10 | SEC | R | Gây lỗi truy vấn bằng dữ liệu của TC-FIND03-R | Thông báo chung, không có chi tiết CSDL | **Không đạt**: `die(mysql_error())` in lỗi ra trang |
| TC-FIND10-H | FIND-10, NFR-10 | SEC | H | Sau sửa: gây lỗi truy vấn ở các luồng chính; xem log máy chủ | Người dùng thấy thông báo chung và mã tham chiếu; chi tiết chỉ có trong log | **Không đạt** (chưa sửa) |
| TC-FIND11-R | FIND-11, NFR-11 | SEC | R | Mở `archive.php` và `unstudents.php` | Không có cảnh báo include hay lỗi bảng | **Không đạt**: include thiếu (`archive.php:3`; `unstudents.php:3, 44`); bảng `students` không tồn tại (`unstudents.php:29`) |

| ID | Truy vết | KT | Loại | Điều kiện, dữ liệu và các bước | Kết quả mong đợi | Dự đoán trên baseline |
|---|---|---|---|---|---|---|
| TC-FIND11-H | FIND-11, NFR-11 | SEC | H | Sau sửa: chạy PHPStan level 0 và lint; mở mọi trang có liên kết | Không còn thông báo include thiếu, không còn tệp rỗng | **Không đạt** (chưa sửa) |

### *7.3.6* Phụ lục F – Ma trận truy vết

Bảng 60 truy vết 52 yêu cầu (23 FR, 15 BR, 14 NFR) tới bộ test case động ở Phụ lục E và tới bộ kiểm tra tĩnh trong tệp Excel. Cột "Tin cậy" lấy từ Bảng 9 đến Bảng 11. Bảng 61 truy vết 11 phát hiện tới tiêu chí checklist, yêu cầu và test case. Tỷ lệ phủ yêu cầu là 52/52 (100%), tỷ lệ phủ use-case là 18/18 (100%), tỷ lệ phủ phát hiện (đủ cặp R và H) là 11/11 (100%).

***Bảng** 60. Ma trận truy vết yêu cầu → test case*

| Yêu cầu | Tin cậy | Test case hợp lệ (+) | Test case không hợp lệ (−), tái hiện (R) | Kiểm tra tĩnh (Excel) |
|---|---|---|---|---|
| FR-01 | R | TC-AUTH-01 | TC-AUTH-04 | — |
| FR-02 | R | TC-AUTH-01 | TC-AUTH-02, TC-AUTH-03 | — |
| FR-03 | R | TC-AUTH-06 | TC-AUTH-05 | — |
| FR-04 | R | TC-AUTH-07 | TC-AUTH-08 | — |
| FR-05 | R | TC-USER-01 | TC-AUTH-05 | — |
| FR-06 | R | TC-USER-02, TC-USER-04 | TC-USER-03, TC-USER-05 | — |
| FR-07 | R | TC-USER-06 | TC-USER-07 | — |
| FR-08 | R | TC-USER-08 | TC-USER-09 | — |
| FR-09 | R | TC-BOOK-15 | TC-AUTH-05 | — |
| FR-10 | R | TC-BOOK-13 | TC-BOOK-14 | — |
| FR-11 | R | TC-BOOK-01 | TC-BOOK-02, TC-BOOK-03, TC-BOOK-04, TC-BOOK-05, TC-BOOK-06 | — |
| FR-12 | R | TC-BOOK-07 | TC-BOOK-08 | — |
| FR-13 | R | TC-BOOK-09 | TC-BOOK-10 | — |
| FR-14 | S | TC-BOOK-11 | TC-BOOK-12 | — |
| FR-15 | R | TC-SRCH-01 | TC-SRCH-02, TC-SRCH-03, TC-SRCH-04, TC-SRCH-05 | — |
| FR-16 | R | TC-MEMB-01 | TC-AUTH-05 | — |
| FR-17 | R | TC-MEMB-02 | TC-MEMB-03, TC-MEMB-05 | — |
| FR-18 | R | TC-MEMB-06, TC-MEMB-07 | TC-MEMB-08 | — |
| FR-19 | R | TC-MEMB-09 | TC-MEMB-10 | — |
| FR-20 | R | TC-CIRC-01 | TC-CIRC-02, TC-CIRC-04, TC-CIRC-06 | — |
| FR-21 | R | TC-CIRC-13 | TC-AUTH-05 | — |
| FR-22 | R | TC-CIRC-10 | TC-CIRC-12 | — |
| FR-23 | R | TC-CIRC-13 | TC-CIRC-14 | — |
| BR-01 | R | TC-BOOK-09 | TC-SRCH-04 | — |
| BR-02 | R | TC-BOOK-15 | TC-BOOK-16 | — |
| BR-03 | R | TC-CIRC-03 | TC-CIRC-04 | — |
| BR-04 | R | — | TC-CIRC-02 | — |

| Yêu cầu | Tin cậy | Test case hợp lệ (+) | Test case không hợp lệ (−), tái hiện (R) | Kiểm tra tĩnh (Excel) |
|---|---|---|---|---|
| BR-05 | R | TC-CIRC-01 | TC-FIND07-R | — |
| BR-06 | R | TC-CIRC-10 | TC-CIRC-11 | — |
| BR-07 | R | — | TC-BOOK-02 | — |
| BR-08 | R | TC-MEMB-07 | TC-MEMB-05, TC-MEMB-08 | — |
| BR-09 | R | — | TC-MEMB-03, TC-MEMB-04 | — |
| BR-10 | S | — | TC-CIRC-05 | — |
| BR-11 | C | — | TC-BOOK-16, TC-CIRC-07 | — |
| BR-12 | C | — | TC-CIRC-09 | — |
| BR-13 | C | — | TC-CIRC-08 | — |
| BR-14 | C | — | TC-CIRC-15 | — |
| BR-15 | C | — | TC-CIRC-16 | — |
| NFR-01 | S | TC-FIND01-H | TC-FIND01-R | TC-01 |
| NFR-02 | S | TC-FIND02-H | TC-FIND02-R | TC-02, TC-16 |
| NFR-03 | S | TC-FIND03-H | TC-FIND03-R | TC-03 |
| NFR-04 | S | TC-FIND04-H | TC-FIND04-R | TC-04 |
| NFR-05 | S | TC-FIND05-H | TC-FIND05-R | TC-05 |
| NFR-06 | S | TC-FIND06-H | TC-FIND06-R | TC-06 |
| NFR-07 | S | TC-FIND07-H | TC-FIND07-R | TC-07 |
| NFR-08 | S | TC-FIND08-H | TC-FIND08-R | TC-08 |
| NFR-09 | R | TC-FIND09-H | TC-FIND09-R | TC-09 |
| NFR-10 | S | TC-FIND10-H | TC-FIND10-R | TC-10 |
| NFR-11 | R | TC-BOOK-11, TC-FIND11-H | TC-FIND11-R | TC-11 |
| NFR-12 | S | — | TC-AUTH-09 | — |
| NFR-13 | S | — | TC-AUTH-10 | — |
| NFR-14 | R | TC-BOOK-17 | TC-BOOK-18 | — |

***Bảng** 61. Ma trận truy vết phát hiện → yêu cầu → test case*

| Phát hiện | Checklist | Yêu cầu | Test case tái hiện, liên quan | Test case hồi quy (H) | Kiểm tra tĩnh (Excel) |
|---|---|---|---|---|---|
| FIND-01 | AUTH-01 | REQ-L01, NFR-01 | TC-FIND01-R | TC-FIND01-H | TC-01 |
| FIND-02 | AC-02, AC-04 | REQ-L02, NFR-02 | TC-FIND02-R | TC-FIND02-H | TC-02, TC-16 |
| FIND-03 | AC-04, INP-01, INP-02, INP-03 | REQ-L03, NFR-03 | TC-FIND03-R | TC-FIND03-H | TC-03 |
| FIND-04 | OUT-01, OUT-02, OUT-03 | REQ-L04, NFR-04 | TC-FIND04-R | TC-FIND04-H | TC-04 |

| Phát hiện | Checklist | Yêu cầu | Test case tái hiện, liên quan | Test case hồi quy (H) | Kiểm tra tĩnh (Excel) |
|---|---|---|---|---|---|
| FIND-05 | AUTH-02, ERR-03 | REQ-L05, NFR-05 | TC-FIND05-R | TC-FIND05-H | TC-05 |
| FIND-06 | STATE-01, STATE-02, STATE-03 | REQ-L06, NFR-06 | TC-FIND06-R | TC-FIND06-H | TC-06 |
| FIND-07 | BIZ-03 | REQ-L07, NFR-07 | TC-FIND07-R | TC-FIND07-H | TC-07 |
| FIND-08 | ERR-03 | REQ-L08, NFR-08 | TC-FIND08-R | TC-FIND08-H | TC-08 |
| FIND-09 | — | REQ-L09, NFR-09 | TC-FIND09-R | TC-FIND09-H | TC-09 |
| FIND-10 | ERR-01 | REQ-L10, NFR-10 | TC-FIND10-R | TC-FIND10-H | TC-10 |
| FIND-11 | — | REQ-L11, NFR-11 | TC-FIND11-R | TC-FIND11-H | TC-11 |

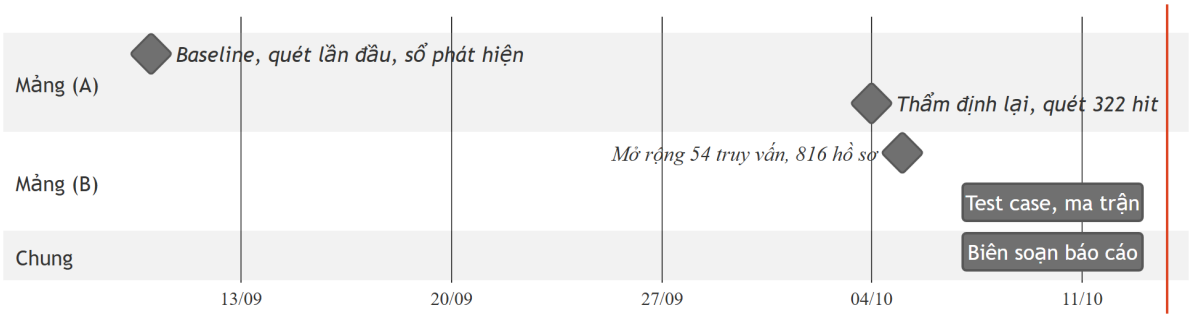
### *7.3.7* Phụ lục G – Các thành phần dự án theo template

## G.1 Kế hoạch dự án

Kế hoạch được tổ chức theo 16 gói công việc A1 đến D4 ở trang "Phân công thực hiện đồ án". Bảng 62 ghi các mốc có bằng chứng trong hồ sơ: thời điểm commit, thời điểm lấy mã, ngày ghi trên bìa báo cáo PDF và ngày tạo tệp báo cáo. Hồ sơ không lưu ngày bắt đầu của từng gói công việc. Vì vậy Hình 18 chỉ thể hiện các mốc đó, không vẽ thanh thời gian ước đoán.

***Bảng** 62. Các mốc thực hiện có bằng chứng trong hồ sơ*

| Ngày | Mốc | Gói công việc | Bằng chứng |
|---|---|---|---|
| 10/09/2026 | Lấy baseline, kiểm kê phạm vi, lập checklist, chọn công cụ, quét lần đầu (270 hit), lập sổ phát hiện | A1 đến A5 | `baseline.md`, `scan_meta.json`, commit `bfbc61d` [16] |
| 04/10/2026 | Thẩm định lại: sửa rule, quét lại hai lần (322 hit), checklist 27 tiêu chí, 12 handler; mã sinh và mô hình hình thức | A2 đến A5 | Bìa báo cáo PDF, mục 5.6 [18] |
| 05/10/2026 | Bản mở rộng: 54 cặp truy vấn, 92 tham số, sổ 816 hồ sơ case | B3 đến B5 | Bìa báo cáo PDF, mục 5.7 [18] |
| 07/10/2026 đến 13/10/2026 | Biên soạn báo cáo theo template: đặc tả, mô hình, test case động, ma trận truy vết | B1 đến B5, C1 | Các tệp nguồn của báo cáo này |




***Hình** 18. Các mốc thực hiện có bằng chứng*

## G.2 Đảm bảo thực hiện đúng làm việc nhóm

Hồ sơ cho thấy nhóm dùng các cơ chế sau để giữ chất lượng khi làm việc chung:

- **Một kho hồ sơ chung có lịch sử phiên bản** [16]. Baseline, checklist, cấu hình công cụ, output thô và sổ phát hiện cùng nằm trong một kho, nên mọi thành viên làm việc trên cùng một dữ liệu.

- **Danh sách công việc có tiêu chí hoàn thành.** Kế hoạch nghiên cứu được chia thành 5 nhóm việc với 21 đầu việc, mỗi đầu việc ghi rõ sản phẩm đầu ra. Một kết luận chỉ được đóng khi có bằng chứng.
- **Duyệt từng phần trước khi đi tiếp.** Báo cáo được viết theo từng phần. Mỗi phần có ghi chú duyệt riêng, không in vào báo cáo, ghi lại các điểm đã đối chiếu và hiệu chỉnh, ví dụ số dòng lệch trong hồ sơ cũ.
- **Kiểm tra chéo số liệu.** Mỗi con số được đối chiếu với ít nhất hai nguồn: output công cụ, mã nguồn, tệp Excel hoặc báo cáo PDF. Chênh lệch được ghi và giải thích, như các cặp 270 và 322, 25 và 27 tiêu chí, 8 và 12 handler.

Phân công theo gói công việc. Bảng phân công ở đầu báo cáo ghi mã gói công việc mà từng thành viên phụ trách.

### G.3 Kế hoạch cho kiến thức mới và chiến lược học tập

Đồ án đòi hỏi các kiến thức nằm ngoài nội dung lập trình web thông thường. Bảng 63 liệt kê các kiến thức đó và cách nhóm tiếp cận.

***Bảng** 63. Kiến thức mới và chiến lược học tập*

| Kiến thức | Chiến lược học tập | Vận dụng trong đồ án |
|---|---|---|
| Phân loại điểm yếu theo CWE, OWASP Top 10, ASVS | Đọc định nghĩa gốc trên trang MITRE, OWASP; đối chiếu từng phát hiện với định nghĩa trước khi gán mã | Gán CWE cho 11 phát hiện; câu hỏi của checklist |
| Viết rule và đọc output Semgrep | Học từ tài liệu chính thức [7]; thử trên tập tệp nhỏ trước khi quét toàn bộ; luôn đọc mã thoát cùng trường `errors` | 4 rule tùy biến; phát hiện và sửa lỗi parse rule |
| Phân tích kiểu và cấu trúc bằng PHPStan | Đọc hướng dẫn [8]; dùng stub thay vì sửa mã nguồn | Phát hiện 3 include thiếu |
| Kỹ thuật thiết kế test case theo ISO/IEC/IEEE 29119 | Học từ chuẩn [10], [14] và Myers [13]; luyện trên một use-case trước khi áp dụng cho toàn bộ | 90 test case động; bảng quyết định; mô hình chuyển trạng thái |
| Đặc tả yêu cầu theo ISO/IEC/IEEE 29148 | Học các đặc tính của yêu cầu tốt [12]; áp dụng mức tin cậy cho đặc tả suy ngược | 23 FR, 15 BR, 14 NFR |
| Logic mệnh đề, SAT, SMT | Học thuật toán DPLL [21] và Z3 [22]; đối chiếu ba bộ kiểm tra trên cùng công thức | 178 bài toán SAT, 562 bài toán SMT |

Chiến lược chung là học qua tài liệu gốc và kiểm chứng bằng thực nghiệm nhỏ trước khi áp dụng diện rộng. Mọi kết quả học được đều ghi lại thành hồ sơ trong kho chung để thành viên khác dùng lại.

### *7.3.8* Phụ lục H – Mô hình trạng thái và so sánh trước, sau khi sửa

Hai bảng dưới đây bổ sung cho mục 5.1.6. Dữ liệu lấy từ các sheet MoHinhTrangThai và ThuocTinhAnToan của tệp Excel [18] và từ các tệp auth_model.json, generated_static_results.json, sql_case_results.json, formal_results.json trong thư mục evidence/ của gói nộp.

***Bảng** 64. Mô hình Kripke của luồng xác thực và kết quả kiểm tra CTL*

| Thành phần | Nội dung | Kết quả trên baseline | Giới hạn |
|---|---|---|---|
| Cấu trúc Kripke | 5 trạng thái: unauthenticated (khởi tạo) chuyển tới denied, authenticated, unauthorized_write; authenticated chuyển tới authorized_write. Nhãn: authenticated, write, denied, violation | Cả 5 trạng thái đạt được | Dựng thủ công từ session.php:5–7, login.php:10–12, delete_user.php:2–6; vòng tự lặp ở trạng thái cuối do mô hình thêm |
| AG(write → authenticated) | Mọi thao tác ghi xảy ra sau khi xác thực | VI PHẠM. Phản ví dụ: unauthenticated → unauthorized_write (FIND-02) | Giả định endpoint gọi trực tiếp được và truy vấn thành công |
| EF(denied), EF(authenticated) | Cả hai nhánh đăng nhập đều đạt được | THỎA | Không chứng minh tính sống của hệ thống thật |

***Bảng** 65. So sánh trước sửa (_v0) và sau sửa (_v1) trên mã minh họa*

| Phép kiểm tra | _v0 (trước sửa) | _v1 (sau sửa) | Nguồn |
|---|---|---|---|
| Semgrep, 6 rule cho mã sinh, 5 cặp chức năng | 8 hit | 0 hit | generated_static_results.json |
| Semgrep, cùng bộ rule, 54 cặp wrapper SQL | 54 hit (gồm cả truy vấn hằng) | 0 hit; lint 109/109 tệp | sql_case_results.json |
| CNF 5 thuộc tính: đăng nhập, phân quyền, truy vấn, token, xuất script | SAT (có phản ví dụ) | UNSAT; đối chứng hợp lệ SAT | formal_results.json |
| CNF executed → all_bound cho 54 truy vấn | 35 truy vấn có tham số SAT; 19 truy vấn hằng UNSAT | 54 UNSAT; 54 đối chứng SAT | sql_case_results.json |
| SMT guard token (Int, Bool) | SAT | Vi phạm UNSAT; đối chứng SAT | formal_results.json |